invicti

28/03/2026 4:57:29 AM (UTC+05:00)

Detailed Scan Report

http://150.1.7.104/dvwa/login.php

Scan Time	: 28/03/2026 12:53:29 AM (UTC+05:00)
Scan Duration	: 00:03:42:48
Total Requests	: 22,539
Average Speed	: 1.7r/s

Risk Level:
CRITICAL

23 IDENTIFIED	7 CONFIRMED	2 CRITICAL
1 HIGH	1 MEDIUM	9 LOW
	3 BEST PRACTICE	7 INFORMATION

Identified Vulnerabilities

Critical	2
High	1
Medium	1
Low	9
Best Practice	3
Information	7
TOTAL	**23**

Confirmed Vulnerabilities

Critical	0
High	1
Medium	0
Low	4
Best Practice	1
Information	1
TOTAL	**7**

Vulnerability Summary

CONFIRM	VULNERABILITY	METHOD	URL	PARAMETER	PARAMETER TYPES
	Out-of-date Version (Apache)	GET	http://150.1.7.104/dvwa/login.php	No Parameters	No Parameter Types
	Out-of-date Version (PHP)	GET	http://150.1.7.104/dvwa/login.php	No Parameters	No Parameter Types
	Password Transmitted over HTTP	GET	http://150.1.7.104/dvwa/login.php	No Parameters	No Parameter Types
	SSL/TLS Not Implemented	GET	https://150.1.7.104/dvwa/login.php	No Parameters	No Parameter Types
	Apache MultiViews Enabled	HEAD	http://150.1.7.104/dvwa/login	No Parameters	No Parameter Types
	Missing X-Content-Type-Options Header	GET	http://150.1.7.104/dvwa/login.php	No Parameters	No Parameter Types
	Programming Error Message	GET	http://150.1.7.104/dvwa/dvwa/includes/dvwaPage.inc.php	No Parameters	No Parameter Types
	Version Disclosure (Apache)	GET	http://150.1.7.104/dvwa/login.php	No Parameters	No Parameter Types
	Version Disclosure (PHP)	GET	http://150.1.7.104/dvwa/login.php	No Parameters	No Parameter Types
	Autocomplete is Enabled	GET	http://150.1.7.104/dvwa/login.php	No Parameters	No Parameter Types
	Cookie Not Marked as HttpOnly	GET	http://150.1.7.104/dvwa/login.php	No Parameters	No Parameter Types

CONFIRM	VULNERABILITY	METHOD	URL	PARAMETER	PARAMETER TYPES
	Internal Server Error	GET	http://150.1.7.104/dvwa/dvwa/includes/DBMS/PGSQL.php	No Parameters	No Parameter Types
	TRACE/TRACK Method Detected	TRACE	http://150.1.7.104/dvwa/	No Parameters	No Parameter Types
	Referrer-Policy Not Implemented	GET	http://150.1.7.104/dvwa/login.php	No Parameters	No Parameter Types
	SameSite Cookie Not Implemented	GET	http://150.1.7.104/dvwa/login.php	No Parameters	No Parameter Types
	Content Security Policy (CSP) Not Implemented	GET	http://150.1.7.104/dvwa/login.php	No Parameters	No Parameter Types
	[Possible] Internal Path Disclosure (*nix)	GET	http://150.1.7.104/dvwa/dvwa/includes/dvwaPage.inc.php	No Parameters	No Parameter Types
	[Possible] Login Page Identified	GET	http://150.1.7.104/dvwa/login.php	No Parameters	No Parameter Types
	Apache Web Server Identified	GET	http://150.1.7.104/dvwa/login.php	No Parameters	No Parameter Types
	Directory Listing (Apache)	GET	http://150.1.7.104/dvwa/dvwa/	No Parameters	No Parameter Types
	Email Address Disclosure	GET	http://150.1.7.104/dvwa/login.php@r87.com	No Parameters	No Parameter Types
	PHP Identified	GET	http://150.1.7.104/dvwa/login.php	No Parameters	No Parameter Types

CONFIRM	VULNERABILITY	METHOD	URL	PARAMETER	PARAMETER TYPES
	Forbidden Resource	GET	http://150.1.7.104/dvwa/(%23_memberAccess%3d@ognl.OgnlContext@DEFAULT_MEMBER_ACCESS)%3f(%23wr%3d%23context%5b%23parameters.obj%5b0%5d%5d.getWriter(),%23rs%3d@org.apache.commons.io.IOUtils@toString(@java.lang.Runtime@getRuntime().exec(%23parameters.command[0]).getInputStream()),%23wr.println(%23rs),%23wr.flush(),%23wr.close()):xx.toString.json?&obj=com.opensymphony.xwork2.dispatcher.HttpServletResponse&command=expr%20268409241%20-%2059770	No Parameters	No Parameter Types

1. Out-of-date Version (Apache)

CRITICAL | 1

Invicti Standard identified you are using an out-of-date version of Apache.

Impact

Since this is an old version of the software, it may be vulnerable to attacks.

Apache HTTP Server Improper Input Validation Vulnerability

In Apache httpd before 2.2.34 and 2.4.x before 2.4.27, the value placeholder in [Proxy-]Authorization headers of type 'Digest' was not initialized or reset before or between successive key=value assignments by mod_auth_digest. Providing an initial key with no '=' assignment could reflect the stale value of uninitialized pool memory used by the prior request, leading to leakage of potentially confidential information, and a segfault in other cases resulting in denial of service.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

External References

- CVE-2017-9788

Apache HTTP Server Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

In Apache httpd 2.2.x before 2.2.33 and 2.4.x before 2.4.26, mod_mime can read one byte past the end of a buffer when sending a malicious Content-Type response header.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2017-7679

Apache HTTP Server Server-Side Request Forgery (SSRF) Vulnerability

A crafted request uri-path can cause mod_proxy to forward the request to an origin server choosen by the remote user. This issue affects Apache HTTP Server 2.4.48 and earlier.

Affected Versions

0.8.14 to

CVSS

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H

External References

- CVE-2021-40438

Apache HTTP Inconsistent Interpretation of HTTP Requests ('HTTP Request Smuggling') Server Vulnerability

Apache HTTP Server 2.4.52 and earlier fails to close inbound connection when errors are encountered discarding the request body, exposing the server to HTTP Request Smuggling

External References

- CVE-2022-22720

Apache HTTP Server Out-of-bounds Write Vulnerability

A carefully crafted request body can cause a buffer overflow in the mod_lua multipart parser (r:parsebody() called from Lua scripts). The Apache httpd team is not aware of an exploit for the vulnerabilty though it might be possible to craft one. This issue affects Apache HTTP Server 2.4.51 and earlier.

External References

- CVE-2021-44790

Apache HTTP Server Insufficient Verification of Data Authenticity Vulnerability

Apache HTTP Server 2.4.53 and earlier may not send the X-Forwarded-* headers to the origin server based on client side Connection header hop-by-hop mechanism. This may be used to bypass IP based authentication on the origin server/application.

Affected Versions

0.8.14 to

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2022-31813

Apache HTTP Server Integer Overflow or Wraparound Vulnerability

Apache HTTP Server 2.4.53 and earlier may crash or disclose information due to a read beyond bounds in ap_strcmp_match() when provided with an extremely large input buffer. While no code distributed with the server can be coerced into such a call, third-party modules or lua scripts that use ap_strcmp_match() may hypothetically be affected.

Affected Versions

0.8.14 to

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

External References

- CVE-2022-28615

Apache HTTP Server Out-of-bounds Write Vulnerability

ap_escape_quotes() may write beyond the end of a buffer when given malicious input. No included modules pass untrusted data to these functions, but third-party / external modules may. This issue affects Apache HTTP Server 2.4.48 and earlier.

Affected Versions

0.8.14 to

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2021-39275

Apache HTTP Server Integer Overflow or Wraparound Vulnerability

If LimitXMLRequestBody is set to allow request bodies larger than 350MB (defaults to 1M) on 32 bit systems an integer overflow happens which later causes out of bounds writes. This issue affects Apache HTTP Server 2.4.52 and earlier.

Affected Versions

0.8.14 to

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2022-22721

Apache HTTP Server CVE-2010-0425 Vulnerability

modules/arch/win32/mod_isapi.c in mod_isapi in the Apache HTTP Server 2.0.37 through 2.0.63, 2.2.0 through 2.2.14, and 2.3.x before 2.3.7, when running on Windows, does not ensure that request processing is complete before calling isapi_unload for an ISAPI .dll module, which allows remote attackers to execute arbitrary code via unspecified vectors related to a crafted request, a reset packet, and "orphaned callback pointers."

CVSS

AV:N/AC:L/Au:N/C:C/I:C/A:C

External References

- CVE-2010-0425

Apache HTTP Server Improper Locking Vulnerability

The Solaris pollset feature in the Event Port backend in poll/unix/port.c in the Apache Portable Runtime (APR) library before 1.3.9, as used in the Apache HTTP Server before 2.2.14 and other products, does not properly handle errors, which allows remote attackers to cause a denial of service (daemon hang) via unspecified HTTP requests, related to the prefork and event MPMs.

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2009-2699

Apache HTTP Server Improper Restriction of Recursive Entity References in DTDs ('XML Entity Expansion') Vulnerability

The expat XML parser in the apr_xml_* interface in xml/apr_xml.c in Apache APR-util before 1.3.7, as used in the mod_dav and mod_dav_svn modules in the Apache HTTP Server, allows remote attackers to cause a denial of service (memory consumption) via a crafted XML document containing a large number of nested entity references, as demonstrated by a PROPFIND request, a similar issue to CVE-2003-1564.

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2009-1955

Apache HTTP Server Use After Free Vulnerability

Apache httpd allows remote attackers to read secret data from process memory if the Limit directive can be set in a user's .htaccess file, or if httpd.conf has certain misconfigurations, aka Optionsbleed. This affects the Apache HTTP Server through 2.2.34 and 2.4.x through 2.4.27. The attacker sends an unauthenticated OPTIONS HTTP request when attempting to read secret data. This is a use-after-free issue and thus secret data is not always sent, and the specific data depends on many factors including configuration. Exploitation with .htaccess can be blocked with a patch to the ap_limit_section function in server/core.c.

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

External References

- CVE-2017-9798

Apache HTTP Server Out-of-bounds Read Vulnerability

A specially crafted HTTP request header could have crashed the Apache HTTP Server prior to version 2.4.30 due to an out of bound read while preparing data to be cached in shared memory. It could be used as a Denial of Service attack against users of mod_cache_socache. The vulnerability is considered as low risk since mod_cache_socache is not widely used, mod_cache_disk is not concerned by this vulnerability.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2018-1303

Apache HTTP Server Out-of-bounds Write Vulnerability

A carefully crafted If: request header can cause a memory read, or write of a single zero byte, in a pool (heap) memory location beyond the header value sent. This could cause the process to crash. This issue affects Apache HTTP Server 2.4.54 and earlier.

Affected Versions

0.8.14 to

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2006-20001

Apache HTTP Server Out-of-bounds Read Vulnerability

Out-of-bounds Read vulnerability in mod_macro of Apache HTTP Server.This issue affects Apache HTTP Server: through 2.4.57.

Affected Versions

0.8.14 to

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2023-31122

Apache HTTP Server Insertion of Sensitive Information Into Sent Data Vulnerability

Apache HTTP Server 2.4.65 and earlier with Server Side Includes (SSI) enabled and mod_cgid (but not mod_cgi) passes the shell-escaped query string to #exec cmd="..." directives. This issue affects Apache HTTP Server before 2.4.66. Users are recommended to upgrade to version 2.4.66, which fixes the issue.

Affected Versions

0.8.14 to

CVSS

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:L

External References

- CVE-2025-58098

Apache HTTP Server Improper Authentication Vulnerability

In some mod_ssl configurations on Apache HTTP Server versions through to 2.4.63, an HTTP desynchronisation attack allows a man-in-the-middle attacker to hijack an HTTP session via a TLS upgrade. Only configurations using "SSLEngine optional" to enable TLS upgrades are affected. Users are recommended to upgrade to version 2.4.64, which removes support for TLS upgrade.

Affected Versions

0.8.14 to

CVSS

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

External References

- CVE-2025-49812

Apache HTTP Server Improper Validation of Specified Quantity in Input Vulnerability

Faulty input validation in the core of Apache allows malicious or exploitable backend/content generators to split HTTP responses. This issue affects Apache HTTP Server: through 2.4.58.

Affected Versions

0.8.14 to

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

External References

- CVE-2023-38709

Apache HTTP Server Server-Side Request Forgery (SSRF) Vulnerability

SSRF in Apache HTTP Server on Windows with mod_rewrite in server/vhost context, allows to potentially leak NTML hashes to a malicious server via SSRF and malicious requests. Users are recommended to upgrade to version 2.4.62 which fixes this issue.

Affected Versions

0.8.14 to

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

External References

- CVE-2024-40898

Apache HTTP Server NULL Pointer Dereference Vulnerability

Malformed requests may cause the server to dereference a NULL pointer. This issue affects Apache HTTP Server 2.4.48 and earlier.

External References

- CVE-2021-34798

Apache HTTP Server NULL Pointer Dereference Vulnerability

mod_auth_openidc is an authentication and authorization module for the Apache 2.x HTTP server that implements the OpenID Connect Relying Party functionality. In versions 2.0.0 through 2.4.13.1, when `OIDCStripCookies` is set and a crafted cookie supplied, a NULL pointer dereference would occur, resulting in a segmentation fault. This could be used in a Denial-of-Service attack and thus presents an availability risk. Version 2.4.13.2 contains a patch for this issue. As a workaround, avoid using `OIDCStripCookies`.

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2023-28625

Apache HTTP Server Uncontrolled Resource Consumption Vulnerability

CVE-2009-1890 httpd: mod_proxy reverse proxy DoS (infinite loop)

CVSS

AV:N/AC:M/Au:N/C:N/I:N/A:C

External References

- CVE-2009-1890

Apache HTTP Improper Initialization Server Vulnerability

A carefully crafted request body can cause a read to a random memory area which could cause the process to crash. This issue affects Apache HTTP Server 2.4.52 and earlier.

External References

- CVE-2022-22719

Apache HTTP Server Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

Apache HTTP Server 2.4.53 and earlier may return lengths to applications calling r:wsread() that point past the end of the storage allocated for the buffer.

Affected Versions

0.8.14 to

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

External References

- CVE-2022-30556

Apache HTTP Server Uncontrolled Resource Consumption Vulnerability

The mod_deflate module in Apache httpd 2.2.11 and earlier compresses large files until completion even after the associated network connection is closed, which allows remote attackers to cause a denial of service (CPU consumption).

CVSS

AV:N/AC:M/Au:N/C:N/I:N/A:C

External References

- CVE-2009-1891

Apache HTTP Server Uncontrolled Resource Consumption Vulnerability

The byterange filter in the Apache HTTP Server 1.3.x, 2.0.x through 2.0.64, and 2.2.x through 2.2.19 allows remote attackers to cause a denial of service (memory and CPU consumption) via a Range header that expresses multiple overlapping ranges, as exploited in the wild in August 2011, a different vulnerability than CVE-2007-0086.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:C

External References

- CVE-2011-3192

Apache HTTP Server CVE-2016-8743 Vulnerability

Apache HTTP Server, in all releases prior to 2.2.32 and 2.4.25, was liberal in the whitespace accepted from requests and sent in response lines and headers. Accepting these different behaviors represented a security concern when httpd participates in any chain of proxies or interacts with back-end application servers, either through mod_proxy or using conventional CGI mechanisms, and may result in request smuggling, response splitting and cache pollution.

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

External References

- CVE-2016-8743

Apache HTTP Server CVE-2016-5387 Vulnerability

The Apache HTTP Server through 2.4.23 follows RFC 3875 section 4.1.18 and therefore does not protect applications from the presence of untrusted client data in the HTTP_PROXY environment variable, which might allow remote attackers to redirect an application's outbound HTTP traffic to an arbitrary proxy server via a crafted Proxy header in an HTTP request, aka an "httpoxy" issue. NOTE: the vendor states "This mitigation has been assigned the identifier CVE-2016-5387"; in other words, this is not a CVE ID for a vulnerability.

CVSS

CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2016-5387

Apache HTTP Server Configuration Vulnerability

The Apache HTTP Server 2.2.11 and earlier 2.2 versions does not properly handle Options=IncludesNOEXEC in the AllowOverride directive, which allows local users to gain privileges by configuring (1) Options Includes, (2) Options +Includes, or (3) Options +IncludesNOEXEC in a .htaccess file, and then inserting an exec element in a .shtml file.

CVSS
AV:L/AC:L/Au:N/C:N/I:N/A:C

External References
- CVE-2009-1195

Apache HTTP Server CVE-2009-3720 Vulnerability

The updatePosition function in lib/xmltok_impl.c in libexpat in Expat 2.0.1, as used in Python, PyXML, w3c-libwww, and other software, allows context-dependent attackers to cause a denial of service (application crash) via an XML document with crafted UTF-8 sequences that trigger a buffer over-read, a different vulnerability than CVE-2009-2625.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2009-3720

Apache HTTP Server Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

Cross-site scripting (XSS) vulnerability in proxy_ftp.c in the mod_proxy_ftp module in Apache 2.0.63 and earlier, and mod_proxy_ftp.c in the mod_proxy_ftp module in Apache 2.2.9 and earlier 2.2 versions, allows remote attackers to inject arbitrary web script or HTML via a wildcard in the last directory component in the pathname in an FTP URI.

CVSS
AV:N/AC:M/Au:N/C:N/I:P/A:N

External References
- CVE-2008-2939

Apache HTTP Server Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The apr_strmatch_precompile function in strmatch/apr_strmatch.c in Apache APR-util before 1.3.5 allows remote attackers to cause a denial of service (daemon crash) via crafted input involving (1) a .htaccess file used with the Apache HTTP Server, (2) the SVNMasterURI directive in the mod_dav_svn module in the Apache HTTP Server, (3) the mod_apreq2 module for the Apache HTTP Server, or (4) an application that uses the libapreq2 library, which triggers a heap-based buffer underflow.

CVSS
AV:N/AC:M/Au:N/C:N/I:N/A:P

External References
- CVE-2009-0023

Apache HTTP Server Improper Input Validation Vulnerability

Apache HTTP Server mod_cluster before version httpd 2.4.23 is vulnerable to an Improper Input Validation in the protocol parsing logic in the load balancer resulting in a Segmentation Fault in the serving httpd process.

CVSS
CVSS:3.0/AV:A/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

External References

- CVE-2016-8612

Apache HTTP Server Improper Neutralization of CRLF Sequences ('CRLF Injection') Vulnerability

Possible CRLF injection allowing HTTP response splitting attacks for sites which use mod_userdir. This issue was mitigated by changes made in 2.4.25 and 2.2.32 which prohibit CR or LF injection into the "Location" or other outbound header key or value. Fixed in Apache HTTP Server 2.4.25 (Affected 2.4.1-2.4.23). Fixed in Apache HTTP Server 2.2.32 (Affected 2.2.0-2.2.31).

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

External References

- CVE-2016-4975

Apache HTTP Server Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

A specially crafted request could have crashed the Apache HTTP Server prior to version 2.4.30, due to an out of bound access after a size limit is reached by reading the HTTP header. This vulnerability is considered very hard if not impossible to trigger in non-debug mode (both log and build level), so it is classified as low risk for common server usage.

CVSS

CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2018-1301

Apache HTTP Server NULL Pointer Dereference Vulnerability

When an HTTP/2 stream was destroyed after being handled, the Apache HTTP Server prior to version 2.4.30 could have written a NULL pointer potentially to an already freed memory. The memory pools maintained by the server make this vulnerability hard to trigger in usual configurations, the reporter and the team could not reproduce it outside debug builds, so it is classified as low risk.

CVSS

CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2018-1302

Apache HTTP Server Numeric Errors Vulnerability

Off-by-one error in the apr_brigade_vprintf function in Apache APR-util before 1.3.5 on big-endian platforms allows remote attackers to obtain sensitive information or cause a denial of service (application crash) via crafted input.

CVSS

AV:N/AC:L/Au:N/C:P/I:N/A:P

External References

- CVE-2009-1956

Apache HTTP Server Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Memory leak in the apr_brigade_split_line function in buckets/apr_brigade.c in the Apache Portable Runtime Utility library (aka APR-util) before 1.3.10, as used in the mod_reqtimeout module in the Apache HTTP Server and other software, allows remote attackers to cause a denial of service (memory consumption) via unspecified vectors related to the destruction of an APR bucket.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2010-1623

Apache HTTP Server Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The big2_toUtf8 function in lib/xmltok.c in libexpat in Expat 2.0.1, as used in the XML-Twig module for Perl, allows context-dependent attackers to cause a denial of service (application crash) via an XML document with malformed UTF-8 sequences that trigger a buffer over-read, related to the doProlog function in lib/xmlparse.c, a different vulnerability than CVE-2009-2625 and CVE-2009-3720.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2009-3560

Apache HTTP Server Uncontrolled Resource Consumption Vulnerability

When a HTTP/2 stream was reset (RST frame) by a client, there was a time window were the request's memory resources were not reclaimed immediately. Instead, de-allocation was deferred to connection close. A client could send new requests and resets, keeping the connection busy and open and causing the memory footprint to keep on growing. On connection close, all resources were reclaimed, but the process might run out of memory before that. This was found by the reporter during testing of CVE-2023-44487 (HTTP/2 Rapid Reset Exploit) with their own test client. During "normal" HTTP/2 use, the probability to hit this bug is very low. The kept memory would not become noticeable before the connection closes or times out. Users are recommended to upgrade to version 2.4.58, which fixes the issue.

Affected Versions
0.8.14 to

CVSS
CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2023-45802

Apache HTTP Server Interpretation Conflict Vulnerability

Prior to Apache HTTP Server 2.4.55, a malicious backend can cause the response headers to be truncated early, resulting in some headers being incorporated into the response body. If the later headers have any security purpose, they will not be interpreted by the client.

Affected Versions
0.8.14 to

CVSS
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

External References
- CVE-2022-37436

Apache Denial of service in mod_lua r:parsebody Vulnerability

In Apache HTTP Server 2.4.53 and earlier, a malicious request to a lua script that calls r:parsebody(0) may cause a denial of service due to no default limit on possible input size.

CVSS

-

External References

- CVE-2022-29404

Apache read beyond bounds via ap_rwrite() Vulnerability

The ap_rwrite() function in Apache HTTP Server 2.4.53 and earlier may read unintended memory if an attacker can cause the server to reflect very large input using ap_rwrite() or ap_rputs(), such as with mod_luas r:puts() function.

CVSS

-

External References

- CVE-2022-28614

Apache read beyond bounds in mod_isapi Vulnerability

Apache HTTP Server 2.4.53 and earlier on Windows may read beyond bounds when configured to process requests with the mod_isapi module.

CVSS

-

External References

- CVE-2022-28330

Apache HTTP Server Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

Cross-site scripting (XSS) vulnerability in the mod_negotiation module in the Apache HTTP Server 2.2.6 and earlier in the 2.2.x series, 2.0.61 and earlier in the 2.0.x series, and 1.3.39 and earlier in the 1.3.x series allows remote authenticated users to inject arbitrary web script or HTML by uploading a file with a name containing XSS sequences and a file extension, which leads to injection within a (1) "406 Not Acceptable" or (2) "300 Multiple Choices" HTTP response when the extension is omitted in a request for the file.

CVSS

AV:N/AC:M/Au:N/C:N/I:P/A:N

External References

- CVE-2008-0455

Apache HTTP Server Allocation of Resources Without Limits or Throttling Vulnerability

The ap_proxy_http_process_response function in mod_proxy_http.c in the mod_proxy module in the Apache HTTP Server 2.0.63 and 2.2.8 does not limit the number of forwarded interim responses, which allows remote HTTP servers to cause a denial of service (memory consumption) via a large number of interim responses.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2008-2364

Apache HTTP Server Other Vulnerability

The mod_proxy_ftp module in the Apache HTTP Server allows remote attackers to bypass intended access restrictions and send arbitrary commands to an FTP server via vectors related to the embedding of these commands in the Authorization HTTP header, as demonstrated by a certain module in VulnDisco Pack Professional 8.11.

CVSS

AV:N/AC:L/Au:N/C:N/I:P/A:N

External References

- CVE-2009-3095

Apache HTTP Server Concurrent Execution using Shared Resource with Improper Synchronization ('Race Condition') Vulnerability

Race condition in the mod_status module in the Apache HTTP Server before 2.4.10 allows remote attackers to cause a denial of service (heap-based buffer overflow), or possibly obtain sensitive credential information or execute arbitrary code, via a crafted request that triggers improper scoreboard handling within the status_handler function in modules/generators/mod_status.c and the lua_ap_scoreboard_worker function in modules/lua/lua_request.c.

CVSS

AV:N/AC:M/Au:N/C:P/I:P/A:P

External References

- CVE-2014-0226

Apache HTTP Server Allocation of Resources Without Limits or Throttling Vulnerability

Stack consumption vulnerability in the fnmatch implementation in apr_fnmatch.c in the Apache Portable Runtime (APR) library before 1.4.3 and the Apache HTTP Server before 2.2.18, and in fnmatch.c in libc in NetBSD 5.1, OpenBSD 4.8, FreeBSD, Apple Mac OS X 10.6, Oracle Solaris 10, and Android, allows context-dependent attackers to cause a denial of service (CPU and memory consumption) via *? sequences in the first argument, as demonstrated by attacks against mod_autoindex in httpd.

CVSS

AV:N/AC:M/Au:N/C:N/I:N/A:P

External References

- CVE-2011-0419

Apache HTTP Server Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

The ap_read_request function in server/protocol.c in the Apache HTTP Server 2.2.x before 2.2.15, when a multithreaded MPM is used, does not properly handle headers in subrequests in certain circumstances involving a parent request that has a body, which might allow remote attackers to obtain sensitive information via a crafted request that triggers access to memory locations associated with an earlier request.

CVSS

AV:N/AC:M/Au:N/C:P/I:N/A:N

External References

- CVE-2010-0434

Apache HTTP Server CVE-2014-0098 Vulnerability

The log_cookie function in mod_log_config.c in the mod_log_config module in the Apache HTTP Server before 2.4.8 allows remote attackers to cause a denial of service (segmentation fault and daemon crash) via a crafted cookie that is not properly handled during truncation.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2014-0098

Apache HTTP Server CVE-2012-0031 Vulnerability

scoreboard.c in the Apache HTTP Server 2.2.21 and earlier might allow local users to cause a denial of service (daemon crash during shutdown) or possibly have unspecified other impact by modifying a certain type field within a scoreboard shared memory segment, leading to an invalid call to the free function.

CVSS

AV:L/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2012-0031

Apache HTTP Server CVE-2012-0053 Vulnerability

protocol.c in the Apache HTTP Server 2.2.x through 2.2.21 does not properly restrict header information during construction of Bad Request (aka 400) error documents, which allows remote attackers to obtain the values of HTTPOnly cookies via vectors involving a (1) long or (2) malformed header in conjunction with crafted web script.

CVSS

AV:N/AC:M/Au:N/C:P/I:N/A:N

External References

- CVE-2012-0053

Apache HTTP Server CVE-2012-0883 Vulnerability

envvars (aka envvars-std) in the Apache HTTP Server before 2.4.2 places a zero-length directory name in the LD_LIBRARY_PATH, which allows local users to gain privileges via a Trojan horse DSO in the current working directory during execution of apachectl.

CVSS

AV:L/AC:M/Au:N/C:C/I:C/A:C

External References

- CVE-2012-0883

Apache HTTP Server CVE-2013-1862 Vulnerability

mod_rewrite.c in the mod_rewrite module in the Apache HTTP Server 2.2.x before 2.2.25 writes data to a log file without sanitizing non-printable characters, which might allow remote attackers to execute arbitrary commands via an HTTP request containing an escape sequence for a terminal emulator.

CVSS

AV:N/AC:H/Au:N/C:P/I:P/A:P

External References

- CVE-2013-1862

Apache HTTP Server CVE-2013-1896 Vulnerability

mod_dav.c in the Apache HTTP Server before 2.2.25 does not properly determine whether DAV is enabled for a URI, which allows remote attackers to cause a denial of service (segmentation fault) via a MERGE request in which the URI is configured for handling by the mod_dav_svn module, but a certain href attribute in XML data refers to a non-DAV URI.

CVSS

AV:N/AC:M/Au:N/C:N/I:N/A:P

External References

- CVE-2013-1896

Apache HTTP Server CVE-2013-6438 Vulnerability

The dav_xml_get_cdata function in main/util.c in the mod_dav module in the Apache HTTP Server before 2.4.8 does not properly remove whitespace characters from CDATA sections, which allows remote attackers to cause a denial of service (daemon crash) via a crafted DAV WRITE request.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2013-6438

Apache HTTP Server Uncontrolled Resource Consumption Vulnerability

The deflate_in_filter function in mod_deflate.c in the mod_deflate module in the Apache HTTP Server before 2.4.10, when request body decompression is enabled, allows remote attackers to cause a denial of service (resource consumption) via crafted request data that decompresses to a much larger size.

CVSS

AV:N/AC:M/Au:N/C:N/I:N/A:P

External References

- CVE-2014-0118

Apache HTTP Server CVE-2013-5704 Vulnerability

The mod_headers module in the Apache HTTP Server 2.2.22 allows remote attackers to bypass "RequestHeader unset" directives by placing a header in the trailer portion of data sent with chunked transfer coding. NOTE: the vendor states "this is not a security issue in httpd as such."

CVSS

AV:N/AC:L/Au:N/C:N/I:P/A:N

External References

- CVE-2013-5704

Apache HTTP Server DEPRECATED: Code Vulnerability

The chunked transfer coding implementation in the Apache HTTP Server before 2.4.14 does not properly parse chunk headers, which allows remote attackers to conduct HTTP request smuggling attacks via a crafted request, related to mishandling of large chunk-size values and invalid chunk-extension characters in modules/http/http_filters.c.

CVSS
AV:N/AC:L/Au:N/C:N/I:P/A:N

External References
- CVE-2015-3183

Apache HTTP Server Improper Input Validation Vulnerability

The lua_websocket_read function in lua_request.c in the mod_lua module in the Apache HTTP Server through 2.4.12 allows remote attackers to cause a denial of service (child-process crash) by sending a crafted WebSocket Ping frame after a Lua script has called the wsupgrade function.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2015-0228

Apache HTTP Server Improper Input Validation Vulnerability

The mod_proxy module in the Apache HTTP Server 1.3.x through 1.3.42, 2.0.x through 2.0.64, and 2.2.x through 2.2.21 does not properly interact with use of (1) RewriteRule and (2) ProxyPassMatch pattern matches for configuration of a reverse proxy, which allows remote attackers to send requests to intranet servers via a malformed URI containing an initial @ (at sign) character.

CVSS
AV:N/AC:L/Au:N/C:P/I:N/A:N

External References
- CVE-2011-3368

Apache HTTP Server Other Vulnerability

The (1) mod_cache and (2) mod_dav modules in the Apache HTTP Server 2.2.x before 2.2.16 allow remote attackers to cause a denial of service (process crash) via a request that lacks a path.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2010-1452

Apache HTTP Server Numeric Errors Vulnerability

Integer overflow in the ap_pregsub function in server/util.c in the Apache HTTP Server 2.0.x through 2.0.64 and 2.2.x through 2.2.21, when the mod_setenvif module is enabled, allows local users to gain privileges via a .htaccess file with a crafted SetEnvIf directive, in conjunction with a crafted HTTP request header, leading to a heap-based buffer overflow.

CVSS
AV:L/AC:M/Au:N/C:P/I:P/A:P

External References

- CVE-2011-3607

Apache HTTP Server Cryptographic Issues Vulnerability

The TLS protocol, and the SSL protocol 3.0 and possibly earlier, as used in Microsoft Internet Information Services (IIS) 7.0, mod_ssl in the Apache HTTP Server 2.2.14 and earlier, OpenSSL before 0.9.8l, GnuTLS 2.8.5 and earlier, Mozilla Network Security Services (NSS) 3.12.4 and earlier, multiple Cisco products, and other products, does not properly associate renegotiation handshakes with an existing connection, which allows man-in-the-middle attackers to insert data into HTTPS sessions, and possibly other types of sessions protected by TLS or SSL, by sending an unauthenticated request that is processed retroactively by a server in a post-renegotiation context, related to a "plaintext injection" attack, aka the "Project Mogul" issue.

CVSS

AV:N/AC:M/Au:N/C:N/I:P/A:P

External References

- CVE-2009-3555

Apache HTTP Server Other Vulnerability

The ap_proxy_ajp_request function in mod_proxy_ajp.c in mod_proxy_ajp in the Apache HTTP Server 2.2.x before 2.2.15 does not properly handle certain situations in which a client sends no request body, which allows remote attackers to cause a denial of service (backend server outage) via a crafted request, related to use of a 500 error code instead of the appropriate 400 error code.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2010-0408

Apache HTTP Server Resource Management Errors Vulnerability

The mod_cgid module in the Apache HTTP Server before 2.4.10 does not have a timeout mechanism, which allows remote attackers to cause a denial of service (process hang) via a request to a CGI script that does not read from its stdin file descriptor.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2014-0231

Apache HTTP Server Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

Multiple cross-site scripting (XSS) vulnerabilities in the Apache HTTP Server 2.2.x before 2.2.24-dev and 2.4.x before 2.4.4 allow remote attackers to inject arbitrary web script or HTML via vectors involving hostnames and URIs in the (1) mod_imagemap, (2) mod_info, (3) mod_ldap, (4) mod_proxy_ftp, and (5) mod_status modules.

CVSS

AV:N/AC:M/Au:N/C:N/I:P/A:N

External References

- CVE-2012-3499

Apache HTTP Server Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

Multiple cross-site scripting (XSS) vulnerabilities in the balancer_handler function in the manager interface in mod_proxy_balancer.c in the mod_proxy_balancer module in the Apache HTTP Server 2.2.x before 2.2.24-dev and 2.4.x before 2.4.4 allow remote attackers to inject arbitrary web script or HTML via a crafted string.

CVSS
AV:N/AC:M/Au:N/C:N/I:P/A:N

External References
- CVE-2012-4558

Apache HTTP Server Resource Management Errors Vulnerability

The mod_cgid module in the Apache HTTP Server before 2.4.10 does not have a timeout mechanism, which allows remote attackers to cause a denial of service (process hang) via a request to a CGI script that does not read from its stdin file descriptor.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2014-0231

Apache HTTP Server Resource Management Errors Vulnerability

The Apache HTTP Server 1.x and 2.x allows remote attackers to cause a denial of service (daemon outage) via partial HTTP requests, as demonstrated by Slowloris, related to the lack of the mod_reqtimeout module in versions before 2.2.15.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2007-6750

Apache HTTP Server Improper Input Validation Vulnerability

The mod_proxy module in the Apache HTTP Server 2.0.x through 2.0.64 and 2.2.x before 2.2.18, when the Revision 1179239 patch is in place, does not properly interact with use of (1) RewriteRule and (2) ProxyPassMatch pattern matches for configuration of a reverse proxy, which allows remote attackers to send requests to intranet servers by using the HTTP/0.9 protocol with a malformed URI containing an initial @ (at sign) character. NOTE: this vulnerability exists because of an incomplete fix for CVE-2011-3368.

CVSS
AV:N/AC:M/Au:N/C:N/I:P/A:N

External References
- CVE-2011-3639

Apache HTTP Server Improper Input Validation Vulnerability

The mod_proxy module in the Apache HTTP Server 1.3.x through 1.3.42, 2.0.x through 2.0.64, and 2.2.x through 2.2.21, when the Revision 1179239 patch is in place, does not properly interact with use of (1) RewriteRule and (2) ProxyPassMatch pattern matches for configuration of a reverse proxy, which allows remote attackers to send requests to intranet servers via a malformed URI containing an @ (at sign) character and a : (colon) character in invalid positions. NOTE: this vulnerability exists because of an incomplete fix for CVE-2011-3368.

CVSS

AV:N/AC:M/Au:N/C:N/I:P/A:N

External References

- CVE-2011-4317

Apache HTTP Server Resource Management Errors Vulnerability

The Apache HTTP Server 1.x and 2.x allows remote attackers to cause a denial of service (daemon outage) via partial HTTP requests, as demonstrated by Slowloris, related to the lack of the mod_reqtimeout module in versions before 2.2.15.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2007-6750

Apache HTTP Server: DoS by Null pointer in websocket over HTTP/2

Serving WebSocket protocol upgrades over a HTTP/2 connection could result in a Null Pointer dereference, leading to a crash of the server process, degrading performance.

External References

- CVE-2024-36387

Apache HTTP Server NULL Pointer Dereference Vulnerability

The ap_proxy_ftp_handler function in modules/proxy/proxy_ftp.c in the mod_proxy_ftp module in the Apache HTTP Server 2.0.63 and 2.2.13 allows remote FTP servers to cause a denial of service (NULL pointer dereference and child process crash) via a malformed reply to an EPSV command.

CVSS

AV:N/AC:H/Au:N/C:N/I:N/A:P

External References

- CVE-2009-3094

Apache HTTP Server Improper Neutralization of Special Elements in Output Used by a Downstream Component ('Injection') Vulnerability

CRLF injection vulnerability in the mod_negotiation module in the Apache HTTP Server 2.2.6 and earlier in the 2.2.x series, 2.0.61 and earlier in the 2.0.x series, and 1.3.39 and earlier in the 1.3.x series allows remote authenticated users to inject arbitrary HTTP headers and conduct HTTP response splitting attacks by uploading a file with a multi-line name containing HTTP header sequences and a file extension, which leads to injection within a (1) "406 Not Acceptable" or (2) "300 Multiple Choices" HTTP response when the extension is omitted in a request for the file.

CVSS

AV:N/AC:H/Au:N/C:N/I:P/A:N

External References

- CVE-2008-0456

Apache HTTP Server Improper Input Validation Vulnerability

The ap_pregsub function in server/util.c in the Apache HTTP Server 2.0.x through 2.0.64 and 2.2.x through 2.2.21, when the mod_setenvif module is enabled, does not restrict the size of values of environment variables, which allows local users to cause a

denial of service (memory consumption or NULL pointer dereference) via a .htaccess file with a crafted SetEnvIf directive, in conjunction with a crafted HTTP request header, related to (1) the "len +=" statement and (2) the apr_pcalloc function call, a different vulnerability than CVE-2011-3607.

CVSS
AV:L/AC:H/Au:N/C:N/I:N/A:P

External References
- CVE-2011-4415

Apache HTTP Server Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

Multiple cross-site scripting (XSS) vulnerabilities in the make_variant_list function in mod_negotiation.c in the mod_negotiation module in the Apache HTTP Server 2.4.x before 2.4.3, when the MultiViews option is enabled, allow remote attackers to inject arbitrary web script or HTML via a crafted filename that is not properly handled during construction of a variant list.

CVSS
AV:N/AC:H/Au:N/C:N/I:P/A:N

External References
- CVE-2012-2687

Vulnerabilities

1.1. http://150.1.7.104/dvwa/login.php

Identified Version
- 2.2.8

Latest Version
- 2.2.34 (in this branch)

Overall Latest Version
- 2.4.66

Branch Status
- The official end-of-life date for this branch is: 11/07/2017.

Vulnerability Database
- Result is based on 03/24/2026 20:00:00 vulnerability database content.

Certainty

Request | Response

Request

```
GET /dvwa/login.php HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 172.7328
Total Bytes Received : 1710
Body Length : 1289
Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie: PHPSESSID=**************; path=/
Set-Cookie: security=high
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Pragma: no-cache
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Keep-Alive: timeout=15, max=100
Content-Length: 1289
Connection: Keep-Alive
Content-Type: text/html;charset=utf-8
Date: Fri, 27 Mar 2026 19:53:45 GMT
Cache-Control: no-cache, must-revalidate
```

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">

<head>

<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

<title>Damn Vulnerable Web App (DVWA) - Login</title>

<link rel="stylesheet" type="text/css" href="dvwa/css/login.css" />

</head>

<body>

<div align="center">

<br />

<p><img src="dvwa/images/login_logo.png" /></p>

<br />

<form action="login.php" method="post">

<fieldset>
```

```
<label for="user">Username</label> <input type="text" class="loginInput" size="20" name="username"><br
/>


<label for="pass">Password</label> <input type="password" class="loginInput" AUTOCOMPLETE="off"
size="20" name="password"><br />


<p class="submit"><input type="submit" value="Login" name="Login"></p>

</fieldset>

</form>


<br />



<br />
<br />
<br />
<br />
<br />
<br />
<br />
<br />

<!-- <img src="dvwa/images/RandomStorm.png" /> -->

<p>Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project</p>
<p>Hint: default username is 'admin' with password 'password' </p>
</div> <!-- end align div -->

</body>

</html>
```

Remedy

Please upgrade your installation of Apache to the latest stable version.

Remedy References

- [Downloading the Apache HTTP Server]

CLASSIFICATION

PCI DSS v3.2	6.2
PCI DSS v4.0	6.3.3
OWASP 2013	A9
OWASP 2017	A9
CWE	1035 , 937
CAPEC	310
HIPAA	164.308(a)(1)(i)
ASVS 4.0	1.14.3
NIST SP 800-53	CM-6
DISA STIG	V-16836
OWASP Proactive Controls	C1
ISO27001	A.14.1.2
ISO27001 2022	A.8.19
OWASP Top Ten 2021	A06
OWASP API Top 10 2023	API8

2. Out-of-date Version (PHP)

CRITICAL | 1

Invicti Standard identified you are using an out-of-date version of PHP.

Impact

Since this is an old version of the software, it may be vulnerable to attacks.

PHP Incorrect Calculation of Buffer Size Vulnerability

The init_request_info function in sapi/cgi/cgi_main.c in PHP before 5.2.6 does not properly consider operator precedence when calculating the length of PATH_TRANSLATED, which might allow remote attackers to execute arbitrary code via a crafted URI.

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2008-0599

PHP Insufficient Entropy Vulnerability

The GENERATE_SEED macro in PHP 4.x before 4.4.8 and 5.x before 5.2.5, when running on 64-bit systems, performs a multiplication that generates a portion of zero bits during conversion due to insufficient precision, which produces 24 bits of entropy and simplifies brute force attacks against protection mechanisms that use the rand and mt_rand functions.

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2008-2108

PHP Improper Neutralization of Special Elements used in a Command ('Command Injection') Vulnerability

A command inject vulnerability allows an attacker to perform command injection on Windows applications that indirectly depend on the CreateProcess function when the specific conditions are satisfied.

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2024-3566

PHP Improper Neutralization of Special Elements used in a Command ('Command Injection') Vulnerability

sapi/cgi/cgi_main.c in PHP before 5.3.12 and 5.4.x before 5.4.2, when configured as a CGI script (aka php-cgi), does not properly handle query strings that lack an = (equals sign) character, which allows remote attackers to execute arbitrary code by placing command-line options in the query string, related to lack of skipping a certain php_getopt for the 'd' case.

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2012-1823

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

CVE-2008-2050 php: stack based buffer overflow in FastCGI SAPI

CVSS

AV:N/AC:L/Au:N/C:C/I:C/A:C

External References

- CVE-2008-2050

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

CVE-2008-2050 php: stack based buffer overflow in FastCGI SAPI

CVSS

AV:N/AC:L/Au:N/C:C/I:C/A:C

External References

- CVE-2008-2050

PHP Out-of-bounds Write Vulnerability

An issue was discovered in Oniguruma 6.2.0, as used in Oniguruma-mod in Ruby through 2.4.1 and mbstring in PHP through 7.1.5. A heap out-of-bounds write or read occurs in next_state_val() during regular expression compilation. Octal numbers larger than 0xff are not handled correctly in fetch_token() and fetch_token_in_cc(). A malformed regular expression containing an octal number in the form of '\700' would produce an invalid code point value larger than 0xff in next_state_val(), resulting in an out-of-bounds write memory corruption.

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2017-9226

PHP Out-of-bounds Read Vulnerability

An issue was discovered in Oniguruma 6.2.0, as used in Oniguruma-mod in Ruby through 2.4.1 and mbstring in PHP through 7.1.5. A stack out-of-bounds read occurs in match_at() during regular expression searching. A logical error involving order of validation and access in match_at() could result in an out-of-bounds read from a stack buffer.

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2017-9224

PHP Improper Input Validation Vulnerability

The zend_string_extend function in Zend/zend_string.h in PHP through 7.1.5 does not prevent changes to string objects that result in a negative length, which allows remote attackers to cause a denial of service (application crash) or possibly have unspecified other impact by leveraging a script's use of .= with a long string.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2017-8923

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Off-by-one error in the phar_parse_pharfile function in ext/phar/phar.c in PHP before 5.6.30 and 7.0.x before 7.0.15 allows remote attackers to cause a denial of service (memory corruption) or possibly execute arbitrary code via a crafted PHAR archive with an alias mismatch.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-10160

PHP Out-of-bounds Read Vulnerability

The finish_nested_data function in ext/standard/var_unserializer.re in PHP before 5.6.31, 7.0.x before 7.0.21, and 7.1.x before 7.1.7 is prone to a buffer over-read while unserializing untrusted data. Exploitation of this issue can have an unspecified impact on the integrity of PHP.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2017-12933

PHP Out-of-bounds Read Vulnerability

In PHP before 5.6.30 and 7.x before 7.0.15, the PHAR archive handler could be used by attackers supplying malicious archive files to crash the PHP interpreter or potentially disclose information due to a buffer over-read in the phar_parse_pharfile function in ext/phar/phar.c.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

External References

- CVE-2017-11147

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

ext/standard/var_unserializer.re in PHP before 5.6.26 mishandles object-deserialization failures, which allows remote attackers to cause a denial of service (memory corruption) or possibly have unspecified other impact via an unserialize call that references a partially constructed object.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2016-7411

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The ZIP signature-verification feature in PHP before 5.6.26 and 7.x before 7.0.11 does not ensure that the uncompressed_filesize field is large enough, which allows remote attackers to cause a denial of service (out-of-bounds memory access) or possibly have unspecified other impact via a crafted PHAR archive, related to ext/phar/util.c and ext/phar/zip.c.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2016-7414

PHP Use After Free Vulnerability

Use-after-free vulnerability in the wddx_stack_destroy function in ext/wddx/wddx.c in PHP before 5.6.26 and 7.x before 7.0.11 allows remote attackers to cause a denial of service or possibly have unspecified other impact via a wddxPacket XML document that lacks an end-tag for a recordset field element, leading to mishandling in a wddx_deserialize call.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2016-7413

PHP Out-of-bounds Write Vulnerability

The imagegammacorrect function in ext/gd/gd.c in PHP before 5.6.25 and 7.x before 7.0.10 does not properly validate gamma values, which allows remote attackers to cause a denial of service (out-of-bounds write) or possibly have unspecified other impact by providing different signs for the second and third arguments.

Affected Versions

0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-7127

PHP Improper Input Validation Vulnerability

The php_wddx_process_data function in ext/wddx/wddx.c in PHP before 5.6.25 and 7.x before 7.0.10 allows remote attackers to cause a denial of service (segmentation fault) or possibly have unspecified other impact via an invalid ISO 8601 time value, as demonstrated by a wddx_deserialize call that mishandles a dateTime element in a wddxPacket XML document.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-7129

PHP Out-of-bounds Read Vulnerability

The php_wddx_push_element function in ext/wddx/wddx.c in PHP before 5.6.29 and 7.x before 7.0.14 allows remote attackers to cause a denial of service (out-of-bounds read and memory corruption) or possibly have unspecified other impact via an empty boolean element in a wddxPacket XML document.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-9935

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The SplObjectStorage unserialize implementation in ext/spl/spl_observer.c in PHP before 7.0.12 does not verify that a key is an object, which allows remote attackers to execute arbitrary code or cause a denial of service (uninitialized memory access) via crafted serialized data.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-7480

PHP Improper Input Validation Vulnerability

ext/spl/spl_array.c in PHP before 5.6.26 and 7.x before 7.0.11 proceeds with SplArray unserialization without validating a return value and data type, which allows remote attackers to cause a denial of service or possibly have unspecified other impact via crafted serialized data.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2016-7417

PHP Use After Free Vulnerability

PHP through 5.6.27 and 7.x through 7.0.12 mishandles property modification during __wakeup processing, which allows remote attackers to cause a denial of service or possibly have unspecified other impact via crafted serialized data, as demonstrated by Exception::__toString with DateInterval::__wakeup.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2016-9138

PHP Use After Free Vulnerability

Use-after-free vulnerability in the CURLFile implementation in ext/curl/curl_file.c in PHP before 5.6.27 and 7.x before 7.0.12 allows remote attackers to cause a denial of service or possibly have unspecified other impact via crafted serialized data that is mishandled during __wakeup processing.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2016-9137

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

An issue was discovered in the EXIF component in PHP before 7.1.27, 7.2.x before 7.2.16, and 7.3.x before 7.3.3. There is an uninitialized read in exif_process_IFD_in_TIFF.

Affected Versions

0.2.0 to

CVSS
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2019-9641

PHP Out-of-bounds Read Vulnerability

An issue was discovered in PHP before 5.6.40, 7.x before 7.1.26, 7.2.x before 7.2.14, and 7.3.x before 7.3.1. A number of heap-based buffer over-read instances are present in mbstring regular expression functions when supplied with invalid multibyte data. These occur in ext/mbstring/oniguruma/regcomp.c, ext/mbstring/oniguruma/regexec.c, ext/mbstring/oniguruma/regparse.c, ext/mbstring/oniguruma/enc/unicode.c, and ext/mbstring/oniguruma/src/utf32_be.c when a multibyte regular expression pattern contains invalid multibyte sequences.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2019-9023

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

In PHP through 5.6.33, 7.0.x before 7.0.28, 7.1.x through 7.1.14, and 7.2.x through 7.2.2, there is a stack-based buffer under-read while parsing an HTTP response in the php_stream_url_wrap_http_ex function in ext/standard/http_fopen_wrapper.c. This subsequently results in copying a large string.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2018-7584

PHP Out-of-bounds Read Vulnerability

An issue was discovered in PHP before 5.6.40, 7.x before 7.1.26, 7.2.x before 7.2.14, and 7.3.x before 7.3.1. A heap-based buffer over-read in PHAR reading functions in the PHAR extension may allow an attacker to read allocated or unallocated memory past the actual data when trying to parse the file name, a different vulnerability than CVE-2018-20783. This is related to phar_detect_phar_fname_ext in ext/phar/phar.c.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2019-9021

PHP Use After Free Vulnerability

An issue was discovered in PHP before 5.6.40, 7.x before 7.1.26, 7.2.x before 7.2.14, and 7.3.x before 7.3.1. Invalid input to the function xmlrpc_decode() can lead to an invalid memory access (heap out of bounds read or read after free). This is related to xml_elem_parse_buf in ext/xmlrpc/libxmlrpc/xml_element.c.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2019-9020

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Use-after-free vulnerability in wddx.c in the WDDX extension in PHP before 5.5.33 and 5.6.x before 5.6.19 allows remote attackers to cause a denial of service (memory corruption and application crash) or possibly have unspecified other impact by triggering a wddx_deserialize call on XML data containing a crafted var element.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2016-3141

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The gdImageRotateInterpolated function in ext/gd/libgd/gd_interpolation.c in PHP before 5.5.31, 5.6.x before 5.6.17, and 7.x before 7.0.2 allows remote attackers to obtain sensitive information or cause a denial of service (out-of-bounds read and application crash) via a large bgd_color argument to the imagerotate function.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

External References

- CVE-2016-1903

PHP Out-of-bounds Write Vulnerability

The imagetruecolortopalette function in ext/gd/gd.c in PHP before 5.6.25 and 7.x before 7.0.10 does not properly validate the number of colors, which allows remote attackers to cause a denial of service (select_colors allocation error and out-of-bounds write) or possibly have unspecified other impact via a large value in the third argument.

Affected Versions

0.2.0 to

CVSS
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-7126

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Integer signedness error in the simplestring_addn function in simplestring.c in xmlrpc-epi through 0.54.2, as used in PHP before 5.5.38, 5.6.x before 5.6.24, and 7.x before 7.0.9, allows remote attackers to cause a denial of service (heap-based buffer overflow) or possibly have unspecified other impact via a long first argument to the PHP xmlrpc_encode_request function.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-6296

PHP Integer Overflow or Wraparound Vulnerability

Multiple integer overflows in php_zip.c in the zip extension in PHP before 7.0.6 allow remote attackers to cause a denial of service (heap-based buffer overflow and application crash) or possibly have unspecified other impact via a crafted call to (1) getFromIndex or (2) getFromName in the ZipArchive class.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-3078

PHP Use After Free Vulnerability

ext/snmp/snmp.c in PHP before 5.5.38, 5.6.x before 5.6.24, and 7.x before 7.0.9 improperly interacts with the unserialize implementation and garbage collection, which allows remote attackers to cause a denial of service (use-after-free and application crash) or possibly have unspecified other impact via crafted serialized data, a related issue to CVE-2016-5773.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-6295

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The exif_process_IFD_in_MAKERNOTE function in ext/exif/exif.c in PHP before 5.5.38, 5.6.x before 5.6.24, and 7.x before 7.0.9 allows remote attackers to cause a denial of service (out-of-bounds array access and memory corruption), obtain sensitive information from process memory, or possibly have unspecified other impact via a crafted JPEG image.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-6291

PHP Use After Free Vulnerability

ext/session/session.c in PHP before 5.5.38, 5.6.x before 5.6.24, and 7.x before 7.0.9 does not properly maintain a certain hash data structure, which allows remote attackers to cause a denial of service (use-after-free) or possibly have unspecified other impact via vectors related to session deserialization.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-6290

PHP Out-of-bounds Read Vulnerability

The locale_accept_from_http function in ext/intl/locale/locale_methods.c in PHP before 5.5.38, 5.6.x before 5.6.24, and 7.x before 7.0.9 does not properly restrict calls to the ICU uloc_acceptLanguageFromHTTP function, which allows remote attackers to cause a denial of service (out-of-bounds read) or possibly have unspecified other impact via a call with a long argument.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-6294

PHP Use After Free Vulnerability

spl_array.c in the SPL extension in PHP before 5.5.37 and 5.6.x before 5.6.23 improperly interacts with the unserialize implementation and garbage collection, which allows remote attackers to execute arbitrary code or cause a denial of service (use-after-free and application crash) via crafted serialized data.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-5771

PHP Integer Overflow or Wraparound Vulnerability

Integer overflow in the SplFileObject::fread function in spl_directory.c in the SPL extension in PHP before 5.5.37 and 5.6.x before 5.6.23 allows remote attackers to cause a denial of service or possibly have unspecified other impact via a large integer argument, a related issue to CVE-2016-5096.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-5770

PHP Use After Free Vulnerability

php_zip.c in the zip extension in PHP before 5.5.37, 5.6.x before 5.6.23, and 7.x before 7.0.8 improperly interacts with the unserialize implementation and garbage collection, which allows remote attackers to execute arbitrary code or cause a denial of service (use-after-free and application crash) via crafted serialized data containing a ZipArchive object.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-5773

PHP Deserialization of Untrusted Data Vulnerability

ext/standard/var_unserializer.c in PHP before 5.6.25 and 7.x before 7.0.10 mishandles certain invalid objects, which allows remote attackers to cause a denial of service or possibly have unspecified other impact via crafted serialized data that leads to a (1) __destruct call or (2) magic method call.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-7124

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

sapi/fpm/fpm/fpm_log.c in PHP before 5.5.31, 5.6.x before 5.6.17, and 7.x before 7.0.2 misinterprets the semantics of the snprintf return value, which allows attackers to obtain sensitive information from process memory or cause a denial of service (out-of-bounds read and buffer overflow) via a long string, as demonstrated by a long URI in a configuration with custom REQUEST_URI logging.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

External References
- CVE-2016-5114

PHP Integer Overflow or Wraparound Vulnerability

Multiple integer overflows in mcrypt.c in the mcrypt extension in PHP before 5.5.37, 5.6.x before 5.6.23, and 7.x before 7.0.8 allow remote attackers to cause a denial of service (heap-based buffer overflow and application crash) or possibly have unspecified other impact via a crafted length value, related to the (1) mcrypt_generic and (2) mdecrypt_generic functions.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-5769

PHP Double Free Vulnerability

Double free vulnerability in the _php_mb_regex_ereg_replace_exec function in php_mbregex.c in the mbstring extension in PHP before 5.5.37, 5.6.x before 5.6.23, and 7.x before 7.0.8 allows remote attackers to execute arbitrary code or cause a denial of service (application crash) by leveraging a callback exception.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-5768

PHP Numeric Errors Vulnerability

Integer overflow in the xml_utf8_encode function in ext/xml/xml.c in PHP before 7.0.4 allows remote attackers to cause a denial of service or possibly have unspecified other impact via a long argument to the utf8_encode function, leading to a heap-based buffer overflow.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-4344

PHP Numeric Errors Vulnerability

Integer overflow in the php_filter_encode_url function in ext/filter/sanitizing_filters.c in PHP before 7.0.4 allows remote attackers to cause a denial of service or possibly have unspecified other impact via a long string, leading to a heap-based buffer overflow.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-4345

PHP Improper Input Validation Vulnerability

The bcpowmod function in ext/bcmath/bcmath.c in PHP before 5.5.35, 5.6.x before 5.6.21, and 7.x before 7.0.6 accepts a negative integer for the scale argument, which allows remote attackers to cause a denial of service or possibly have unspecified other impact via a crafted call.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-4537

PHP Numeric Errors Vulnerability

Integer overflow in the str_pad function in ext/standard/string.c in PHP before 7.0.4 allows remote attackers to cause a denial of service or possibly have unspecified other impact via a long string, leading to a heap-based buffer overflow.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-4346

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Stack-based buffer overflow in ext/phar/tar.c in PHP before 5.5.32, 5.6.x before 5.6.18, and 7.x before 7.0.3 allows remote attackers to cause a denial of service (application crash) or possibly have unspecified other impact via a crafted TAR archive.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-2554

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The exif_process_IFD_in_JPEG function in ext/exif/exif.c in PHP before 5.5.35, 5.6.x before 5.6.21, and 7.x before 7.0.6 does not validate IFD sizes, which allows remote attackers to cause a denial of service (out-of-bounds read) or possibly have unspecified other impact via crafted header data.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-4543

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The php_url_parse_ex function in ext/standard/url.c in PHP before 5.5.38 allows remote attackers to cause a denial of service (buffer over-read) or possibly have unspecified other impact via vectors involving the smart_str data type.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-6288

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The xml_parse_into_struct function in ext/xml/xml.c in PHP before 5.5.35, 5.6.x before 5.6.21, and 7.x before 7.0.6 allows remote attackers to cause a denial of service (buffer under-read and segmentation fault) or possibly have unspecified other impact via crafted XML data in the second argument, leading to a parser level of zero.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-4539

PHP Improper Input Validation Vulnerability

The bcpowmod function in ext/bcmath/bcmath.c in PHP before 5.5.35, 5.6.x before 5.6.21, and 7.x before 7.0.6 modifies certain data structures without considering whether they are copies of the _zero_, _one_, or _two_ global variable, which allows remote attackers to cause a denial of service or possibly have unspecified other impact via a crafted call.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2016-4538

PHP Other Vulnerability

The grapheme_stripos function in ext/intl/grapheme/grapheme_string.c in PHP before 5.5.35, 5.6.x before 5.6.21, and 7.x before 7.0.6 allows remote attackers to cause a denial of service (out-of-bounds read) or possibly have unspecified other impact via a negative offset.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2016-4540

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The exif_process_IFD_TAG function in ext/exif/exif.c in PHP before 5.5.35, 5.6.x before 5.6.21, and 7.x before 7.0.6 does not properly construct spprintf arguments, which allows remote attackers to cause a denial of service (out-of-bounds read) or possibly have unspecified other impact via crafted header data.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2016-4542

PHP Other Vulnerability

The grapheme_strpos function in ext/intl/grapheme/grapheme_string.c in PHP before 5.5.35, 5.6.x before 5.6.21, and 7.x before 7.0.6 allows remote attackers to cause a denial of service (out-of-bounds read) or possibly have unspecified other impact via a negative offset.

Affected Versions

0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-4541

PHP Improper Control of Generation of Code ('Code Injection') Vulnerability

The resource system in PHP 5.0.0 through 5.2.1 allows context-dependent attackers to execute arbitrary code by interrupting the hash_update_file function via a userspace (1) error or (2) stream handler, which can then be used to destroy and modify internal resources. NOTE: it was later reported that PHP 5.2 through 5.2.13 and 5.3 through 5.3.2 are also affected.

CVSS
AV:N/AC:M/Au:N/C:C/I:C/A:C

External References
- CVE-2007-1581

PHP Other Vulnerability

PHP before 5.2.12 does not properly handle session data, which has unspecified impact and attack vectors related to (1) interrupt corruption of the SESSION superglobal array and (2) the session.save_path directive.

CVSS
AV:N/AC:L/Au:N/C:C/I:C/A:C

External References
- CVE-2009-4143

PHP Other Vulnerability

PHP before 5.2.12 does not properly handle session data, which has unspecified impact and attack vectors related to (1) interrupt corruption of the SESSION superglobal array and (2) the session.save_path directive.

CVSS
AV:N/AC:L/Au:N/C:C/I:C/A:C

External References
- CVE-2009-4143

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Heap-based buffer overflow in ext/mbstring/libmbfl/filters/mbfilter_htmlent.c in the mbstring extension in PHP 4.3.0 through 5.2.6 allows context-dependent attackers to execute arbitrary code via a crafted string containing an HTML entity, which is not properly handled during Unicode conversion, related to the (1) mb_convert_encoding, (2) mb_check_encoding, (3) mb_convert_variables, and (4) mb_parse_str functions.

CVSS
AV:N/AC:L/Au:N/C:C/I:C/A:C

External References
- CVE-2008-5557

PHP CVE-2008-2051 Vulnerability

The escapeshellcmd API function in PHP before 5.2.6 has unknown impact and context-dependent attack vectors related to "incomplete multibyte chars."

CVSS
AV:N/AC:L/Au:N/C:C/I:C/A:C

External References
- CVE-2008-2051

PHP CVE-2008-2051 Vulnerability

The escapeshellcmd API function in PHP before 5.2.6 has unknown impact and context-dependent attack vectors related to "incomplete multibyte chars."

CVSS
AV:N/AC:L/Au:N/C:C/I:C/A:C

External References
- CVE-2008-2051

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Buffer overflow in the crypt function in PHP before 5.3.7 allows context-dependent attackers to have an unspecified impact via a long salt argument, a different vulnerability than CVE-2011-2483.

CVSS
AV:N/AC:L/Au:N/C:C/I:C/A:C

External References
- CVE-2011-3268

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Buffer overflow in the crypt function in PHP before 5.3.7 allows context-dependent attackers to have an unspecified impact via a long salt argument, a different vulnerability than CVE-2011-2483.

CVSS
AV:N/AC:L/Au:N/C:C/I:C/A:C

External References
- CVE-2011-3268

PHP CVE-2012-2688 Vulnerability

Unspecified vulnerability in the _php_stream_scandir function in the stream implementation in PHP before 5.3.15 and 5.4.x before 5.4.5 has unknown impact and remote attack vectors, related to an "overflow."

CVSS
AV:N/AC:L/Au:N/C:C/I:C/A:C

External References
- CVE-2012-2688

PHP CVE-2012-2688 Vulnerability

Unspecified vulnerability in the _php_stream_scandir function in the stream implementation in PHP before 5.3.15 and 5.4.x before 5.4.5 has unknown impact and remote attack vectors, related to an "overflow."

CVSS
AV:N/AC:L/Au:N/C:C/I:C/A:C

External References
- CVE-2012-2688

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Buffer overflow in the com_print_typeinfo function in PHP 5.4.3 and earlier on Windows allows remote attackers to execute arbitrary code via crafted arguments that trigger incorrect handling of COM object VARIANT types, as exploited in the wild in May 2012.

CVSS
AV:N/AC:L/Au:N/C:C/I:C/A:C

External References
- CVE-2012-2376

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Buffer overflow in the com_print_typeinfo function in PHP 5.4.3 and earlier on Windows allows remote attackers to execute arbitrary code via crafted arguments that trigger incorrect handling of COM object VARIANT types, as exploited in the wild in May 2012.

CVSS
AV:N/AC:L/Au:N/C:C/I:C/A:C

External References
- CVE-2012-2376

PHP Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') Vulnerability

SQL injection vulnerability in Zend Framework 1.10.x before 1.10.9 and 1.11.x before 1.11.6 when using non-ASCII-compatible encodings in conjunction PDO_MySql in PHP before 5.3.6.

CVSS
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2011-1939

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The get_icu_disp_value_src_php function in ext/intl/locale/locale_methods.c in PHP before 5.3.29, 5.4.x before 5.4.30, and 5.5.x before 5.5.14 does not properly restrict calls to the ICU uresbund.cpp component, which allows remote attackers to cause a denial of service (buffer overflow) or possibly have unspecified other impact via a locale_get_display_name call with a long first argument.

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2014-9912

PHP Other Vulnerability

Double free vulnerability in the format printer in PHP 7.x before 7.0.1 allows remote attackers to have an unspecified impact by triggering an error.

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2015-8880

PHP Improper Input Validation Vulnerability

The phar_convert_to_other function in ext/phar/phar_object.c in PHP before 5.4.43, 5.5.x before 5.5.27, and 5.6.x before 5.6.11 does not validate a file pointer before a close operation, which allows remote attackers to cause a denial of service (segmentation fault) or possibly have unspecified other impact via a crafted TAR archive that is mishandled in a Phar::convertToData call.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2015-5589

PHP Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') Vulnerability

The escapeshellarg function in ext/standard/exec.c in PHP before 5.4.42, 5.5.x before 5.5.26, and 5.6.x before 5.6.10 on Windows allows remote attackers to execute arbitrary OS commands via a crafted string to an application that accepts command-line arguments for a call to the PHP system function.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2015-4642

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Integer overflow in the ftp_genlist function in ext/ftp/ftp.c in PHP before 5.4.42, 5.5.x before 5.5.26, and 5.6.x before 5.6.10 allows remote FTP servers to execute arbitrary code via a long reply to a LIST command, leading to a heap-based buffer overflow. NOTE: this vulnerability exists because of an incomplete fix for CVE-2015-4022.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2015-4643

PHP Other Vulnerability

The make_http_soap_request function in ext/soap/php_http.c in PHP before 5.4.44, 5.5.x before 5.5.28, and 5.6.x before 5.6.12 does not properly retrieve keys, which allows remote attackers to cause a denial of service (NULL pointer dereference, type confusion, and application crash) or possibly execute arbitrary code via crafted serialized data representing a numerically indexed _cookies array, related to the SoapClient::__call method in ext/soap/soap.c.

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2015-8835

PHP Other Vulnerability

Multiple use-after-free vulnerabilities in PHP before 5.4.45, 5.5.x before 5.5.29, and 5.6.x before 5.6.13 allow remote attackers to execute arbitrary code via vectors related to (1) the Serializable interface, (2) the SplObjectStorage class, and (3) the SplDoublyLinkedList class, which are mishandled during unserialization.

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2015-6834

PHP Other Vulnerability

The session deserializer in PHP before 5.4.45, 5.5.x before 5.5.29, and 5.6.x before 5.6.13 mishandles multiple php_var_unserialize calls, which allow remote attackers to execute arbitrary code or cause a denial of service (use-after-free) via crafted session content.

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2015-6835

PHP Other Vulnerability

The SoapClient implementation in PHP before 5.4.40, 5.5.x before 5.5.24, and 5.6.x before 5.6.8 allows remote attackers to cause a denial of service (application crash) or possibly execute arbitrary code via an unexpected data type, related to "type confusion" issues in the (1) SoapClient::__getLastRequest, (2) SoapClient::__getLastResponse, (3) SoapClient::__getLastRequestHeaders, (4) SoapClient::__getLastResponseHeaders, (5) SoapClient::__getCookies, and (6) SoapClient::__setCookie methods.

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2015-4600

PHP Other Vulnerability

The SoapFault::__toString method in ext/soap/soap.c in PHP before 5.4.40, 5.5.x before 5.5.24, and 5.6.x before 5.6.8 allows remote attackers to obtain sensitive information, cause a denial of service (application crash), or possibly execute arbitrary code via an unexpected data type, related to a "type confusion" issue.

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2015-4599

PHP Other Vulnerability

Use-after-free vulnerability in the spl_ptr_heap_insert function in ext/spl/spl_heap.c in PHP before 5.5.27 and 5.6.x before 5.6.11 allows remote attackers to execute arbitrary code by triggering a failed SplMinHeap::compare operation.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2015-4116

PHP Other Vulnerability

The exception::getTraceAsString function in Zend/zend_exceptions.c in PHP before 5.4.40, 5.5.x before 5.5.24, and 5.6.x before 5.6.8 allows remote attackers to execute arbitrary code via an unexpected data type, related to a "type confusion" issue.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2015-4603

PHP Other Vulnerability

PHP before 5.6.7 might allow remote attackers to cause a denial of service (application crash) or possibly execute arbitrary code via an unexpected data type, related to "type confusion" issues in (1) ext/soap/php_encoding.c, (2) ext/soap/php_http.c, and (3) ext/soap/soap.c, a different issue than CVE-2015-4600.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2015-4601

PHP Other Vulnerability

The __PHP_Incomplete_Class function in ext/standard/incomplete_class.c in PHP before 5.4.40, 5.5.x before 5.5.24, and 5.6.x before 5.6.8 allows remote attackers to cause a denial of service (application crash) or possibly execute arbitrary code via an unexpected data type, related to a "type confusion" issue.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2015-4602

PHP DEPRECATED: Code Vulnerability

The apprentice_load function in libmagic/apprentice.c in the Fileinfo component in PHP through 5.6.4 attempts to perform a free operation on a stack-based character array, which allows remote attackers to cause a denial of service (memory corruption or application crash) or possibly have unspecified other impact via unknown vectors. NOTE: this is disputed by the vendor because the standard erealloc behavior makes the free operation unreachable

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2014-9426

PHP Resource Management Errors Vulnerability

The gdImageScaleTwoPass function in gd_interpolation.c in the GD Graphics Library (aka libgd) before 2.2.0, as used in PHP before 5.6.12, uses inconsistent allocate and free approaches, which allows remote attackers to cause a denial of service (memory consumption) via a crafted call, as demonstrated by a call to the PHP imagescale function.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2015-8877

PHP Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') Vulnerability

sapi/cgi/cgi_main.c in PHP before 5.3.13 and 5.4.x before 5.4.3, when configured as a CGI script (aka php-cgi), does not properly handle query strings that contain a %3D sequence but no = (equals sign) character, which allows remote attackers to execute arbitrary code by placing command-line options in the query string, related to lack of skipping a certain php_getopt for the 'd' case. NOTE: this vulnerability exists because of an incomplete fix for CVE-2012-1823.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2012-2311

PHP Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') Vulnerability

sapi/cgi/cgi_main.c in PHP before 5.3.13 and 5.4.x before 5.4.3, when configured as a CGI script (aka php-cgi), does not properly handle query strings that contain a %3D sequence but no = (equals sign) character, which allows remote attackers to execute arbitrary code by placing command-line options in the query string, related to lack of skipping a certain php_getopt for the 'd' case. NOTE: this vulnerability exists because of an incomplete fix for CVE-2012-1823.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2012-2311

PHP Out-of-bounds Read Vulnerability

In PHP versions prior to 7.4.33, 8.0.25 and 8.2.12, when using imageloadfont() function in gd extension, it is possible to supply a specially crafted font file, such as if the loaded font is used with imagechar() function, the read outside allocated buffer will be used. This can lead to crashes or disclosure of confidential information.

CVSS

CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:H

External References

- CVE-2022-31630

PHP Numeric Errors Vulnerability

CVE-2012-2386 php: Integer overflow leading to heap-buffer overflow in the Phar extension

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2012-2386

PHP CVE-2014-3515 Vulnerability

The SPL component in PHP before 5.4.30 and 5.5.x before 5.5.14 incorrectly anticipates that certain data structures will have the array data type after unserialization, which allows remote attackers to execute arbitrary code via a crafted string that triggers use of a Hashtable destructor, related to "type confusion" issues in (1) ArrayObject and (2) SPLObjectStorage.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2014-3515

PHP Use After Free Vulnerability

Multiple use-after-free vulnerabilities in SPL in PHP before 5.4.44, 5.5.x before 5.5.28, and 5.6.x before 5.6.12 allow remote attackers to execute arbitrary code via vectors involving (1) ArrayObject, (2) SplObjectStorage, and (3) SplDoublyLinkedList, which are mishandled during unserialization.

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

External References

- CVE-2015-6831

PHP Out-of-bounds Write Vulnerability

Heap-based buffer overflow in pcre_compile.c in the Perl-Compatible Regular Expression (PCRE) library 7.7 allows context-dependent attackers to cause a denial of service (crash) or possibly execute arbitrary code via a regular expression that begins with an option and contains multiple branches.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2008-2371

PHP Out-of-bounds Write Vulnerability

The bzread function in ext/bz2/bz2.c in PHP before 5.5.38, 5.6.x before 5.6.24, and 7.x before 7.0.9 allows remote attackers to cause a denial of service (out-of-bounds write) or execute arbitrary code via a crafted bz2 archive.

Affected Versions

0.2.0 to

CVSS
CVSS:3.0/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

External References
- CVE-2016-5399

PHP Deserialization of Untrusted Data Vulnerability

In PHP before 5.6.31, an invalid free in the WDDX deserialization of boolean parameters could be used by attackers able to inject XML for deserialization to crash the PHP interpreter, related to an invalid free for an empty boolean element in ext/wddx/wddx.c.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2017-11143

PHP Uncontrolled Resource Consumption Vulnerability

In PHP before 5.6.31, 7.x before 7.0.17, and 7.1.x before 7.1.3, remote attackers could cause a CPU consumption denial of service attack by injecting long form variables, related to main/php_variables.c.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2017-11142

PHP Improper Input Validation Vulnerability

In PHP before 5.6.28 and 7.x before 7.0.13, incorrect handling of various URI components in the URL parser could be used by attackers to bypass hostname-specific URL checks, as demonstrated by evil.example.com:80#@good.example.com/ and evil.example.com:80?@good.example.com/ inputs to the parse_url function (implemented in the php_url_parse_ex function in ext/standard/url.c).

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

External References
- CVE-2016-10397

PHP Allocation of Resources Without Limits or Throttling Vulnerability

** DISPUTED ** The GNU Multiple Precision Arithmetic Library (GMP) interfaces for PHP through 7.1.4 allow attackers to cause a denial of service (memory consumption and application crash) via operations on long strings. NOTE: the vendor disputes this, stating "There is no security issue here, because GMP safely aborts in case of an OOM condition. The only attack vector here is denial of

service. However, if you allow attacker-controlled, unbounded allocations you have a DoS vector regardless of GMP's OOM behavior."

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2017-7963

PHP Integer Overflow or Wraparound Vulnerability

Integer overflow in the phar_parse_pharfile function in ext/phar/phar.c in PHP before 5.6.30 and 7.0.x before 7.0.15 allows remote attackers to cause a denial of service (memory consumption or application crash) via a truncated manifest entry in a PHAR archive.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2016-10159

PHP Server-Side Request Forgery (SSRF) Vulnerability

PHP through 7.1.11 enables potential SSRF in applications that accept an fsockopen or pfsockopen hostname argument with an expectation that the port number is constrained. Because a :port syntax is recognized, fsockopen will use the port number that is specified in the hostname argument, instead of the port number in the second argument of the function.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:N/I:H/A:N

External References
- CVE-2017-7272

PHP Out-of-bounds Read Vulnerability

The object_common1 function in ext/standard/var_unserializer.c in PHP before 5.6.30, 7.0.x before 7.0.15, and 7.1.x before 7.1.1 allows remote attackers to cause a denial of service (buffer over-read and application crash) via crafted serialized data that is mishandled in a finish_nested_data call.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2016-10161

PHP Out-of-bounds Read Vulnerability

In PHP before 5.6.32, 7.x before 7.0.25, and 7.1.x before 7.1.11, an error in the date extension's timelib_meridian handling of 'front of' and 'back of' directives could be used by attackers able to supply date strings to leak information from the interpreter, related to ext/date/lib/parse_date.c out-of-bounds reads affecting the php_parse_date function. NOTE: this is a different issue than CVE-2017-11145.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

External References

- CVE-2017-16642

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

In PHP before 5.6.31, 7.x before 7.0.21, and 7.1.x before 7.1.7, an error in the date extension's timelib_meridian parsing code could be used by attackers able to supply date strings to leak information from the interpreter, related to ext/date/lib/parse_date.c out-of-bounds reads affecting the php_parse_date function. NOTE: the correct fix is in the e8b7698f5ee757ce2c8bd10a192a491a498f891c commit, not the bd77ac90d3bdf31ce2a5251ad92e9e75 gist.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

External References

- CVE-2017-11145

PHP Improper Check for Unusual or Exceptional Conditions Vulnerability

In PHP before 5.6.31, 7.x before 7.0.21, and 7.1.x before 7.1.7, the openssl extension PEM sealing code did not check the return value of the OpenSSL sealing function, which could lead to a crash of the PHP interpreter, related to an interpretation conflict for a negative number in ext/openssl/openssl.c, and an OpenSSL documentation omission.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2017-11144

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

In PHP before 5.6.31, 7.x before 7.0.21, and 7.1.x before 7.1.7, a stack-based buffer overflow in the zend_ini_do_op() function in Zend/zend_ini_parser.c could cause a denial of service or potentially allow executing code. NOTE: this is only relevant for PHP

applications that accept untrusted input (instead of the system's php.ini file) for the parse_ini_string or parse_ini_file function, e.g., a web application for syntax validation of php.ini directives.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

External References
- CVE-2017-11628

PHP Numeric Errors Vulnerability

The exif_convert_any_to_int function in ext/exif/exif.c in PHP before 5.6.30, 7.0.x before 7.0.15, and 7.1.x before 7.1.1 allows remote attackers to cause a denial of service (application crash) via crafted EXIF data that triggers an attempt to divide the minimum representable negative integer by -1.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2016-10158

PHP NULL Pointer Dereference Vulnerability

ext/wddx/wddx.c in PHP before 5.6.25 and 7.x before 7.0.10 allows remote attackers to cause a denial of service (NULL pointer dereference and application crash) or possibly have unspecified other impact via an invalid wddxPacket XML document that is mishandled in a wddx_deserialize call, as demonstrated by a stray element inside a boolean element, leading to incorrect pop processing.

Affected Versions
0.2.0 to

CVSS
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2016-7132

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

ext/mysqlnd/mysqlnd_wireprotocol.c in PHP before 5.6.26 and 7.x before 7.0.11 does not verify that a BIT field has the UNSIGNED_FLAG flag, which allows remote MySQL servers to cause a denial of service (heap-based buffer overflow) or possibly have unspecified other impact via crafted field metadata.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-7412

PHP NULL Pointer Dereference Vulnerability

ext/wddx/wddx.c in PHP before 5.6.25 and 7.x before 7.0.10 allows remote attackers to cause a denial of service (NULL pointer dereference and application crash) or possibly have unspecified other impact via a malformed wddxPacket XML document that is mishandled in a wddx_deserialize call, as demonstrated by a tag that lacks a < (less than) character.

Affected Versions
0.2.0 to

CVSS
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2016-7131

PHP NULL Pointer Dereference Vulnerability

The php_wddx_pop_element function in ext/wddx/wddx.c in PHP before 5.6.25 and 7.x before 7.0.10 allows remote attackers to cause a denial of service (NULL pointer dereference and application crash) or possibly have unspecified other impact via an invalid base64 binary value, as demonstrated by a wddx_deserialize call that mishandles a binary element in a wddxPacket XML document.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2016-7130

PHP Other Vulnerability

Zend/zend_exceptions.c in PHP, possibly 5.x before 5.6.28 and 7.x before 7.0.13, allows remote attackers to cause a denial of service (infinite loop) via a crafted Exception object in serialized data, a related issue to CVE-2015-8876.

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2016-7478

PHP NULL Pointer Dereference Vulnerability

ext/wddx/wddx.c in PHP before 5.6.28 and 7.x before 7.0.13 allows remote attackers to cause a denial of service (NULL pointer dereference) via crafted serialized data in a wddxPacket XML document, as demonstrated by a PDORow string.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2016-9934

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The php_wddx_push_element function in ext/wddx/wddx.c in PHP before 5.6.26 and 7.x before 7.0.11 allows remote attackers to cause a denial of service (invalid pointer access and out-of-bounds read) or possibly have unspecified other impact via an incorrect boolean element in a wddxPacket XML document, leading to mishandling in a wddx_deserialize call.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2016-7418

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

ext/intl/msgformat/msgformat_format.c in PHP before 5.6.26 and 7.x before 7.0.11 does not properly restrict the locale length provided to the Locale class in the ICU library, which allows remote attackers to cause a denial of service (application crash) or possibly have unspecified other impact via a MessageFormatter::formatMessage call with a long first argument.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2016-7416

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

An issue was discovered in the EXIF component in PHP before 7.1.27, 7.2.x before 7.2.16, and 7.3.x before 7.3.3. There is an uninitialized read in exif_process_IFD_in_MAKERNOTE because of mishandling the data_len variable.

Affected Versions
0.2.0 to

CVSS
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

External References
- CVE-2019-9639

PHP Out-of-bounds Read Vulnerability

An issue was discovered in PHP before 5.6.40, 7.x before 7.1.26, 7.2.x before 7.2.14, and 7.3.x before 7.3.1. xmlrpc_decode() can allow a hostile XMLRPC server to cause PHP to read memory outside of allocated areas in base64_decode_xmlrpc in

ext/xmlrpc/libxmlrpc/base64.c.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

External References
- CVE-2019-9024

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

An issue was discovered in the EXIF component in PHP before 7.1.27, 7.2.x before 7.2.16, and 7.3.x before 7.3.3. There is an uninitialized read in exif_process_IFD_in_MAKERNOTE because of mishandling the maker_note->offset relationship to value_len.

Affected Versions
0.2.0 to

CVSS
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

External References
- CVE-2019-9638

PHP Permissions, Privileges, and Access Controls Vulnerability

An issue was discovered in PHP before 7.1.27, 7.2.x before 7.2.16, and 7.3.x before 7.3.3. Due to the way rename() across filesystems is implemented, it is possible that file being renamed is briefly available with wrong permissions while the rename is ongoing, thus enabling unauthorized users to access the data.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

External References
- CVE-2019-9637

PHP NULL Pointer Dereference Vulnerability

An issue was discovered in PHP before 5.6.36, 7.0.x before 7.0.30, 7.1.x before 7.1.17, and 7.2.x before 7.2.5. ext/ldap/ldap.c allows remote LDAP servers to cause a denial of service (NULL pointer dereference and application crash) because of mishandling of the ldap_get_dn return value.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2018-10548

PHP Out-of-bounds Read Vulnerability

An issue was discovered in PHP before 5.6.36, 7.0.x before 7.0.30, 7.1.x before 7.1.17, and 7.2.x before 7.2.5. exif_read_data in ext/exif/exif.c has an out-of-bounds read for crafted JPEG data because exif_iif_add_value mishandles the case of a MakerNote that lacks a final '\0' character.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

External References

- CVE-2018-10549

PHP Improper Input Validation Vulnerability

In PHP before 5.5.32, 5.6.x before 5.6.18, and 7.x before 7.0.3, all of the return values of stream_get_meta_data can be controlled if the input can be controlled (e.g., during file uploads). For example, a "$uri = stream_get_meta_data(fopen($file, "r"))['uri']" call mishandles the case where $file is data:text/plain;uri=eviluri, -- in other words, metadata can be set by an attacker.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

External References

- CVE-2016-10712

PHP Loop with Unreachable Exit Condition ('Infinite Loop') Vulnerability

An issue was discovered in PHP before 5.6.36, 7.0.x before 7.0.30, 7.1.x before 7.1.17, and 7.2.x before 7.2.5. An infinite loop exists in ext/iconv/iconv.c because the iconv stream filter does not reject invalid multibyte sequences.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2018-10546

PHP Out-of-bounds Read Vulnerability

In PHP before 5.6.39, 7.x before 7.0.33, 7.1.x before 7.1.25, and 7.2.x before 7.2.13, a buffer over-read in PHAR reading functions may allow an attacker to read allocated or unallocated memory past the actual data when trying to parse a .phar file. This is related to phar_parse_pharfile in ext/phar/phar.c.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

External References
- CVE-2018-20783

PHP NULL Pointer Dereference Vulnerability

ext/imap/php_imap.c in PHP 5.x and 7.x before 7.3.0 allows remote attackers to cause a denial of service (NULL pointer dereference and application crash) via an empty string in the message argument to the imap_mail function.

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2018-19935

PHP Out-of-bounds Write Vulnerability

gdImageColorMatch in gd_color_match.c in the GD Graphics Library (aka LibGD) 2.2.5, as used in the imagecolormatch function in PHP before 5.6.40, 7.x before 7.1.26, 7.2.x before 7.2.14, and 7.3.x before 7.3.1, has a heap-based buffer overflow. This can be exploited by an attacker who is able to trigger imagecolormatch calls with crafted image data.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

External References
- CVE-2019-6977

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

An issue was discovered in ext/standard/link_win32.c in PHP before 5.6.37, 7.0.x before 7.0.31, 7.1.x before 7.1.20, and 7.2.x before 7.2.8. The linkinfo function on Windows doesn't implement the open_basedir check. This could be abused to find files on paths outside of the allowed directories.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

External References
- CVE-2018-15132

PHP Integer Overflow or Wraparound Vulnerability

An issue was discovered in PHP before 5.6.37, 7.0.x before 7.0.31, 7.1.x before 7.1.20, and 7.2.x before 7.2.8. An Integer Overflow leads to a heap-based buffer over-read in exif_thumbnail_extract of exif.c.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2018-14883

PHP Deserialization of Untrusted Data Vulnerability

ext/standard/var_unserializer.c in PHP 5.x through 7.1.24 allows attackers to cause a denial of service (application crash) via an unserialize call for the com, dotnet, or variant class.

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2018-19396

PHP NULL Pointer Dereference Vulnerability

ext/standard/var.c in PHP 5.x through 7.1.24 on Windows allows attackers to cause a denial of service (NULL pointer dereference and application crash) because com and com_safearray_proxy return NULL in com_properties_get in ext/com_dotnet/com_handlers.c, as demonstrated by a serialize call on COM("WScript.Shell").

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2018-19395

PHP Improper Control of Generation of Code ('Code Injection') Vulnerability

An issue was discovered in SDCMS 1.6 with PHP 5.x. app/admin/controller/themecontroller.php uses a check_bad function in an attempt to block certain PHP functions such as eval, but does not prevent use of preg_replace 'e' calls, allowing users to execute arbitrary code by leveraging access to admin template management.

CVSS
CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2018-19520

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The phar_parse_zipfile function in zip.c in the PHAR extension in PHP before 5.5.33 and 5.6.x before 5.6.19 allows remote attackers to obtain sensitive information from process memory or cause a denial of service (out-of-bounds read and application crash) by placing a PK\x05\x06 signature at an invalid location.

Affected Versions
0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:H

External References

- CVE-2016-3142

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Integer overflow in the php_stream_zip_opener function in ext/zip/zip_stream.c in PHP before 5.5.38, 5.6.x before 5.6.24, and 7.x before 7.0.9 allows remote attackers to cause a denial of service (stack-based buffer overflow) or possibly have unspecified other impact via a crafted zip:// URL.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

External References

- CVE-2016-6297

PHP Out-of-bounds Read Vulnerability

The get_icu_value_internal function in ext/intl/locale/locale_methods.c in PHP before 5.5.36, 5.6.x before 5.6.22, and 7.x before 7.0.7 does not ensure the presence of a '\0' character, which allows remote attackers to cause a denial of service (out-of-bounds read) or possibly have unspecified other impact via a crafted locale_get_primary_language call.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:H

External References

- CVE-2016-5093

PHP Integer Overflow or Wraparound Vulnerability

Integer overflow in the php_html_entities function in ext/standard/html.c in PHP before 5.5.36 and 5.6.x before 5.6.22 allows remote attackers to cause a denial of service or possibly have unspecified other impact by triggering a large output string from the htmlspecialchars function.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:H

External References

- CVE-2016-5094

PHP Improper Neutralization of Special Elements in Output Used by a Downstream Component ('Injection') Vulnerability

ext/session/session.c in PHP before 5.6.25 and 7.x before 7.0.10 skips invalid session names in a way that triggers incorrect parsing, which allows remote attackers to inject arbitrary-type session data by leveraging control of a session name, as demonstrated by object

injection.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

External References
- CVE-2016-7125

PHP Integer Overflow or Wraparound Vulnerability

Integer overflow in the fread function in ext/standard/file.c in PHP before 5.5.36 and 5.6.x before 5.6.22 allows remote attackers to cause a denial of service or possibly have unspecified other impact via a large integer in the second argument.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:H

External References
- CVE-2016-5096

PHP Integer Overflow or Wraparound Vulnerability

Integer overflow in the php_escape_html_entities_ex function in ext/standard/html.c in PHP before 5.5.36 and 5.6.x before 5.6.22 allows remote attackers to cause a denial of service or possibly have unspecified other impact by triggering a large output string from a FILTER_SANITIZE_FULL_SPECIAL_CHARS filter_var call. NOTE: this vulnerability exists because of an incomplete fix for CVE-2016-5094.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:H

External References
- CVE-2016-5095

PHP Other Vulnerability

The phar_make_dirstream function in ext/phar/dirstream.c in PHP before 5.6.18 and 7.x before 7.0.3 mishandles zero-size ././@LongLink files, which allows remote attackers to cause a denial of service (uninitialized pointer dereference) or possibly have unspecified other impact via a crafted TAR archive.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

External References

- CVE-2016-4343

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

ext/phar/phar_object.c in PHP before 5.5.32, 5.6.x before 5.6.18, and 7.x before 7.0.3 mishandles zero-length uncompressed data, which allows remote attackers to cause a denial of service (heap memory corruption) or possibly have unspecified other impact via a crafted (1) TAR, (2) ZIP, or (3) PHAR archive.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

External References

- CVE-2016-4342

PHP Improper Input Validation Vulnerability

The make_http_soap_request function in ext/soap/php_http.c in PHP before 5.4.44, 5.5.x before 5.5.28, 5.6.x before 5.6.12, and 7.x before 7.0.4 allows remote attackers to obtain sensitive information from process memory or cause a denial of service (type confusion and application crash) via crafted serialized _cookies data, related to the SoapClient::__call method in ext/soap/soap.c.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:H

External References

- CVE-2016-3185

PHP Numeric Errors Vulnerability

** DISPUTED ** Integer overflow in the php_raw_url_encode function in ext/standard/url.c in PHP before 5.5.34, 5.6.x before 5.6.20, and 7.x before 7.0.5 allows remote attackers to cause a denial of service (application crash) via a long string to the rawurlencode function. NOTE: the vendor says "Not sure if this qualifies as security issue (probably not)."

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2016-4070

PHP CVE-2016-6174 Vulnerability

applications/core/modules/front/system/content.php in Invision Power Services IPS Community Suite (aka Invision Power Board, IPB, or Power Board) before 4.1.13, when used with PHP before 5.4.24 or 5.5.x before 5.5.8, allows remote attackers to execute arbitrary code via the content_class parameter.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-6174

PHP Improper Access Control Vulnerability

PHP through 7.0.8 does not attempt to address RFC 3875 section 4.1.18 namespace conflicts and therefore does not protect applications from the presence of untrusted client data in the HTTP_PROXY environment variable, which might allow remote attackers to redirect an application's outbound HTTP traffic to an arbitrary proxy server via a crafted Proxy header in an HTTP request, as demonstrated by (1) an application that makes a getenv('HTTP_PROXY') call or (2) a CGI configuration of PHP, aka an "httpoxy" issue.

Affected Versions
0.2.0 to

CVSS
CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

External References
- CVE-2016-5385

PHP Integer Overflow or Wraparound Vulnerability

Integer overflow in the virtual_file_ex function in TSRM/tsrm_virtual_cwd.c in PHP before 5.5.38, 5.6.x before 5.6.24, and 7.x before 7.0.9 allows remote attackers to cause a denial of service (stack-based buffer overflow) or possibly have unspecified other impact via a crafted extract operation on a ZIP archive.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

External References
- CVE-2016-6289

PHP Improper Input Validation Vulnerability

The safe_mode implementation in PHP before 5.2.13 does not properly handle directory pathnames that lack a trailing / (slash) character, which allows context-dependent attackers to bypass intended access restrictions via vectors related to use of the tempnam function.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2010-1129

PHP Improper Control of Generation of Code ('Code Injection') Vulnerability

The (1) sqlite_single_query and (2) sqlite_array_query functions in ext/sqlite/sqlite.c in PHP 5.2 through 5.2.13 and 5.3 through 5.3.2 allow context-dependent attackers to execute arbitrary code by calling these functions with an empty SQL query, which triggers access of uninitialized memory.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2010-1868

PHP Resource Management Errors Vulnerability

Use-after-free vulnerability in the SplObjectStorage unserializer in PHP 5.2.x and 5.3.x through 5.3.2 allows remote attackers to execute arbitrary code or obtain sensitive information via serialized data, related to the PHP unserialize function.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2010-2225

PHP Permissions, Privileges, and Access Controls Vulnerability

The proc_open function in ext/standard/proc_open.c in PHP before 5.2.11 and 5.3.x before 5.3.1 does not enforce the (1) safe_mode_allowed_env_vars and (2) safe_mode_protected_env_vars directives, which allows context-dependent attackers to execute programs with an arbitrary environment via the env parameter, as demonstrated by a crafted value of the LD_LIBRARY_PATH environment variable.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2009-4018

PHP Permissions, Privileges, and Access Controls Vulnerability

The proc_open function in ext/standard/proc_open.c in PHP before 5.2.11 and 5.3.x before 5.3.1 does not enforce the (1) safe_mode_allowed_env_vars and (2) safe_mode_protected_env_vars directives, which allows context-dependent attackers to execute programs with an arbitrary environment via the env parameter, as demonstrated by a crafted value of the LD_LIBRARY_PATH environment variable.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2009-4018

PHP Numeric Errors Vulnerability

Integer overflow in ext/shmop/shmop.c in PHP before 5.3.6 allows context-dependent attackers to cause a denial of service (crash) and possibly read sensitive memory via a large third argument to the shmop_read function.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2011-1092

PHP Use of Externally-Controlled Format String Vulnerability

Multiple format string vulnerabilities in phar_object.c in the phar extension in PHP 5.3.5 and earlier allow context-dependent attackers to obtain sensitive information from process memory, cause a denial of service (memory corruption), or possibly execute arbitrary code via format string specifiers in an argument to a class method, leading to an incorrect zend_throw_exception_ex call.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2011-1153

PHP Numeric Errors Vulnerability

Integer overflow in ext/shmop/shmop.c in PHP before 5.3.6 allows context-dependent attackers to cause a denial of service (crash) and possibly read sensitive memory via a large third argument to the shmop_read function.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2011-1092

PHP Resource Management Errors Vulnerability

Use-after-free vulnerability in the substr_replace function in PHP 5.3.6 and earlier allows context-dependent attackers to cause a denial of service (memory corruption) or possibly have unspecified other impact by using the same variable for multiple arguments.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2011-1148

PHP Use of Externally-Controlled Format String Vulnerability

Multiple format string vulnerabilities in phar_object.c in the phar extension in PHP 5.3.5 and earlier allow context-dependent attackers to obtain sensitive information from process memory, cause a denial of service (memory corruption), or possibly execute arbitrary code via format string specifiers in an argument to a class method, leading to an incorrect zend_throw_exception_ex call.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2011-1153

PHP Improper Input Validation Vulnerability

The php_openssl_apply_verification_policy function in PHP before 5.2.11 does not properly perform certificate validation, which has unknown impact and attack vectors, probably related to an ability to spoof certificates.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2009-3291

PHP Improper Input Validation Vulnerability

The php_openssl_apply_verification_policy function in PHP before 5.2.11 does not properly perform certificate validation, which has unknown impact and attack vectors, probably related to an ability to spoof certificates.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2009-3291

PHP CVE-2009-3293 Vulnerability

Unspecified vulnerability in the imagecolortransparent function in PHP before 5.2.11 has unknown impact and attack vectors related to an incorrect "sanity check for the color index."

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2009-3293

PHP CVE-2009-3292 Vulnerability

Unspecified vulnerability in PHP before 5.2.11, and 5.3.x before 5.3.1, has unknown impact and attack vectors related to "missing sanity checks around exif processing."

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2009-3292

PHP CVE-2009-3292 Vulnerability

Unspecified vulnerability in PHP before 5.2.11, and 5.3.x before 5.3.1, has unknown impact and attack vectors related to "missing sanity checks around exif processing."

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2009-3292

PHP CVE-2009-3293 Vulnerability

Unspecified vulnerability in the imagecolortransparent function in PHP before 5.2.11 has unknown impact and attack vectors related to an incorrect "sanity check for the color index."

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2009-3293

PHP Numeric Errors Vulnerability

The GENERATE_SEED macro in PHP 4.x before 4.4.8 and 5.x before 5.2.5, when running on 32-bit systems, performs a multiplication using values that can produce a zero seed in rare circumstances, which allows context-dependent attackers to predict subsequent values of the rand and mt_rand functions and possibly bypass protection mechanisms that rely on an unknown initial seed.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2008-2107

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Buffer overflow in the imageloadfont function in ext/gd/gd.c in PHP 4.4.x before 4.4.9 and PHP 5.2 before 5.2.6-r6 allows context-dependent attackers to cause a denial of service (crash) and possibly execute arbitrary code via a crafted font file.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2008-3658

PHP Permissions, Privileges, and Access Controls Vulnerability

PHP 5 before 5.2.7 does not enforce the error_log safe_mode restrictions when safe_mode is enabled through a php_admin_flag setting in httpd.conf, which allows context-dependent attackers to write to arbitrary files by placing a "php_value error_log" entry in a .htaccess file.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2008-5625

PHP Permissions, Privileges, and Access Controls Vulnerability

PHP 5 before 5.2.7 does not properly initialize the page_uid and page_gid global variables for use by the SAPI php_getuid function, which allows context-dependent attackers to bypass safe_mode restrictions via variable settings that are intended to be restricted to root, as demonstrated by a setting of /etc for the error_log variable.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2008-5624

PHP Permissions, Privileges, and Access Controls Vulnerability

PHP 5 before 5.2.7 does not enforce the error_log safe_mode restrictions when safe_mode is enabled through a php_admin_flag setting in httpd.conf, which allows context-dependent attackers to write to arbitrary files by placing a "php_value error_log" entry in a .htaccess file.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2008-5625

PHP Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') Vulnerability

Directory traversal vulnerability in the ZipArchive::extractTo function in PHP 5.2.6 and earlier allows context-dependent attackers to write arbitrary files via a ZIP file with a file whose name contains .. (dot dot) sequences.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2008-5658

PHP Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') Vulnerability

Directory traversal vulnerability in the ZipArchive::extractTo function in PHP 5.2.6 and earlier allows context-dependent attackers to write arbitrary files via a ZIP file with a file whose name contains .. (dot dot) sequences.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2008-5658

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The asn1_time_to_time_t function in ext/openssl/openssl.c in PHP before 5.3.28, 5.4.x before 5.4.23, and 5.5.x before 5.5.7 does not properly parse (1) notBefore and (2) notAfter timestamps in X.509 certificates, which allows remote attackers to execute arbitrary code or cause a denial of service (memory corruption) via a crafted certificate that is not properly handled by the openssl_x509_parse function.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2013-6420

PHP Numeric Errors Vulnerability

Integer overflow in the object_custom function in ext/standard/var_unserializer.c in PHP before 5.4.34, 5.5.x before 5.5.18, and 5.6.x before 5.6.2 allows remote attackers to cause a denial of service (application crash) or possibly execute arbitrary code via an argument to the unserialize function that triggers calculation of a large length value.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2014-3669

PHP Other Vulnerability

Multiple use-after-free vulnerabilities in ext/date/php_date.c in PHP before 5.4.38, 5.5.x before 5.5.22, and 5.6.x before 5.6.6 allow remote attackers to execute arbitrary code via crafted serialized input containing a (1) R or (2) r type specifier in (a) DateTimeZone data handled by the php_date_timezone_initialize_from_hash function or (b) DateTime data handled by the php_date_initialize_from_hash function.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2015-0273

PHP Use After Free Vulnerability

Use-after-free vulnerability in the _zend_shared_memdup function in zend_shared_alloc.c in the OPcache extension in PHP through 5.6.7 allows remote attackers to cause a denial of service or possibly have unspecified other impact via unknown vectors.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2015-1351

PHP Improper Input Validation Vulnerability

readelf.c in file before 5.22, as used in the Fileinfo component in PHP before 5.4.37, 5.5.x before 5.5.21, and 5.6.x before 5.6.5, does not consider that pread calls sometimes read only a subset of the available data, which allows remote attackers to cause a denial of service (uninitialized memory access) or possibly have unspecified other impact via a crafted ELF file.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2014-9653

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Heap-based buffer overflow in the enchant_broker_request_dict function in ext/enchant/enchant.c in PHP before 5.4.38, 5.5.x before 5.5.22, and 5.6.x before 5.6.6 allows remote attackers to execute arbitrary code via vectors that trigger creation of multiple dictionaries.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2014-9705

PHP Other Vulnerability

Use-after-free vulnerability in the process_nested_data function in ext/standard/var_unserializer.re in PHP before 5.4.39, 5.5.x before 5.5.23, and 5.6.x before 5.6.7 allows remote attackers to execute arbitrary code via a crafted unserialize call that leverages use of the unset function within an __wakeup function, a related issue to CVE-2015-0231.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2015-2787

PHP Numeric Errors Vulnerability

Integer overflow in the _zip_cdir_new function in zip_dirent.c in libzip 0.11.2 and earlier, as used in the ZIP extension in PHP before 5.4.39, 5.5.x before 5.5.23, and 5.6.x before 5.6.7 and other products, allows remote attackers to cause a denial of service (application crash) or possibly execute arbitrary code via a ZIP archive that contains many entries, leading to a heap-based buffer overflow.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2015-2331

PHP Other Vulnerability

Use-after-free vulnerability in the process_nested_data function in ext/standard/var_unserializer.re in PHP before 5.4.36, 5.5.x before 5.5.20, and 5.6.x before 5.6.4 allows remote attackers to execute arbitrary code via a crafted unserialize call that leverages improper handling of duplicate keys within the serialized properties of an object, a different vulnerability than CVE-2004-1019.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2014-8142

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Stack-based buffer overflow in the date_from_ISO8601 function in ext/xmlrpc/libxmlrpc/xmlrpc.c in PHP before 5.2.7 allows remote attackers to cause a denial of service (application crash) or possibly execute arbitrary code by including a timezone field in a date, leading to improper XML-RPC encoding.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2014-8626

PHP Other Vulnerability

Double free vulnerability in the zend_ts_hash_graceful_destroy function in zend_ts_hash.c in the Zend Engine in PHP through 5.5.20 and 5.6.x through 5.6.4 allows remote attackers to cause a denial of service or possibly have unspecified other impact via unknown vectors.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2014-9425

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Stack-based buffer overflow in the date_from_ISO8601 function in ext/xmlrpc/libxmlrpc/xmlrpc.c in PHP before 5.2.7 allows remote attackers to cause a denial of service (application crash) or possibly execute arbitrary code by including a timezone field in a date, leading to improper XML-RPC encoding.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2014-8626

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

sapi/cgi/cgi_main.c in the CGI component in PHP through 5.4.36, 5.5.x through 5.5.20, and 5.6.x through 5.6.4, when mmap is used to read a .php file, does not properly consider the mapping's length during processing of an invalid file that begins with a # character and lacks a newline character, which causes an out-of-bounds read and might (1) allow remote attackers to obtain sensitive information from php-cgi process memory by leveraging the ability to upload a .php file or (2) trigger unexpected code execution if a valid PHP script is present in memory locations adjacent to the mapping.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2014-9427

PHP Other Vulnerability

Use-after-free vulnerability in the process_nested_data function in ext/standard/var_unserializer.re in PHP before 5.4.37, 5.5.x before 5.5.21, and 5.6.x before 5.6.5 allows remote attackers to execute arbitrary code via a crafted unserialize call that leverages improper handling of duplicate numerical keys within the serialized properties of an object. NOTE: this vulnerability exists because of an incomplete fix for CVE-2014-8142.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2015-0231

PHP Permissions, Privileges, and Access Controls Vulnerability

ext/soap/soap.c in PHP before 5.3.22 and 5.4.x before 5.4.13 does not validate the relationship between the soap.wsdl_cache_dir directive and the open_basedir directive, which allows remote attackers to bypass intended access restrictions by triggering the creation of cached SOAP WSDL files in an arbitrary directory.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2013-1635

PHP Permissions, Privileges, and Access Controls Vulnerability

ext/soap/soap.c in PHP before 5.3.22 and 5.4.x before 5.4.13 does not validate the relationship between the soap.wsdl_cache_dir directive and the open_basedir directive, which allows remote attackers to bypass intended access restrictions by triggering the creation of cached SOAP WSDL files in an arbitrary directory.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2013-1635

PHP Permissions, Privileges, and Access Controls Vulnerability

An issue was discovered in PHP 5.x and 7.x, when the configuration uses apache2handler/mod_php or php-fpm with OpCache enabled. With 5.x after 5.6.28 or 7.x after 7.0.13, the issue is resolved in a non-default configuration with the opcache.validate_permission=1 setting. The vulnerability details are as follows. In PHP SAPIs where PHP interpreters share a common parent process, Zend OpCache creates a shared memory object owned by the common parent during initialization. Child PHP processes inherit the SHM descriptor, using it to cache and retrieve compiled script bytecode ("opcode" in PHP jargon). Cache keys vary depending on configuration, but filename is a central key component, and compiled opcode can generally be run if a script's filename is known or can be guessed. Many common shared-hosting configurations change EUID in child processes to enforce privilege separation among hosted users (for example using mod_ruid2 for the Apache HTTP Server, or php-fpm user settings). In these scenarios, the default Zend OpCache behavior defeats script file permissions by sharing a single SHM cache among all child PHP processes. PHP scripts often contain sensitive information: Think of CMS configurations where reading or running another user's script usually means gaining privileges to the CMS database.

CVSS

CVSS:3.0/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H

External References

- CVE-2015-8994

PHP Missing Release of Resource after Effective Lifetime Vulnerability

PHP5 before 5.4.4 allows passing invalid utf-8 strings via the xmlTextWriterWriteAttribute, which are then misparsed by libxml2. This results in memory leak into the resulting output.

CVSS

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

External References

- CVE-2010-4657

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Stack consumption vulnerability in GD in PHP before 5.6.12 allows remote attackers to cause a denial of service via a crafted imagefilltoborder call.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2015-8874

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The file_check_mem function in funcs.c in file before 5.23, as used in the Fileinfo component in PHP before 5.5.34, 5.6.x before 5.6.20, and 7.x before 7.0.5, mishandles continuation-level jumps, which allows context-dependent attackers to cause a denial of service (buffer overflow and application crash) or possibly execute arbitrary code via a crafted magic file.

CVSS

CVSS:3.0/AV:L/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:H

External References

- CVE-2015-8865

PHP Improper Input Validation Vulnerability

Stack consumption vulnerability in Zend/zend_exceptions.c in PHP before 5.4.44, 5.5.x before 5.5.28, and 5.6.x before 5.6.12 allows remote attackers to cause a denial of service (segmentation fault) via recursive method calls.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2015-8873

PHP Improper Input Validation Vulnerability

The odbc_bindcols function in ext/odbc/php_odbc.c in PHP before 5.6.12 mishandles driver behavior for SQL_WVARCHAR columns, which allows remote attackers to cause a denial of service (application crash) in opportunistic circumstances by leveraging use of the odbc_fetch_array function to access a certain type of Microsoft SQL Server table.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2015-8879

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Stack-based buffer overflow in the phar_fix_filepath function in ext/phar/phar.c in PHP before 5.4.43, 5.5.x before 5.5.27, and 5.6.x before 5.6.11 allows remote attackers to cause a denial of service or possibly have unspecified other impact via a large length value, as demonstrated by mishandling of an e-mail attachment by the imap PHP extension.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

External References

- CVE-2015-5590

PHP Other Vulnerability

file before 5.18, as used in the Fileinfo component in PHP before 5.6.0, allows remote attackers to cause a denial of service (NULL pointer dereference and application crash) via a zero root_storage value in a CDF file, related to cdf.c and readcdf.c.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2014-0236

PHP Other Vulnerability

The SoapClient __call method in ext/soap/soap.c in PHP before 5.4.45, 5.5.x before 5.5.29, and 5.6.x before 5.6.13 does not properly manage headers, which allows remote attackers to execute arbitrary code via crafted serialized data that triggers a "type confusion" in the serialize_function_call function.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

External References

- CVE-2015-6836

PHP Other Vulnerability

Use-after-free vulnerability in the SPL unserialize implementation in ext/spl/spl_array.c in PHP before 5.4.44, 5.5.x before 5.5.28, and 5.6.x before 5.6.12 allows remote attackers to execute arbitrary code via crafted serialized data that triggers misuse of an array field.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

External References

- CVE-2015-6832

PHP Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') Vulnerability

Directory traversal vulnerability in the PharData class in PHP before 5.4.44, 5.5.x before 5.5.28, and 5.6.x before 5.6.12 allows remote attackers to write to arbitrary files via a .. (dot dot) in a ZIP archive entry that is mishandled during an extractTo call.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

External References

- CVE-2015-6833

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The phar_parse_metadata function in ext/phar/phar.c in PHP before 5.4.40, 5.5.x before 5.5.24, and 5.6.x before 5.6.8 allows remote attackers to cause a denial of service (heap metadata corruption) or possibly have unspecified other impact via a crafted tar archive.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2015-3307

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Multiple stack-based buffer overflows in the phar_set_inode function in phar_internal.h in PHP before 5.4.40, 5.5.x before 5.5.24, and 5.6.x before 5.6.8 allow remote attackers to execute arbitrary code via a crafted length value in a (1) tar, (2) phar, or (3) ZIP archive.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2015-3329

PHP Data Processing Errors Vulnerability

The pcntl_exec implementation in PHP before 5.4.41, 5.5.x before 5.5.25, and 5.6.x before 5.6.9 truncates a pathname upon encountering a \x00 character, which might allow remote attackers to bypass intended extension restrictions and execute files with unexpected names via a crafted first argument. NOTE: this vulnerability exists because of an incomplete fix for CVE-2006-7243.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2015-4026

PHP Data Processing Errors Vulnerability

The SoapClient::__call method in ext/soap/soap.c in PHP before 5.4.39, 5.5.x before 5.5.23, and 5.6.x before 5.6.7 does not verify that __default_headers is an array, which allows remote attackers to execute arbitrary code by providing crafted serialized data with an unexpected data type, related to a "type confusion" issue.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2015-4147

PHP Numeric Errors Vulnerability

Integer overflow in the ftp_genlist function in ext/ftp/ftp.c in PHP before 5.4.41, 5.5.x before 5.5.25, and 5.6.x before 5.6.9 allows remote FTP servers to execute arbitrary code via a long reply to a LIST command, leading to a heap-based buffer overflow.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2015-4022

PHP Data Processing Errors Vulnerability

PHP before 5.4.41, 5.5.x before 5.5.25, and 5.6.x before 5.6.9 truncates a pathname upon encountering a \x00 character in certain situations, which allows remote attackers to bypass intended extension restrictions and access files or directories with unexpected names via a crafted argument to (1) set_include_path, (2) tempnam, (3) rmdir, or (4) readlink. NOTE: this vulnerability exists because of an incomplete fix for CVE-2006-7243.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2015-4025

PHP Other Vulnerability

The php_pgsql_meta_data function in pgsql.c in the PostgreSQL (aka pgsql) extension in PHP before 5.4.42, 5.5.x before 5.5.26, and 5.6.x before 5.6.10 does not validate token extraction for table names, which might allow remote attackers to cause a denial of service

(NULL pointer dereference and application crash) via a crafted name. NOTE: this vulnerability exists because of an incomplete fix for CVE-2015-1352.

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2015-4644

PHP Other Vulnerability

The xsl_ext_function_php function in ext/xsl/xsltprocessor.c in PHP before 5.4.45, 5.5.x before 5.5.29, and 5.6.x before 5.6.13, when libxml2 before 2.9.2 is used, does not consider the possibility of a NULL valuePop return value before proceeding with a free operation after the principal argument loop, which allows remote attackers to cause a denial of service (NULL pointer dereference and application crash) via a crafted XML document, a different vulnerability than CVE-2015-6837.

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2015-6838

PHP Other Vulnerability

The xsl_ext_function_php function in ext/xsl/xsltprocessor.c in PHP before 5.4.45, 5.5.x before 5.5.29, and 5.6.x before 5.6.13, when libxml2 before 2.9.2 is used, does not consider the possibility of a NULL valuePop return value before proceeding with a free operation during initial error checking, which allows remote attackers to cause a denial of service (NULL pointer dereference and application crash) via a crafted XML document, a different vulnerability than CVE-2015-6838.

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2015-6837

PHP Improper Input Validation Vulnerability

The mcopy function in softmagic.c in file 5.x, as used in the Fileinfo component in PHP before 5.4.40, 5.5.x before 5.5.24, and 5.6.x before 5.6.8, does not properly restrict a certain offset value, which allows remote attackers to cause a denial of service (application crash) or possibly execute arbitrary code via a crafted string that is mishandled by a "Python script text executable" rule.

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2015-4605

PHP Improper Input Validation Vulnerability

The mget function in softmagic.c in file 5.x, as used in the Fileinfo component in PHP before 5.4.40, 5.5.x before 5.5.24, and 5.6.x before 5.6.8, does not properly maintain a certain pointer relationship, which allows remote attackers to cause a denial of service (application crash) or possibly execute arbitrary code via a crafted string that is mishandled by a "Python script text executable" rule.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2015-4604

PHP Cryptographic Issues Vulnerability

The crypt_des (aka DES-based crypt) function in FreeBSD before 9.0-RELEASE-p2, as used in PHP, PostgreSQL, and other products, does not process the complete cleartext password if this password contains a 0x80 character, which makes it easier for context-dependent attackers to obtain access via an authentication attempt with an initial substring of the intended password, as demonstrated by a Unicode password.

CVSS

AV:N/AC:M/Au:N/C:N/I:P/A:N

External References

- CVE-2012-2143

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The cdf_read_property_info function in cdf.c in the Fileinfo component in PHP before 5.4.29 and 5.5.x before 5.5.13 allows remote attackers to cause a denial of service (infinite loop or out-of-bounds memory access) via a vector that (1) has zero length or (2) is too long.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2014-0238

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The scan function in ext/date/lib/parse_iso_intervals.c in PHP through 5.5.6 does not properly restrict creation of DateInterval objects, which might allow remote attackers to cause a denial of service (heap-based buffer over-read) via a crafted interval specification.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2013-6712

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

softmagic.c in file before 5.17 and libmagic allows context-dependent attackers to cause a denial of service (out-of-bounds memory access and crash) via crafted offsets in the softmagic of a PE executable.

CVSS

AV:N/AC:M/Au:N/C:N/I:N/A:P

External References

- CVE-2014-2270

PHP CVE-2014-3479 Vulnerability

The cdf_check_stream_offset function in cdf.c in file before 5.19, as used in the Fileinfo component in PHP before 5.4.30 and 5.5.x before 5.5.14, relies on incorrect sector-size data, which allows remote attackers to cause a denial of service (application crash) via a crafted stream offset in a CDF file.

CVSS
AV:N/AC:M/Au:N/C:N/I:N/A:P

External References
- CVE-2014-3479

PHP Improper Restriction of XML External Entity Reference Vulnerability

The SOAP parser in PHP before 5.3.22 and 5.4.x before 5.4.12 allows remote attackers to read arbitrary files via a SOAP WSDL file containing an XML external entity declaration in conjunction with an entity reference, related to an XML External Entity (XXE) issue in the soap_xmlParseFile and soap_xmlParseMemory functions.

CVSS
AV:N/AC:M/Au:N/C:P/I:N/A:N

External References
- CVE-2013-1824

PHP Improper Input Validation Vulnerability

CVE-2010-3870 php: XSS mitigation bypass via utf8_decode()

CVSS
AV:N/AC:M/Au:N/C:P/I:P/A:P

External References
- CVE-2010-3870

PHP Improper Input Validation Vulnerability

CVE-2010-3709 php: NULL pointer dereference in ZipArchive::getArchiveComment

CVSS
AV:N/AC:M/Au:N/C:N/I:N/A:P

External References
- CVE-2010-3709

PHP Improper Input Validation Vulnerability

CVE-2012-2336 php: incomplete CVE-2012-1823 fix - missing filtering of -T and -h

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2012-2336

PHP Improper Input Validation Vulnerability

CVE-2012-2336 php: incomplete CVE-2012-1823 fix - missing filtering of -T and -h

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2012-2336

PHP Numeric Errors Vulnerability

Integer signedness error in zip_stream.c in the Zip extension in PHP before 5.3.6 allows context-dependent attackers to cause a denial of service (CPU consumption) via a malformed archive file that triggers errors in zip_fread function calls.

CVSS
AV:N/AC:M/Au:N/C:N/I:N/A:P

External References
- CVE-2011-1471

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

The var_export function in PHP 5.2 before 5.2.14 and 5.3 before 5.3.3 flushes the output buffer to the user when certain fatal errors occur, even if display_errors is off, which allows remote attackers to obtain sensitive information by causing the application to exceed limits for memory, execution time, or recursion.

CVSS
AV:N/AC:M/Au:N/C:P/I:N/A:N

External References
- CVE-2010-2531

PHP Improper Input Validation Vulnerability

The exif_read_data function in the Exif module in PHP before 5.2.10 allows remote attackers to cause a denial of service (crash) via a malformed JPEG image with invalid offset fields, a different issue than CVE-2005-3353.

CVSS
AV:N/AC:M/Au:N/C:N/I:N/A:P

External References
- CVE-2009-2687

PHP Resource Management Errors Vulnerability

The cdf_unpack_summary_info function in cdf.c in the Fileinfo component in PHP before 5.4.29 and 5.5.x before 5.5.13 allows remote attackers to cause a denial of service (performance degradation) by triggering many file_printf calls.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2014-0237

PHP Loop with Unreachable Exit Condition ('Infinite Loop') Vulnerability

In PHP versions before 7.4.31, 8.0.24 and 8.1.11, the phar uncompressor code would recursively uncompress "quines" gzip files, resulting in an infinite loop.

CVSS
CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

External References
- CVE-2022-31628

PHP CVE-2022-31629 Vulnerability

In PHP versions before 7.4.31, 8.0.24 and 8.1.11, the vulnerability enables network and same-site attackers to set a standard insecure cookie in the victim's browser which is treated as a `__Host-` or `__Secure-` cookie by PHP applications.

CVSS
CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:N

External References
- CVE-2022-31629

PHP Incorrect Conversion between Numeric Types Vulnerability

gd_gif_in.c in the GD Graphics Library (aka libgd), as used in PHP before 5.6.33, 7.0.x before 7.0.27, 7.1.x before 7.1.13, and 7.2.x before 7.2.1, has an integer signedness error that leads to an infinite loop via a crafted GIF file, as demonstrated by a call to the imagecreatefromgif or imagecreatefromstring PHP function. This is related to GetCode_ and gdImageCreateFromGifCtx.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

External References
- CVE-2018-5711

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

The GIF decoding function gdImageCreateFromGifCtx in gd_gif_in.c in the GD Graphics Library (aka libgd), as used in PHP before 5.6.31 and 7.x before 7.1.7, does not zero colorMap arrays before use. A specially crafted GIF image could use the uninitialized tables to read ~700 bytes from the top of the stack, potentially disclosing sensitive information.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N

External References
- CVE-2017-7890

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

The exif_process_IFD_in_TIFF function in ext/exif/exif.c in PHP before 5.6.25 and 7.x before 7.0.10 mishandles the case of a thumbnail offset that exceeds the file size, which allows remote attackers to obtain sensitive information from process memory via a crafted TIFF

image.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

External References
- CVE-2016-7128

PHP Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

An issue was discovered in PHP before 5.6.33, 7.0.x before 7.0.27, 7.1.x before 7.1.13, and 7.2.x before 7.2.1. There is Reflected XSS on the PHAR 404 error page via the URI of a request for a .phar file.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

External References
- CVE-2018-5712

PHP Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

An issue was discovered in ext/phar/phar_object.c in PHP before 5.6.36, 7.0.x before 7.0.30, 7.1.x before 7.1.17, and 7.2.x before 7.2.5. There is Reflected XSS on the PHAR 403 and 404 error pages via request data of a request for a .phar file. NOTE: this vulnerability exists because of an incomplete fix for CVE-2018-5712.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

External References
- CVE-2018-10547

PHP Out-of-bounds Read Vulnerability

exif_process_IFD_in_MAKERNOTE in ext/exif/exif.c in PHP before 5.6.37, 7.0.x before 7.0.31, 7.1.x before 7.1.20, and 7.2.x before 7.2.8 allows remote attackers to cause a denial of service (out-of-bounds read and application crash) via a crafted JPEG file.

Affected Versions
0.2.0 to

CVSS
CVSS:3.0/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

External References

- CVE-2018-14851

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

An issue was discovered in PHP before 5.6.35, 7.0.x before 7.0.29, 7.1.x before 7.1.16, and 7.2.x before 7.2.4. Dumpable FPM child processes allow bypassing opcache access controls because fpm_unix.c makes a PR_SET_DUMPABLE prctl call, allowing one user (in a multiuser environment) to obtain sensitive information from the process memory of a second user's PHP applications by running gcore on the PID of the PHP-FPM worker process.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N

External References

- CVE-2018-10545

PHP Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

The Apache2 component in PHP before 5.6.38, 7.0.x before 7.0.32, 7.1.x before 7.1.22, and 7.2.x before 7.2.10 allows XSS via the body of a "Transfer-Encoding: chunked" request, because the bucket brigade is mishandled in the php_handler function in sapi/apache2handler/sapi_apache2.c.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

External References

- CVE-2018-17082

PHP NULL Pointer Dereference Vulnerability

The exif_process_user_comment function in ext/exif/exif.c in PHP before 5.5.38, 5.6.x before 5.6.24, and 7.x before 7.0.9 allows remote attackers to cause a denial of service (NULL pointer dereference and application crash) via a crafted JPEG image.

Affected Versions

0.2.0 to

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

External References

- CVE-2016-6292

PHP Permissions, Privileges, and Access Controls Vulnerability

session.c in the session extension in PHP before 5.2.13, and 5.3.1, does not properly interpret ; (semicolon) characters in the argument to the session_save_path function, which allows context-dependent attackers to bypass open_basedir and safe_mode restrictions via an argument that contains multiple ; characters in conjunction with a .. (dot dot).

CVSS

AV:N/AC:L/Au:N/C:N/I:P/A:N

External References

- CVE-2010-1130

PHP Cryptographic Issues Vulnerability

The Linear Congruential Generator (LCG) in PHP before 5.2.13 does not provide the expected entropy, which makes it easier for context-dependent attackers to guess values that were intended to be unpredictable, as demonstrated by session cookies generated by using the uniqid function.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:N

External References

- CVE-2010-1128

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

The html_entity_decode function in PHP 5.2 through 5.2.13 and 5.3 through 5.3.2 allows context-dependent attackers to obtain sensitive information (memory contents) or trigger memory corruption by causing a userspace interruption of an internal call, related to the call time pass by reference feature.

CVSS

AV:N/AC:L/Au:N/C:P/I:N/A:N

External References

- CVE-2010-1860

PHP Permissions, Privileges, and Access Controls Vulnerability

session.c in the session extension in PHP before 5.2.13, and 5.3.1, does not properly interpret ; (semicolon) characters in the argument to the session_save_path function, which allows context-dependent attackers to bypass open_basedir and safe_mode restrictions via an argument that contains multiple ; characters in conjunction with a .. (dot dot).

CVSS

AV:N/AC:L/Au:N/C:N/I:P/A:N

External References

- CVE-2010-1130

PHP Cryptographic Issues Vulnerability

The Linear Congruential Generator (LCG) in PHP before 5.2.13 does not provide the expected entropy, which makes it easier for context-dependent attackers to guess values that were intended to be unpredictable, as demonstrated by session cookies generated by using the uniqid function.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:N

External References

- CVE-2010-1128

PHP Numeric Errors Vulnerability

The unserialize function in PHP 5.3.0 and earlier allows context-dependent attackers to cause a denial of service (resource consumption) via a deeply nested serialized variable, as demonstrated by a string beginning with a:1: followed by many {a:1: sequences.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2009-4418

PHP Numeric Errors Vulnerability

The unserialize function in PHP 5.3.0 and earlier allows context-dependent attackers to cause a denial of service (resource consumption) via a deeply nested serialized variable, as demonstrated by a string beginning with a:1: followed by many {a:1: sequences.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2009-4418

PHP Resource Management Errors Vulnerability

The sysvshm extension for PHP 5.2 through 5.2.13 and 5.3 through 5.3.2 allows context-dependent attackers to write to arbitrary memory addresses by using an object's __sleep function to interrupt an internal call to the shm_put_var function, which triggers access of a freed resource.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:N

External References
- CVE-2010-1861

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

The chunk_split function in PHP 5.2 through 5.2.13 and 5.3 through 5.3.2 allows context-dependent attackers to obtain sensitive information (memory contents) by causing a userspace interruption of an internal function, related to the call time pass by reference feature.

CVSS
AV:N/AC:L/Au:N/C:P/I:N/A:N

External References
- CVE-2010-1862

PHP Numeric Errors Vulnerability

Integer overflow in the NumberFormatter::getSymbol (aka numfmt_get_symbol) function in PHP 5.3.3 and earlier allows context-dependent attackers to cause a denial of service (application crash) via an invalid argument.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2010-4409

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

The (1) iconv_mime_decode, (2) iconv_substr, and (3) iconv_mime_encode functions in PHP 5.2 through 5.2.13 and 5.3 through 5.3.2 allow context-dependent attackers to obtain sensitive information (memory contents) by causing a userspace interruption of an internal function, related to the call time pass by reference feature.

CVSS

AV:N/AC:L/Au:N/C:P/I:N/A:N

External References

- CVE-2010-2097

PHP Resource Management Errors Vulnerability

Use-after-free vulnerability in the request shutdown functionality in PHP 5.2 before 5.2.13 and 5.3 before 5.3.2 allows context-dependent attackers to cause a denial of service (crash) via a stream context structure that is freed before destruction occurs.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2010-2093

PHP Resource Management Errors Vulnerability

Stack consumption vulnerability in PHP 5.2 through 5.2.13 and 5.3 through 5.3.2 allows context-dependent attackers to cause a denial of service (PHP crash) via a crafted first argument to the fnmatch function, as demonstrated using a long string.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2010-1917

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

The preg_quote function in PHP 5.2 through 5.2.13 and 5.3 through 5.3.2 allows context-dependent attackers to obtain sensitive information (memory contents) by causing a userspace interruption of an internal function, related to the call time pass by reference feature, modification of ZVALs whose values are not updated in the associated local variables, and access of previously-freed memory.

CVSS

AV:N/AC:L/Au:N/C:P/I:N/A:N

External References

- CVE-2010-1915

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

The Zend Engine in PHP 5.2 through 5.2.13 and 5.3 through 5.3.2 allows context-dependent attackers to obtain sensitive information by interrupting the handler for the (1) ZEND_BW_XOR opcode (shift_left_function), (2) ZEND_SL opcode (bitwise_xor_function), or (3) ZEND_SR opcode (shift_right_function), related to the convert_to_long_base function.

CVSS
AV:N/AC:L/Au:N/C:P/I:N/A:N

External References
- CVE-2010-1914

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

The addcslashes function in PHP 5.2 through 5.2.13 and 5.3 through 5.3.2 allows context-dependent attackers to obtain sensitive information (memory contents) by causing a userspace interruption of an internal function, related to the call time pass by reference feature.

CVSS
AV:N/AC:L/Au:N/C:P/I:N/A:N

External References
- CVE-2010-1864

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

The (1) htmlentities, (2) htmlspecialchars, (3) str_getcsv, (4) http_build_query, (5) strpbrk, and (6) strtr functions in PHP 5.2 through 5.2.13 and 5.3 through 5.3.2 allow context-dependent attackers to obtain sensitive information (memory contents) by causing a userspace interruption of an internal function, related to the call time pass by reference feature.

CVSS
AV:N/AC:L/Au:N/C:P/I:N/A:N

External References
- CVE-2010-2100

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

The (1) strip_tags, (2) setcookie, (3) strtok, (4) wordwrap, (5) str_word_count, and (6) str_pad functions in PHP 5.2 through 5.2.13 and 5.3 through 5.3.2 allow context-dependent attackers to obtain sensitive information (memory contents) by causing a userspace interruption of an internal function, related to the call time pass by reference feature.

CVSS
AV:N/AC:L/Au:N/C:P/I:N/A:N

External References
- CVE-2010-2101

PHP Numeric Errors Vulnerability

Integer overflow in the xml_utf8_decode function in ext/xml/xml.c in PHP before 5.2.11 makes it easier for remote attackers to bypass cross-site scripting (XSS) and SQL injection protection mechanisms via a crafted string that uses overlong UTF-8 encoding, a different vulnerability than CVE-2010-3870.

CVSS
AV:N/AC:M/Au:N/C:P/I:P/A:P

External References
- CVE-2009-5016

PHP Resource Management Errors Vulnerability

Stack consumption vulnerability in the filter_var function in PHP 5.2.x through 5.2.14 and 5.3.x through 5.3.3, when FILTER_VALIDATE_EMAIL mode is used, allows remote attackers to cause a denial of service (memory consumption and application crash) via a long e-mail address string.

CVSS

AV:N/AC:M/Au:N/C:N/I:N/A:P

External References

- CVE-2010-3710

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

The strrchr function in PHP 5.2 before 5.2.14 allows context-dependent attackers to obtain sensitive information (memory contents) or trigger memory corruption by causing a userspace interruption of an internal function or handler.

CVSS

AV:N/AC:L/Au:N/C:P/I:N/A:N

External References

- CVE-2010-2484

PHP Permissions, Privileges, and Access Controls Vulnerability

The default session serializer in PHP 5.2 through 5.2.13 and 5.3 through 5.3.2 does not properly handle the PS_UNDEF_MARKER marker, which allows context-dependent attackers to modify arbitrary session variables via a crafted session variable name.

CVSS

AV:N/AC:L/Au:N/C:N/I:P/A:N

External References

- CVE-2010-3065

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The (1) parse_str, (2) preg_match, (3) unpack, and (4) pack functions; the (5) ZEND_FETCH_RW, (6) ZEND_CONCAT, and (7) ZEND_ASSIGN_CONCAT opcodes; and the (8) ArrayObject::uasort method in PHP 5.2 through 5.2.13 and 5.3 through 5.3.2 allow context-dependent attackers to obtain sensitive information (memory contents) or trigger memory corruption by causing a userspace interruption of an internal function or handler. NOTE: vectors 2 through 4 are related to the call time pass by reference feature.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:N

External References

- CVE-2010-2191

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

The (1) trim, (2) ltrim, (3) rtrim, and (4) substr_replace functions in PHP 5.2 through 5.2.13 and 5.3 through 5.3.2 allow context-dependent attackers to obtain sensitive information (memory contents) by causing a userspace interruption of an internal function, related to the call time pass by reference feature.

CVSS

AV:N/AC:L/Au:N/C:P/I:N/A:N

External References

- CVE-2010-2190

PHP Permissions, Privileges, and Access Controls Vulnerability

The posix_mkfifo function in ext/posix/posix.c in PHP before 5.2.12 and 5.3.x before 5.3.1 allows context-dependent attackers to bypass open_basedir restrictions, and create FIFO files, via the pathname and mode arguments, as demonstrated by creating a .htaccess file.

CVSS

AV:N/AC:M/Au:N/C:P/I:P/A:P

External References

- CVE-2009-3558

PHP Permissions, Privileges, and Access Controls Vulnerability

The tempnam function in ext/standard/file.c in PHP before 5.2.12 and 5.3.x before 5.3.1 allows context-dependent attackers to bypass safe_mode restrictions, and create files in group-writable or world-writable directories, via the dir and prefix arguments.

CVSS

AV:N/AC:L/Au:N/C:N/I:P/A:N

External References

- CVE-2009-3557

PHP Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

The htmlspecialchars function in PHP before 5.2.12 does not properly handle (1) overlong UTF-8 sequences, (2) invalid Shift_JIS sequences, and (3) invalid EUC-JP sequences, which allows remote attackers to conduct cross-site scripting (XSS) attacks by placing a crafted byte sequence before a special character.

CVSS

AV:N/AC:M/Au:N/C:N/I:P/A:N

External References

- CVE-2009-4142

PHP Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

The htmlspecialchars function in PHP before 5.2.12 does not properly handle (1) overlong UTF-8 sequences, (2) invalid Shift_JIS sequences, and (3) invalid EUC-JP sequences, which allows remote attackers to conduct cross-site scripting (XSS) attacks by placing a crafted byte sequence before a special character.

CVSS

AV:N/AC:M/Au:N/C:N/I:P/A:N

External References

- CVE-2009-4142

PHP Other Vulnerability

The zend_restore_ini_entry_cb function in zend_ini.c in PHP 5.3.0, 5.2.10, and earlier versions allows context-specific attackers to obtain sensitive information (memory contents) and cause a PHP crash by using the ini_set function to declare a variable, then using the

ini_restore function to restore the variable.

CVSS
AV:N/AC:L/Au:N/C:P/I:N/A:P

External References
- CVE-2009-2626

PHP Other Vulnerability

The zend_restore_ini_entry_cb function in zend_ini.c in PHP 5.3.0, 5.2.10, and earlier versions allows context-specific attackers to obtain sensitive information (memory contents) and cause a PHP crash by using the ini_set function to declare a variable, then using the ini_restore function to restore the variable.

CVSS
AV:N/AC:L/Au:N/C:P/I:N/A:P

External References
- CVE-2009-2626

PHP Numeric Errors Vulnerability

Integer overflow in the mt_rand function in PHP before 5.3.4 might make it easier for context-dependent attackers to predict the return values by leveraging a script's use of a large max parameter, as demonstrated by a value that exceeds mt_getrandmax.

CVSS
AV:N/AC:L/Au:N/C:N/I:P/A:N

External References
- CVE-2011-0755

PHP Numeric Errors Vulnerability

Integer overflow in the mt_rand function in PHP before 5.3.4 might make it easier for context-dependent attackers to predict the return values by leveraging a script's use of a large max parameter, as demonstrated by a value that exceeds mt_getrandmax.

CVSS
AV:N/AC:L/Au:N/C:N/I:P/A:N

External References
- CVE-2011-0755

PHP Other Vulnerability

The _zip_name_locate function in zip_name_locate.c in the Zip extension in PHP before 5.3.6 does not properly handle a ZIPARCHIVE::FL_UNCHANGED argument, which might allow context-dependent attackers to cause a denial of service (NULL pointer dereference) via an empty ZIP archive that is processed with a (1) locateName or (2) statName operation.

CVSS
AV:N/AC:M/Au:N/C:N/I:N/A:P

External References
- CVE-2011-0421

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

exif.c in the Exif extension in PHP before 5.3.6 on 64-bit platforms performs an incorrect cast, which allows remote attackers to cause a denial of service (application crash) via an image with a crafted Image File Directory (IFD) that triggers a buffer over-read.

CVSS

AV:N/AC:M/Au:N/C:N/I:N/A:P

External References

- CVE-2011-0708

PHP Other Vulnerability

The _zip_name_locate function in zip_name_locate.c in the Zip extension in PHP before 5.3.6 does not properly handle a ZIPARCHIVE::FL_UNCHANGED argument, which might allow context-dependent attackers to cause a denial of service (NULL pointer dereference) via an empty ZIP archive that is processed with a (1) locateName or (2) statName operation.

CVSS

AV:N/AC:M/Au:N/C:N/I:N/A:P

External References

- CVE-2011-0421

PHP Resource Management Errors Vulnerability

Use-after-free vulnerability in the Zend engine in PHP before 5.2.15 and 5.3.x before 5.3.4 might allow context-dependent attackers to cause a denial of service (heap memory corruption) or have unspecified other impact via vectors related to use of __set, __get, __isset, and __unset methods on objects accessed by a reference.

CVSS

AV:N/AC:M/Au:N/C:P/I:P/A:P

External References

- CVE-2010-4697

PHP Numeric Errors Vulnerability

The iconv_mime_decode_headers function in the Iconv extension in PHP before 5.3.4 does not properly handle encodings that are unrecognized by the iconv and mbstring (aka Multibyte String) implementations, which allows remote attackers to trigger an incomplete output array, and possibly bypass spam detection or have unspecified other impact, via a crafted Subject header in an e-mail message, as demonstrated by the ks_c_5601-1987 character set.

CVSS

AV:N/AC:L/Au:N/C:N/I:P/A:N

External References

- CVE-2010-4699

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Stack-based buffer overflow in the GD extension in PHP before 5.2.15 and 5.3.x before 5.3.4 allows context-dependent attackers to cause a denial of service (application crash) via a large number of anti-aliasing steps in an argument to the imagepstext function.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2010-4698

PHP Resource Management Errors Vulnerability

Use-after-free vulnerability in the Zend engine in PHP before 5.2.15 and 5.3.x before 5.3.4 might allow context-dependent attackers to cause a denial of service (heap memory corruption) or have unspecified other impact via vectors related to use of __set, __get, __isset, and __unset methods on objects accessed by a reference.

CVSS

AV:N/AC:M/Au:N/C:P/I:P/A:P

External References

- CVE-2010-4697

PHP Improper Input Validation Vulnerability

PHP before 5.3.4 accepts the \0 character in a pathname, which might allow context-dependent attackers to bypass intended access restrictions by placing a safe file extension after this character, as demonstrated by .php\0.jpg at the end of the argument to the file_exists function.

CVSS

AV:N/AC:L/Au:N/C:N/I:P/A:N

External References

- CVE-2006-7243

PHP Numeric Errors Vulnerability

strtod.c, as used in the zend_strtod function in PHP 5.2 before 5.2.17 and 5.3 before 5.3.5, and other products, allows context-dependent attackers to cause a denial of service (infinite loop) via a certain floating-point value in scientific notation, which is not properly handled in x87 FPU registers, as demonstrated using 2.2250738585072011e-308.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2010-4645

PHP Resource Management Errors Vulnerability

Double free vulnerability in the imap_do_open function in the IMAP extension (ext/imap/php_imap.c) in PHP 5.2 before 5.2.15 and 5.3 before 5.3.4 allows attackers to cause a denial of service (memory corruption) or possibly execute arbitrary code via unspecified vectors.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2010-4150

PHP Improper Input Validation Vulnerability

PHP before 5.3.4 accepts the \0 character in a pathname, which might allow context-dependent attackers to bypass intended access restrictions by placing a safe file extension after this character, as demonstrated by .php\0.jpg at the end of the argument to the file_exists function.

CVSS
AV:N/AC:L/Au:N/C:N/I:P/A:N

External References
- CVE-2006-7243

PHP Improper Link Resolution Before File Access ('Link Following') Vulnerability

The SplFileInfo::getType function in the Standard PHP Library (SPL) extension in PHP before 5.3.4 on Windows does not properly detect symbolic links, which might make it easier for local users to conduct symlink attacks by leveraging cross-platform differences in the stat structure, related to lack of a FILE_ATTRIBUTE_REPARSE_POINT check.

CVSS
AV:L/AC:M/Au:N/C:P/I:P/A:P

External References
- CVE-2011-0754

PHP Concurrent Execution using Shared Resource with Improper Synchronization ('Race Condition') Vulnerability

Race condition in the PCNTL extension in PHP before 5.3.4, when a user-defined signal handler exists, might allow context-dependent attackers to cause a denial of service (memory corruption) via a large number of concurrent signals.

CVSS
AV:N/AC:M/Au:N/C:N/I:N/A:P

External References
- CVE-2011-0753

PHP Improper Input Validation Vulnerability

The extract function in PHP before 5.2.15 does not prevent use of the EXTR_OVERWRITE parameter to overwrite (1) the GLOBALS superglobal array and (2) the this variable, which allows context-dependent attackers to bypass intended access restrictions by modifying data structures that were not intended to depend on external input, a related issue to CVE-2005-2691 and CVE-2006-3758.

CVSS
AV:N/AC:L/Au:N/C:N/I:P/A:N

External References
- CVE-2011-0752

PHP Numeric Errors Vulnerability

The iconv_mime_decode_headers function in the Iconv extension in PHP before 5.3.4 does not properly handle encodings that are unrecognized by the iconv and mbstring (aka Multibyte String) implementations, which allows remote attackers to trigger an incomplete output array, and possibly bypass spam detection or have unspecified other impact, via a crafted Subject header in an e-mail message, as demonstrated by the ks_c_5601-1987 character set.

CVSS
AV:N/AC:L/Au:N/C:N/I:P/A:N

External References

- CVE-2010-4699

PHP Improper Input Validation Vulnerability

The extract function in PHP before 5.2.15 does not prevent use of the EXTR_OVERWRITE parameter to overwrite (1) the GLOBALS superglobal array and (2) the this variable, which allows context-dependent attackers to bypass intended access restrictions by modifying data structures that were not intended to depend on external input, a related issue to CVE-2005-2691 and CVE-2006-3758.

CVSS

AV:N/AC:L/Au:N/C:N/I:P/A:N

External References

- CVE-2011-0752

PHP Other Vulnerability

The MySQL extension in PHP 5.2.4 and earlier allows remote attackers to bypass safe_mode and open_basedir restrictions via the MySQL (1) LOAD_FILE, (2) INTO DUMPFILE, and (3) INTO OUTFILE functions, a different issue than CVE-2007-3997.

CVSS

AV:N/AC:M/Au:N/C:P/I:P/A:P

External References

- CVE-2007-4889

PHP Permissions, Privileges, and Access Controls Vulnerability

ioncube_loader_win_5.2.dll in the ionCube Loader 6.5 extension for PHP 5.2.4 does not follow safe_mode and disable_functions restrictions, which allows context-dependent attackers to bypass intended limitations, as demonstrated by reading arbitrary files via the ioncube_read_file function.

CVSS

AV:N/AC:M/Au:N/C:P/I:N/A:N

External References

- CVE-2007-5447

PHP Improper Input Validation Vulnerability

PHP 5.2.4 and earlier allows context-dependent attackers to cause a denial of service (application crash) via (1) a long string in the out_charset parameter to the iconv function; or a long string in the charset parameter to the (2) iconv_mime_decode_headers, (3) iconv_mime_decode, or (4) iconv_strlen function. NOTE: this might not be a vulnerability in most web server environments that support multiple threads, unless these issues can be demonstrated for code execution.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2007-4840

PHP Improper Input Validation Vulnerability

The dl function in PHP 5.2.4 and earlier allows context-dependent attackers to cause a denial of service (application crash) via a long string in the library parameter. NOTE: there are limited usage scenarios under which this would be a vulnerability.

CVSS
AV:N/AC:M/Au:N/C:N/I:N/A:P

External References
- CVE-2007-4887

PHP Permissions, Privileges, and Access Controls Vulnerability

PHP before 5.2.5 allows local users to bypass protection mechanisms configured through php_admin_value or php_admin_flag in httpd.conf by using ini_set to modify arbitrary configuration variables, a different issue than CVE-2006-4625.

CVSS
AV:L/AC:M/Au:N/C:C/I:C/A:C

External References
- CVE-2007-5900

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

The output_add_rewrite_var function in PHP before 5.2.5 rewrites local forms in which the ACTION attribute references a non-local URL, which allows remote attackers to obtain potentially sensitive information by reading the requests for this URL, as demonstrated by a rewritten form containing a local session ID.

CVSS
AV:N/AC:M/Au:N/C:P/I:N/A:N

External References
- CVE-2007-5899

PHP Numeric Errors Vulnerability

Integer overflow in PHP 5.2.5 and earlier allows context-dependent attackers to cause a denial of service and possibly have unspecified other impact via a printf format parameter with a large width specifier, related to the php_sprintf_appendstring function in formatted_print.c and probably other functions for formatted strings (aka *printf functions).

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2008-1384

PHP Permissions, Privileges, and Access Controls Vulnerability

curl/interface.c in the cURL library (aka libcurl) in PHP 5.2.4 and 5.2.5 allows context-dependent attackers to bypass safe_mode and open_basedir restrictions and read arbitrary files via a file:// request containing a \x00 sequence, a different vulnerability than CVE-2006-2563.

CVSS
AV:N/AC:L/Au:N/C:P/I:N/A:N

External References
- CVE-2007-4850

PHP CVE-2007-5898 Vulnerability

The (1) htmlentities and (2) htmlspecialchars functions in PHP before 5.2.5 accept partial multibyte sequences, which has unknown impact and attack vectors, a different issue than CVE-2006-5465.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:N

External References
- CVE-2007-5898

PHP Improper Input Validation Vulnerability

The iconv_substr function in PHP 5.2.4 and earlier allows context-dependent attackers to cause (1) a denial of service (application crash) via a long string in the charset parameter, probably also requiring a long string in the str parameter; or (2) a denial of service (temporary application hang) via a long string in the str parameter. NOTE: this might not be a vulnerability in most web server environments that support multiple threads, unless these issues can be demonstrated for code execution.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2007-4783

PHP Improper Input Validation Vulnerability

The php_zip_make_relative_path function in php_zip.c in PHP 5.2.x before 5.2.9 allows context-dependent attackers to cause a denial of service (crash) via a ZIP file that contains filenames with relative paths, which is not properly handled during extraction.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2009-1272

PHP Other Vulnerability

The JSON_parser function (ext/json/JSON_parser.c) in PHP 5.2.x before 5.2.9 allows remote attackers to cause a denial of service (segmentation fault) via a malformed string to the json_decode API function.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2009-1271

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

Array index error in the imageRotate function in PHP 5.2.8 and earlier allows context-dependent attackers to read the contents of arbitrary memory locations via a crafted value of the third argument (aka the bgd_color or clrBack argument) for an indexed image.

CVSS
AV:N/AC:L/Au:N/C:P/I:N/A:N

External References
- CVE-2008-5498

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

Array index error in the imageRotate function in PHP 5.2.8 and earlier allows context-dependent attackers to read the contents of arbitrary memory locations via a crafted value of the third argument (aka the bgd_color or clrBack argument) for an indexed image.

CVSS

AV:N/AC:L/Au:N/C:P/I:N/A:N

External References

- CVE-2008-5498

PHP Use of Externally-Controlled Format String Vulnerability

The popen API function in TSRM/tsrm_win32.c in PHP before 5.2.11 and 5.3.x before 5.3.1, when running on certain Windows operating systems, allows context-dependent attackers to cause a denial of service (crash) via a crafted (1) "e" or (2) "er" string in the second argument (aka mode), possibly related to the _fdopen function in the Microsoft C runtime library. NOTE: this might not cross privilege boundaries except in rare cases in which the mode argument is accessible to an attacker outside of an application that uses the popen function.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2009-3294

PHP Use of Externally-Controlled Format String Vulnerability

The popen API function in TSRM/tsrm_win32.c in PHP before 5.2.11 and 5.3.x before 5.3.1, when running on certain Windows operating systems, allows context-dependent attackers to cause a denial of service (crash) via a crafted (1) "e" or (2) "er" string in the second argument (aka mode), possibly related to the _fdopen function in the Microsoft C runtime library. NOTE: this might not cross privilege boundaries except in rare cases in which the mode argument is accessible to an attacker outside of an application that uses the popen function.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2009-3294

PHP Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') Vulnerability

Multiple directory traversal vulnerabilities in PHP 5.2.6 and earlier allow context-dependent attackers to bypass safe_mode restrictions by creating a subdirectory named http: and then placing ../ (dot dot slash) sequences in an http URL argument to the (1) chdir or (2) ftok function.

CVSS

AV:N/AC:L/Au:N/C:P/I:N/A:N

External References

- CVE-2008-2666

PHP Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') Vulnerability

Multiple directory traversal vulnerabilities in PHP 5.2.6 and earlier allow context-dependent attackers to bypass safe_mode restrictions by creating a subdirectory named http: and then placing ../ (dot dot slash) sequences in an http URL argument to the (1) chdir or (2)

ftok function.

CVSS
AV:N/AC:L/Au:N/C:P/I:N/A:N

External References
- CVE-2008-2666

PHP Improper Input Validation Vulnerability

PHP 4.4.x before 4.4.9, and 5.x through 5.2.6, when used as a FastCGI module, allows remote attackers to cause a denial of service (crash) via a request with multiple dots preceding the extension, as demonstrated using foo..php.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2008-3660

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Buffer overflow in the memnstr function in PHP 4.4.x before 4.4.9 and PHP 5.6 through 5.2.6 allows context-dependent attackers to cause a denial of service (crash) and possibly execute arbitrary code via the delimiter argument to the explode function. NOTE: the scope of this issue is limited since most applications would not use an attacker-controlled delimiter, but local attacks against safe_mode are feasible.

CVSS
AV:N/AC:L/Au:N/C:N/I:P/A:P

External References
- CVE-2008-3659

PHP Numeric Errors Vulnerability

The (1) rand and (2) mt_rand functions in PHP 5.2.6 do not produce cryptographically strong random numbers, which allows attackers to leverage exposures in products that rely on these functions for security-relevant functionality, as demonstrated by the password-reset functionality in Joomla! 1.5.x and WordPress before 2.6.2, a different vulnerability than CVE-2008-2107, CVE-2008-2108, and CVE-2008-4102.

CVSS
AV:N/AC:H/Au:N/C:P/I:P/A:P

External References
- CVE-2008-4107

PHP Numeric Errors Vulnerability

The (1) rand and (2) mt_rand functions in PHP 5.2.6 do not produce cryptographically strong random numbers, which allows attackers to leverage exposures in products that rely on these functions for security-relevant functionality, as demonstrated by the password-reset functionality in Joomla! 1.5.x and WordPress before 2.6.2, a different vulnerability than CVE-2008-2107, CVE-2008-2108, and CVE-2008-4102.

CVSS
AV:N/AC:H/Au:N/C:P/I:P/A:P

External References

- CVE-2008-4107

PHP Improper Input Validation Vulnerability

The cdf_count_chain function in cdf.c in file before 5.19, as used in the Fileinfo component in PHP before 5.4.30 and 5.5.x before 5.5.14, does not properly validate sector-count data, which allows remote attackers to cause a denial of service (application crash) via a crafted CDF file.

CVSS

AV:N/AC:M/Au:N/C:N/I:N/A:P

External References

- CVE-2014-3480

PHP Improper Input Validation Vulnerability

The cdf_read_property_info function in file before 5.19, as used in the Fileinfo component in PHP before 5.4.30 and 5.5.x before 5.5.14, does not properly validate a stream offset, which allows remote attackers to cause a denial of service (application crash) via a crafted CDF file.

CVSS

AV:N/AC:M/Au:N/C:N/I:N/A:P

External References

- CVE-2014-3487

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The cdf_read_short_sector function in cdf.c in file before 5.19, as used in the Fileinfo component in PHP before 5.4.30 and 5.5.x before 5.5.14, allows remote attackers to cause a denial of service (assertion failure and application exit) via a crafted CDF file.

CVSS

AV:N/AC:M/Au:N/C:N/I:N/A:P

External References

- CVE-2014-0207

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Buffer overflow in the mconvert function in softmagic.c in file before 5.19, as used in the Fileinfo component in PHP before 5.4.30 and 5.5.x before 5.5.14, allows remote attackers to cause a denial of service (application crash) via a crafted Pascal string in a FILE_PSTRING conversion.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2014-3478

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Buffer overflow in the date_from_ISO8601 function in the mkgmtime implementation in libxmlrpc/xmlrpc.c in the XMLRPC extension in PHP before 5.4.34, 5.5.x before 5.5.18, and 5.6.x before 5.6.2 allows remote attackers to cause a denial of service (application crash) via

(1) a crafted first argument to the xmlrpc_set_type function or (2) a crafted argument to the xmlrpc_decode function, related to an out-of-bounds read operation.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2014-3668

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Multiple buffer overflows in the php_parserr function in ext/standard/dns.c in PHP before 5.4.32 and 5.5.x before 5.5.16 allow remote DNS servers to cause a denial of service (application crash) or possibly execute arbitrary code via a crafted DNS record, related to the dns_get_record function and the dn_expand function. NOTE: this issue exists because of an incomplete fix for CVE-2014-4049.

CVSS
AV:N/AC:M/Au:N/C:P/I:P/A:P

External References
- CVE-2014-3597

PHP Other Vulnerability

Use-after-free vulnerability in ext/spl/spl_dllist.c in the SPL component in PHP through 5.5.14 allows context-dependent attackers to cause a denial of service or possibly have unspecified other impact via crafted iterator usage within applications in certain web-hosting environments.

CVSS
AV:L/AC:L/Au:N/C:P/I:P/A:P

External References
- CVE-2014-4670

PHP Numeric Errors Vulnerability

Integer overflow in the cdf_read_property_info function in cdf.c in file through 5.19, as used in the Fileinfo component in PHP before 5.4.32 and 5.5.x before 5.5.16, allows remote attackers to cause a denial of service (application crash) via a crafted CDF file. NOTE: this vulnerability exists because of an incomplete fix for CVE-2012-1571.

CVSS
AV:N/AC:M/Au:N/C:N/I:N/A:P

External References
- CVE-2014-3587

PHP Improper Input Validation Vulnerability

The openssl_x509_parse function in openssl.c in the OpenSSL module in PHP before 5.4.18 and 5.5.x before 5.5.2 does not properly handle a '\0' character in a domain name in the Subject Alternative Name field of an X.509 certificate, which allows man-in-the-middle attackers to spoof arbitrary SSL servers via a crafted certificate issued by a legitimate Certification Authority, a related issue to CVE-2009-2408.

CVSS
AV:N/AC:M/Au:N/C:N/I:P/A:N

External References

- CVE-2013-4248

PHP Permissions, Privileges, and Access Controls Vulnerability

Session fixation vulnerability in the Sessions subsystem in PHP before 5.5.2 allows remote attackers to hijack web sessions by specifying a session ID.

CVSS

AV:N/AC:M/Au:N/C:P/I:P/A:P

External References

- CVE-2011-4718

PHP Improper Input Validation Vulnerability

The openssl_x509_parse function in openssl.c in the OpenSSL module in PHP before 5.4.18 and 5.5.x before 5.5.2 does not properly handle a '\0' character in a domain name in the Subject Alternative Name field of an X.509 certificate, which allows man-in-the-middle attackers to spoof arbitrary SSL servers via a crafted certificate issued by a legitimate Certification Authority, a related issue to CVE-2009-2408.

CVSS

AV:N/AC:M/Au:N/C:N/I:P/A:N

External References

- CVE-2013-4248

PHP Numeric Errors Vulnerability

Integer overflow in the SdnToJewish function in jewish.c in the Calendar component in PHP before 5.3.26 and 5.4.x before 5.4.16 allows context-dependent attackers to cause a denial of service (application hang) via a large argument to the jdtojewish function.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2013-4635

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

ext/xml/xml.c in PHP before 5.3.27 does not properly consider parsing depth, which allows remote attackers to cause a denial of service (heap memory corruption) or possibly have unspecified other impact via a crafted document that is processed by the xml_parse_into_struct function.

CVSS

AV:N/AC:M/Au:N/C:P/I:P/A:P

External References

- CVE-2013-4113

PHP Permissions, Privileges, and Access Controls Vulnerability

Session fixation vulnerability in the Sessions subsystem in PHP before 5.5.2 allows remote attackers to hijack web sessions by specifying a session ID.

CVSS
AV:N/AC:M/Au:N/C:P/I:P/A:P

External References
- CVE-2011-4718

PHP Resource Management Errors Vulnerability

The gdImageCreateFromXpm function in gdxpm.c in libgd, as used in PHP 5.4.26 and earlier, allows remote attackers to cause a denial of service (NULL pointer dereference and application crash) via a crafted color table in an XPM file.

CVSS
AV:N/AC:M/Au:N/C:N/I:N/A:P

External References
- CVE-2014-2497

PHP Resource Management Errors Vulnerability

The gdImageCreateFromXpm function in gdxpm.c in libgd, as used in PHP 5.4.26 and earlier, allows remote attackers to cause a denial of service (NULL pointer dereference and application crash) via a crafted color table in an XPM file.

CVSS
AV:N/AC:M/Au:N/C:N/I:N/A:P

External References
- CVE-2014-2497

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

The libxml RSHUTDOWN function in PHP 5.x allows remote attackers to bypass the open_basedir protection mechanism and read arbitrary files via vectors involving a stream_close method call during use of a custom stream wrapper.

CVSS
AV:N/AC:L/Au:N/C:P/I:N/A:N

External References
- CVE-2012-1171

PHP Improper Input Validation Vulnerability

The gdImageCrop function in ext/gd/gd.c in PHP 5.5.x before 5.5.9 does not check return values, which allows remote attackers to cause a denial of service (application crash) or possibly have unspecified other impact via invalid imagecrop arguments that lead to use of a NULL pointer as a return value, a different vulnerability than CVE-2013-7226.

CVSS
AV:N/AC:M/Au:N/C:P/I:P/A:P

External References
- CVE-2013-7327

PHP Numeric Errors Vulnerability

ext/gd/gd.c in PHP 5.5.x before 5.5.9 does not check data types, which might allow remote attackers to obtain sensitive information by using a (1) string or (2) array data type in place of a numeric data type, as demonstrated by an imagecrop function call with a string for

the x dimension value, a different vulnerability than CVE-2013-7226.

CVSS
AV:N/AC:L/Au:N/C:P/I:N/A:N

External References
- CVE-2014-2020

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

ext/phar/phar.c in PHP before 5.4.40, 5.5.x before 5.5.24, and 5.6.x before 5.6.8 allows remote attackers to obtain sensitive information from process memory or cause a denial of service (buffer over-read and application crash) via a crafted length value in conjunction with crafted serialized data in a phar archive, related to the phar_parse_metadata and phar_parse_pharfile functions.

CVSS
AV:N/AC:M/Au:N/C:P/I:N/A:P

External References
- CVE-2015-2783

PHP Permissions, Privileges, and Access Controls Vulnerability

The move_uploaded_file implementation in ext/standard/basic_functions.c in PHP before 5.4.39, 5.5.x before 5.5.23, and 5.6.x before 5.6.7 truncates a pathname upon encountering a \x00 character, which allows remote attackers to bypass intended extension restrictions and create files with unexpected names via a crafted second argument. NOTE: this vulnerability exists because of an incomplete fix for CVE-2006-7243.

CVSS
AV:N/AC:L/Au:N/C:N/I:P/A:N

External References
- CVE-2015-2348

PHP Other Vulnerability

The build_tablename function in pgsql.c in the PostgreSQL (aka pgsql) extension in PHP through 5.6.7 does not validate token extraction for table names, which allows remote attackers to cause a denial of service (NULL pointer dereference and application crash) via a crafted name.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2015-1352

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The exif_ifd_make_value function in exif.c in the EXIF extension in PHP before 5.4.34, 5.5.x before 5.5.18, and 5.6.x before 5.6.2 operates on floating-point arrays incorrectly, which allows remote attackers to cause a denial of service (heap memory corruption and application crash) or possibly execute arbitrary code via a crafted JPEG image with TIFF thumbnail data that is improperly handled by the exif_thumbnail function.

CVSS
AV:N/AC:M/Au:N/C:P/I:P/A:P

External References

- CVE-2014-3670

PHP Other Vulnerability

The exif_process_unicode function in ext/exif/exif.c in PHP before 5.4.37, 5.5.x before 5.5.21, and 5.6.x before 5.6.5 allows remote attackers to execute arbitrary code or cause a denial of service (uninitialized pointer free and application crash) via crafted EXIF data in a JPEG image.

CVSS

AV:N/AC:M/Au:N/C:P/I:P/A:P

External References

- CVE-2015-0232

PHP Improper Neutralization of Special Elements in Output Used by a Downstream Component ('Injection') Vulnerability

The default soap.wsdl_cache_dir setting in (1) php.ini-production and (2) php.ini-development in PHP through 5.6.7 specifies the /tmp directory, which makes it easier for local users to conduct WSDL injection attacks by creating a file under /tmp with a predictable filename that is used by the get_sdl function in ext/soap/php_sdl.c.

CVSS

AV:L/AC:L/Au:N/C:P/I:P/A:P

External References

- CVE-2013-6501

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

The mconvert function in softmagic.c in file before 5.21, as used in the Fileinfo component in PHP before 5.4.37, 5.5.x before 5.5.21, and 5.6.x before 5.6.5, does not properly handle a certain string-length field during a copy of a truncated version of a Pascal string, which might allow remote attackers to cause a denial of service (out-of-bounds memory access and application crash) via a crafted file.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2014-9652

PHP Cryptographic Issues Vulnerability

crypt_blowfish before 1.1, as used in PHP before 5.3.7 on certain platforms, PostgreSQL before 8.4.9, and other products, does not properly handle 8-bit characters, which makes it easier for context-dependent attackers to determine a cleartext password by leveraging knowledge of a password hash.

CVSS

AV:N/AC:L/Au:N/C:P/I:N/A:N

External References

- CVE-2011-2483

PHP Cryptographic Issues Vulnerability

crypt_blowfish before 1.1, as used in PHP before 5.3.7 on certain platforms, PostgreSQL before 8.4.9, and other products, does not properly handle 8-bit characters, which makes it easier for context-dependent attackers to determine a cleartext password by

leveraging knowledge of a password hash.

CVSS
AV:N/AC:L/Au:N/C:P/I:N/A:N

External References
- CVE-2011-2483

PHP Other Vulnerability

PHP before 5.3.7 does not properly check the return values of the malloc, calloc, and realloc library functions, which allows context-dependent attackers to cause a denial of service (NULL pointer dereference and application crash) or trigger a buffer overflow by leveraging the ability to provide an arbitrary value for a function argument, related to (1) ext/curl/interface.c, (2) ext/date/lib/parse_date.c, (3) ext/date/lib/parse_iso_intervals.c, (4) ext/date/lib/parse_tz.c, (5) ext/date/lib/timelib.c, (6) ext/pdo_odbc/pdo_odbc.c, (7) ext/reflection/php_reflection.c, (8) ext/soap/php_sdl.c, (9) ext/xmlrpc/libxmlrpc/base64.c, (10) TSRM/tsrm_win32.c, and (11) the strtotime function.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2011-3182

PHP Permissions, Privileges, and Access Controls Vulnerability

The rfc1867_post_handler function in main/rfc1867.c in PHP before 5.3.7 does not properly restrict filenames in multipart/form-data POST requests, which allows remote attackers to conduct absolute path traversal attacks, and possibly create or overwrite arbitrary files, via a crafted upload request, related to a "file path injection vulnerability."

CVSS
AV:N/AC:L/Au:N/C:N/I:P/A:P

External References
- CVE-2011-2202

PHP Improper Input Validation Vulnerability

The Zip extension in PHP before 5.3.6 allows context-dependent attackers to cause a denial of service (application crash) via a ziparchive stream that is not properly handled by the stream_get_contents function.

CVSS
AV:N/AC:M/Au:N/C:N/I:N/A:P

External References
- CVE-2011-1470

PHP Improper Input Validation Vulnerability

PHP before 5.3.9 computes hash values for form parameters without restricting the ability to trigger hash collisions predictably, which allows remote attackers to cause a denial of service (CPU consumption) by sending many crafted parameters.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2011-4885

PHP Resource Management Errors Vulnerability

PHP before 5.3.7 does not properly implement the error_log function, which allows context-dependent attackers to cause a denial of service (application crash) via unspecified vectors.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2011-3267

PHP Other Vulnerability

PHP before 5.3.7 does not properly check the return values of the malloc, calloc, and realloc library functions, which allows context-dependent attackers to cause a denial of service (NULL pointer dereference and application crash) or trigger a buffer overflow by leveraging the ability to provide an arbitrary value for a function argument, related to (1) ext/curl/interface.c, (2) ext/date/lib/parse_date.c, (3) ext/date/lib/parse_iso_intervals.c, (4) ext/date/lib/parse_tz.c, (5) ext/date/lib/timelib.c, (6) ext/pdo_odbc/pdo_odbc.c, (7) ext/reflection/php_reflection.c, (8) ext/soap/php_sdl.c, (9) ext/xmlrpc/libxmlrpc/base64.c, (10) TSRM/tsrm_win32.c, and (11) the strtotime function.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2011-3182

PHP Resource Management Errors Vulnerability

PHP before 5.3.7 does not properly implement the error_log function, which allows context-dependent attackers to cause a denial of service (application crash) via unspecified vectors.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2011-3267

PHP Numeric Errors Vulnerability

Integer overflow in the SdnToJulian function in the Calendar extension in PHP before 5.3.6 allows context-dependent attackers to cause a denial of service (application crash) via a large integer in the first argument to the cal_from_jd function.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2011-1466

PHP CVE-2011-1467 Vulnerability

Unspecified vulnerability in the NumberFormatter::setSymbol (aka numfmt_set_symbol) function in the Intl extension in PHP before 5.3.6 allows context-dependent attackers to cause a denial of service (application crash) via an invalid argument, a related issue to CVE-

2010-4409.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2011-1467

PHP Numeric Errors Vulnerability

Integer overflow in the SdnToJulian function in the Calendar extension in PHP before 5.3.6 allows context-dependent attackers to cause a denial of service (application crash) via a large integer in the first argument to the cal_from_jd function.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2011-1466

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Buffer overflow in the strval function in PHP before 5.3.6, when the precision configuration option has a large value, might allow context-dependent attackers to cause a denial of service (application crash) via a small numerical value in the argument.

CVSS
AV:N/AC:M/Au:N/C:N/I:N/A:P

External References
- CVE-2011-1464

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

exif.c in the Exif extension in PHP before 5.3.6 on 64-bit platforms performs an incorrect cast, which allows remote attackers to cause a denial of service (application crash) via an image with a crafted Image File Directory (IFD) that triggers a buffer over-read.

CVSS
AV:N/AC:M/Au:N/C:N/I:N/A:P

External References
- CVE-2011-0708

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Buffer overflow in the strval function in PHP before 5.3.6, when the precision configuration option has a large value, might allow context-dependent attackers to cause a denial of service (application crash) via a small numerical value in the argument.

CVSS
AV:N/AC:M/Au:N/C:N/I:N/A:P

External References
- CVE-2011-1464

PHP CVE-2011-1469 Vulnerability

Unspecified vulnerability in the Streams component in PHP before 5.3.6 allows context-dependent attackers to cause a denial of service (application crash) by accessing an ftp:// URL during use of an HTTP proxy with the FTP wrapper.

CVSS
AV:N/AC:M/Au:N/C:N/I:N/A:P

External References
- CVE-2011-1469

PHP Improper Input Validation Vulnerability

The Zip extension in PHP before 5.3.6 allows context-dependent attackers to cause a denial of service (application crash) via a ziparchive stream that is not properly handled by the stream_get_contents function.

CVSS
AV:N/AC:M/Au:N/C:N/I:N/A:P

External References
- CVE-2011-1470

PHP CVE-2011-1469 Vulnerability

Unspecified vulnerability in the Streams component in PHP before 5.3.6 allows context-dependent attackers to cause a denial of service (application crash) by accessing an ftp:// URL during use of an HTTP proxy with the FTP wrapper.

CVSS
AV:N/AC:M/Au:N/C:N/I:N/A:P

External References
- CVE-2011-1469

PHP Resource Management Errors Vulnerability

Multiple memory leaks in the OpenSSL extension in PHP before 5.3.6 might allow remote attackers to cause a denial of service (memory consumption) via (1) plaintext data to the openssl_encrypt function or (2) ciphertext data to the openssl_decrypt function.

CVSS
AV:N/AC:M/Au:N/C:N/I:N/A:P

External References
- CVE-2011-1468

PHP CVE-2011-1467 Vulnerability

Unspecified vulnerability in the NumberFormatter::setSymbol (aka numfmt_set_symbol) function in the Intl extension in PHP before 5.3.6 allows context-dependent attackers to cause a denial of service (application crash) via an invalid argument, a related issue to CVE-2010-4409.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2011-1467

PHP Resource Management Errors Vulnerability

Multiple memory leaks in the OpenSSL extension in PHP before 5.3.6 might allow remote attackers to cause a denial of service (memory consumption) via (1) plaintext data to the openssl_encrypt function or (2) ciphertext data to the openssl_decrypt function.

CVSS

AV:N/AC:M/Au:N/C:N/I:N/A:P

External References

- CVE-2011-1468

PHP Improper Input Validation Vulnerability

The sapi_header_op function in main/SAPI.c in PHP before 5.3.11 and 5.4.x before 5.4.0RC2 does not check for %0D sequences (aka carriage return characters), which allows remote attackers to bypass an HTTP response-splitting protection mechanism via a crafted URL, related to improper interaction between the PHP header function and certain browsers, as demonstrated by Internet Explorer and Google Chrome.

CVSS

AV:N/AC:M/Au:N/C:N/I:P/A:N

External References

- CVE-2011-1398

PHP Permissions, Privileges, and Access Controls Vulnerability

The SQLite functionality in PHP before 5.3.15 allows remote attackers to bypass the open_basedir protection mechanism via unspecified vectors.

CVSS

AV:N/AC:L/Au:N/C:N/I:P/A:N

External References

- CVE-2012-3365

PHP Permissions, Privileges, and Access Controls Vulnerability

The SQLite functionality in PHP before 5.3.15 allows remote attackers to bypass the open_basedir protection mechanism via unspecified vectors.

CVSS

AV:N/AC:L/Au:N/C:N/I:P/A:N

External References

- CVE-2012-3365

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Heap-based buffer overflow in the php_quot_print_encode function in ext/standard/quot_print.c in PHP before 5.3.26 and 5.4.x before 5.4.16 allows remote attackers to cause a denial of service (application crash) or possibly have unspecified other impact via a crafted argument to the quoted_printable_encode function.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2013-2110

PHP Numeric Errors Vulnerability

Integer overflow in the SdnToJewish function in jewish.c in the Calendar component in PHP before 5.3.26 and 5.4.x before 5.4.16 allows context-dependent attackers to cause a denial of service (application hang) via a large argument to the jdtojewish function.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2013-4635

PHP Improper Restriction of Operations within the Bounds of a Memory Buffer Vulnerability

Heap-based buffer overflow in the php_quot_print_encode function in ext/standard/quot_print.c in PHP before 5.3.26 and 5.4.x before 5.4.16 allows remote attackers to cause a denial of service (application crash) or possibly have unspecified other impact via a crafted argument to the quoted_printable_encode function.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2013-2110

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

The SOAP parser in PHP before 5.3.23 and 5.4.x before 5.4.13 allows remote attackers to read arbitrary files via a SOAP WSDL file containing an XML external entity declaration in conjunction with an entity reference, related to an XML External Entity (XXE) issue in the soap_xmlParseFile and soap_xmlParseMemory functions. NOTE: this vulnerability exists because of an incorrect fix for CVE-2013-1824.

CVSS

AV:N/AC:L/Au:N/C:P/I:N/A:N

External References

- CVE-2013-1643

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

The SOAP parser in PHP before 5.3.23 and 5.4.x before 5.4.13 allows remote attackers to read arbitrary files via a SOAP WSDL file containing an XML external entity declaration in conjunction with an entity reference, related to an XML External Entity (XXE) issue in the soap_xmlParseFile and soap_xmlParseMemory functions. NOTE: this vulnerability exists because of an incorrect fix for CVE-2013-1824.

CVSS

AV:N/AC:L/Au:N/C:P/I:N/A:N

External References

- CVE-2013-1643

PHP Improper Input Validation Vulnerability

PHP before 5.3.10 does not properly perform a temporary change to the magic_quotes_gpc directive during the importing of environment variables, which makes it easier for remote attackers to conduct SQL injection attacks via a crafted request, related to main/php_variables.c, sapi/cgi/cgi_main.c, and sapi/fpm/fpm/fpm_main.c.

CVSS
AV:N/AC:M/Au:N/C:P/I:P/A:P

External References
- CVE-2012-0831

PHP Improper Input Validation Vulnerability

The PDORow implementation in PHP before 5.3.9 does not properly interact with the session feature, which allows remote attackers to cause a denial of service (application crash) via a crafted application that uses a PDO driver for a fetch and then calls the session_start function, as demonstrated by a crash of the Apache HTTP Server.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2012-0788

PHP Improper Input Validation Vulnerability

The PDORow implementation in PHP before 5.3.9 does not properly interact with the session feature, which allows remote attackers to cause a denial of service (application crash) via a crafted application that uses a PDO driver for a fetch and then calls the session_start function, as demonstrated by a crash of the Apache HTTP Server.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References
- CVE-2012-0788

PHP Permissions, Privileges, and Access Controls Vulnerability

PHP before 5.3.9 has improper libxslt security settings, which allows remote attackers to create arbitrary files via a crafted XSLT stylesheet that uses the libxslt output extension.

CVSS
AV:N/AC:L/Au:N/C:P/I:P/A:N

External References
- CVE-2012-0057

PHP Improper Input Validation Vulnerability

PHP before 5.3.9 computes hash values for form parameters without restricting the ability to trigger hash collisions predictably, which allows remote attackers to cause a denial of service (CPU consumption) by sending many crafted parameters.

CVSS
AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2011-4885

PHP Improper Input Validation Vulnerability

PHP before 5.3.10 does not properly perform a temporary change to the magic_quotes_gpc directive during the importing of environment variables, which makes it easier for remote attackers to conduct SQL injection attacks via a crafted request, related to main/php_variables.c, sapi/cgi/cgi_main.c, and sapi/fpm/fpm/fpm_main.c.

CVSS

AV:N/AC:M/Au:N/C:P/I:P/A:P

External References

- CVE-2012-0831

PHP Permissions, Privileges, and Access Controls Vulnerability

PHP before 5.3.9 has improper libxslt security settings, which allows remote attackers to create arbitrary files via a crafted XSLT stylesheet that uses the libxslt output extension.

CVSS

AV:N/AC:L/Au:N/C:P/I:P/A:N

External References

- CVE-2012-0057

PHP Resource Management Errors Vulnerability

Memory leak in the timezone functionality in PHP before 5.3.9 allows remote attackers to cause a denial of service (memory consumption) by triggering many strtotime function calls, which are not properly handled by the php_date_parse_tzfile cache.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2012-0789

PHP Improper Input Validation Vulnerability

The file-upload implementation in rfc1867.c in PHP before 5.4.0 does not properly handle invalid [(open square bracket) characters in name values, which makes it easier for remote attackers to cause a denial of service (malformed $_FILES indexes) or conduct directory traversal attacks during multi-file uploads by leveraging a script that lacks its own filename restrictions.

CVSS

AV:N/AC:M/Au:N/C:N/I:P/A:P

External References

- CVE-2012-1172

PHP Improper Input Validation Vulnerability

The file-upload implementation in rfc1867.c in PHP before 5.4.0 does not properly handle invalid [(open square bracket) characters in name values, which makes it easier for remote attackers to cause a denial of service (malformed $_FILES indexes) or conduct directory traversal attacks during multi-file uploads by leveraging a script that lacks its own filename restrictions.

CVSS

AV:N/AC:M/Au:N/C:N/I:P/A:P

External References

- CVE-2012-1172

PHP Resource Management Errors Vulnerability

Memory leak in the timezone functionality in PHP before 5.3.9 allows remote attackers to cause a denial of service (memory consumption) by triggering many strtotime function calls, which are not properly handled by the php_date_parse_tzfile cache.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2012-0789

PHP Uncontrolled Resource Consumption Vulnerability

An issue was discovered in PHP 7.3.x before 7.3.0alpha3, 7.2.x before 7.2.8, and before 7.1.20. The php-fpm master process restarts a child process in an endless loop when using program execution functions (e.g., passthru, exec, shell_exec, or system) with a non-blocking STDIN stream, causing this master process to consume 100% of the CPU, and consume disk space with a large volume of error logs, as demonstrated by an attack by a customer of a shared-hosting facility.

CVSS

CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

External References

- CVE-2015-9253

PHP Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') Vulnerability

Directory traversal vulnerability in the ZipArchive::extractTo function in ext/zip/php_zip.c in PHP before 5.4.45, 5.5.x before 5.5.29, and 5.6.x before 5.6.13 and ext/zip/ext_zip.cpp in HHVM before 3.12.1 allows remote attackers to create arbitrary empty directories via a crafted ZIP archive.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N

External References

- CVE-2014-9767

PHP Improper Access Control Vulnerability

ext/mysqlnd/mysqlnd.c in PHP before 5.4.43, 5.5.x before 5.5.27, and 5.6.x before 5.6.11 uses a client SSL option to mean that SSL is optional, which allows man-in-the-middle attackers to spoof servers via a cleartext-downgrade attack, a related issue to CVE-2015-3152.

CVSS

CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:H/A:N

External References

- CVE-2015-8838

PHP Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

The sapi_header_op function in main/SAPI.c in PHP before 5.4.38, 5.5.x before 5.5.22, and 5.6.x before 5.6.6 supports deprecated line folding without considering browser compatibility, which allows remote attackers to conduct cross-site scripting (XSS) attacks against Internet Explorer by leveraging (1) %0A%20 or (2) %0D%0A%20 mishandling in the header function.

CVSS
CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

External References
- CVE-2015-8935

PHP Numeric Errors Vulnerability

Off-by-one error in the phar_parse_zipfile function in ext/phar/zip.c in PHP before 5.5.30 and 5.6.x before 5.6.14 allows remote attackers to cause a denial of service (uninitialized pointer dereference and application crash) by including the / filename in a .zip PHAR archive.

CVSS
AV:N/AC:M/Au:N/C:P/I:P/A:P

External References
- CVE-2015-7804

PHP Improper Input Validation Vulnerability

The do_soap_call function in ext/soap/soap.c in PHP before 5.4.39, 5.5.x before 5.5.23, and 5.6.x before 5.6.7 does not verify that the uri property is a string, which allows remote attackers to obtain sensitive information by providing crafted serialized data with an int data type, related to a "type confusion" issue.

CVSS
AV:N/AC:L/Au:N/C:P/I:N/A:N

External References
- CVE-2015-4148

PHP Other Vulnerability

The phar_get_entry_data function in ext/phar/util.c in PHP before 5.5.30 and 5.6.x before 5.6.14 allows remote attackers to cause a denial of service (NULL pointer dereference and application crash) via a .phar file with a crafted TAR archive entry in which the Link indicator references a file that does not exist.

CVSS
AV:N/AC:M/Au:N/C:P/I:P/A:P

External References
- CVE-2015-7803

PHP Improper Input Validation Vulnerability

PHP before 5.4.40, 5.5.x before 5.5.24, and 5.6.x before 5.6.8 does not ensure that pathnames lack %00 sequences, which might allow remote attackers to read or write to arbitrary files via crafted input to an application that calls (1) a DOMDocument load method, (2) the xmlwriter_open_uri function, (3) the finfo_file function, or (4) the hash_hmac_file function, as demonstrated by a filename\0.xml attack that bypasses an intended configuration in which client users may read only .xml files.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

External References

- CVE-2015-3411

PHP Improper Input Validation Vulnerability

The php_handler function in sapi/apache2handler/sapi_apache2.c in PHP before 5.4.40, 5.5.x before 5.5.24, and 5.6.x before 5.6.8, when the Apache HTTP Server 2.4.x is used, allows remote attackers to cause a denial of service (application crash) or possibly execute arbitrary code via pipelined HTTP requests that result in a "deconfigured interpreter."

CVSS

AV:N/AC:M/Au:N/C:P/I:P/A:P

External References

- CVE-2015-3330

PHP Numeric Errors Vulnerability

The phar_parse_tarfile function in ext/phar/tar.c in PHP before 5.4.41, 5.5.x before 5.5.25, and 5.6.x before 5.6.9 does not verify that the first character of a filename is different from the \0 character, which allows remote attackers to cause a denial of service (integer underflow and memory corruption) via a crafted entry in a tar archive.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2015-4021

PHP Resource Management Errors Vulnerability

Algorithmic complexity vulnerability in the multipart_buffer_headers function in main/rfc1867.c in PHP before 5.4.41, 5.5.x before 5.5.25, and 5.6.x before 5.6.9 allows remote attackers to cause a denial of service (CPU consumption) via crafted form data that triggers an improper order-of-growth outcome.

CVSS

AV:N/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2015-4024

PHP Improper Input Validation Vulnerability

PHP before 5.4.42, 5.5.x before 5.5.26, and 5.6.x before 5.6.10 does not ensure that pathnames lack %00 sequences, which might allow remote attackers to read or write to arbitrary files via crafted input to an application that calls (1) a DOMDocument save method or (2) the GD imagepsloadfont function, as demonstrated by a filename\0.html attack that bypasses an intended configuration in which client users may write to only .html files.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

External References

- CVE-2015-4598

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

PHP before 5.4.40, 5.5.x before 5.5.24, and 5.6.x before 5.6.8 does not ensure that pathnames lack %00 sequences, which might allow remote attackers to read arbitrary files via crafted input to an application that calls the stream_resolve_include_path function in ext/standard/streamsfuncs.c, as demonstrated by a filename\0.extension attack that bypasses an intended configuration in which client users may read files with only one specific extension.

CVSS

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

External References

- CVE-2015-3412

PHP Improper Link Resolution Before File Access ('Link Following') Vulnerability

The PEAR_REST class in REST.php in PEAR in PHP through 5.6.0 allows local users to write to arbitrary files via a symlink attack on a (1) rest.cachefile or (2) rest.cacheid file in /tmp/pear/cache/, related to the retrieveCacheFirst and useLocalCache functions.

CVSS

AV:L/AC:L/Au:N/C:N/I:P/A:P

External References

- CVE-2014-5459

PHP Improper Link Resolution Before File Access ('Link Following') Vulnerability

acinclude.m4, as used in the configure script in PHP 5.5.13 and earlier, allows local users to overwrite arbitrary files via a symlink attack on the /tmp/phpglibccheck file.

CVSS

AV:L/AC:M/Au:N/C:N/I:P/A:P

External References

- CVE-2014-3981

PHP Improper Input Validation Vulnerability

PHP 5.2.5 and earlier allows context-dependent attackers to cause a denial of service (application crash) via a long string in (1) the domain parameter to the dgettext function, the message parameter to the (2) dcgettext or (3) gettext function, the msgid1 parameter to the (4) dngettext or (5) ngettext function, or (6) the classname parameter to the stream_wrapper_register function. NOTE: this might not be a vulnerability in most web server environments that support multiple threads, unless this issue can be demonstrated for code execution.

CVSS

AV:L/AC:L/Au:N/C:N/I:N/A:P

External References

- CVE-2007-6039

PHP Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

Cross-site scripting (XSS) vulnerability in PHP, possibly 5.2.7 and earlier, when display_errors is enabled, allows remote attackers to inject arbitrary web script or HTML via unspecified vectors. NOTE: because of the lack of details, it is unclear whether this is related to CVE-2006-0208.

CVSS
AV:N/AC:H/Au:N/C:N/I:P/A:N

External References
- CVE-2008-5814

PHP Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') Vulnerability

Cross-site scripting (XSS) vulnerability in PHP, possibly 5.2.7 and earlier, when display_errors is enabled, allows remote attackers to inject arbitrary web script or HTML via unspecified vectors. NOTE: because of the lack of details, it is unclear whether this is related to CVE-2006-0208.

CVSS
AV:N/AC:H/Au:N/C:N/I:P/A:N

External References
- CVE-2008-5814

PHP Exposure of Sensitive Information to an Unauthorized Actor Vulnerability

The phpinfo implementation in ext/standard/info.c in PHP before 5.4.30 and 5.5.x before 5.5.14 does not ensure use of the string data type for the PHP_AUTH_PW, PHP_AUTH_TYPE, PHP_AUTH_USER, and PHP_SELF variables, which might allow context-dependent attackers to obtain sensitive information from process memory by using the integer data type with crafted values, related to a "type confusion" vulnerability, as demonstrated by reading a private SSL key in an Apache HTTP Server web-hosting environment with mod_ssl and a PHP 5.3.x mod_php.

CVSS
AV:N/AC:H/Au:N/C:P/I:N/A:N

External References
- CVE-2014-4721

PHP Other Vulnerability

pdo_sql_parser.re in the PDO extension in PHP before 5.3.14 and 5.4.x before 5.4.4 does not properly determine the end of the query string during parsing of prepared statements, which allows remote attackers to cause a denial of service (out-of-bounds read and application crash) via a crafted parameter value.

CVSS
AV:N/AC:H/Au:N/C:N/I:N/A:P

External References
- CVE-2012-3450

Vulnerabilities

2.1. http://150.1.7.104/dvwa/login.php

Identified Version
- 5.2.4

Latest Version

- 5.2.17 (in this branch)

Overall Latest Version

- 8.5.4

Branch Status

- The official end-of-life date for this branch is: 06/01/2011.

Vulnerability Database

- Result is based on 03/24/2026 20:00:00 vulnerability database content.

Certainty

Request | Response

Request

```
GET /dvwa/login.php HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 172.7328
Total Bytes Received : 1710
Body Length : 1289
Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie: PHPSESSID=**************; path=/
Set-Cookie: security=high
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Pragma: no-cache

Expires: Tue, 23 Jun 2009 12:00:00 GMT
Keep-Alive: timeout=15, max=100
Content-Length: 1289
Connection: Keep-Alive
Content-Type: text/html;charset=utf-8
Date: Fri, 27 Mar 2026 19:53:45 GMT
Cache-Control: no-cache, must-revalidate
```

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">

<head>

<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

<title>Damn Vulnerable Web App (DVWA) - Login</title>

<link rel="stylesheet" type="text/css" href="dvwa/css/login.css" />

</head>

<body>

<div align="center">

<br />

<p><img src="dvwa/images/login_logo.png" /></p>

<br />

<form action="login.php" method="post">
```

```
<fieldset>

<label for="user">Username</label> <input type="text" class="loginInput" size="20" name="username"><br
/>


<label for="pass">Password</label> <input type="password" class="loginInput" AUTOCOMPLETE="off"
size="20" name="password"><br />


<p class="submit"><input type="submit" value="Login" name="Login"></p>

</fieldset>

</form>


<br />



<br />
<br />
<br />
<br />
<br />
<br />
<br />
<br />

<!-- <img src="dvwa/images/RandomStorm.png" /> -->

<p>Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project</p>
<p>Hint: default username is 'admin' with password 'password' </p>
</div> <!-- end align div -->

</body>

</html>
```

Remedy

Please upgrade your installation of PHP to the latest stable version.

Remedy References

- Downloading PHP

CLASSIFICATION

PCI DSS v3.2	6.2
PCI DSS v4.0	6.3.3
OWASP 2013	A9
OWASP 2017	A9
CWE	1035 , 937
CAPEC	310
HIPAA	164.308(a)(1)(i)
ASVS 4.0	1.14.3
NIST SP 800-53	CM-6
DISA STIG	V-16836
OWASP Proactive Controls	C1
ISO27001	A.14.1.2
ISO27001 2022	A.8.19
OWASP Top Ten 2021	A06
OWASP API Top 10 2023	API8

3. Password Transmitted over HTTP

HIGH 1 | CONFIRMED 1

Invicti Standard detected that password data is being transmitted over HTTP.

Impact

If an attacker can intercept network traffic, he/she can steal users' credentials.

Vulnerabilities

3.1. http://150.1.7.104/dvwa/login.php

CONFIRMED

Input Name

- password

Form target action

- http://150.1.7.104/dvwa/login.php

Request | Response

Request

```
GET /dvwa/login.php HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 172.7328
Total Bytes Received : 1710
Body Length : 1289
Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie: PHPSESSID=**************; path=/
Set-Cookie: security=high
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Pragma: no-cache
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Keep-Alive: timeout=15, max=100
Content-Length: 1289
Connection: Keep-Alive
Content-Type: text/html;charset=utf-8
Date: Fri, 27 Mar 2026 19:53:45 GMT
Cache-Control: no-cache, must-revalidate
```

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">

<head>

<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

<title>Damn Vulnerable Web App (DVWA) - Login</title>

<link rel="stylesheet" type="text/css" href="dvwa/css/login.css" />

</head>

<body>

<div align="center">

<br />

<p><img src="dvwa/images/login_logo.png" /></p>

<br />

<form action="login.php" method="post">

<fieldset>
```

```
<label for="user">Username</label> <input type="text" class="loginInput" size="20" name="username"><br
/>


<label for="pass">Password</label> <input type="password" class="loginInput" AUTOCOMPLETE="off"
size="20" name="password"><br />


<p class="submit"><input type="submit" value="Login" name="Login"></p>

</fieldset>

</form>


<br />



<br />
<br />
<br />
<br />
<br />
<br />
<br />
<br />

<!-- <img src="dvwa/images/RandomStorm.png" /> -->

<p>Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project</p>
<p>Hint: default username is 'admin' with password 'password' </p>
</div> <!-- end align div -->

</body>

</html>
```

Actions to Take

1. See the remedy for solution.
2. Move all of your critical forms and pages to HTTPS and do not serve them over HTTP.

Remedy

All sensitive data should be transferred over HTTPS rather than HTTP. Forms should be served over HTTPS. All aspects of the application that accept user input, starting from the login process, should only be served over HTTPS.

CLASSIFICATION

PCI DSS v3.2	6.5.4
PCI DSS v4.0	6.2.4
OWASP 2013	A6
OWASP 2017	A3
CWE	319
CAPEC	65
WASC	4
ASVS 4.0	2.2.5
NIST SP 800-53	SC-8
DISA STIG	V-16796
ISO27001	A.14.1.3
ISO27001 2022	A.8.5
ISO27001 2022	A.8.24
ISO27001 2022	A.8.27
ISO27001 2022	A.8.3
OWASP Top Ten 2021	A02

CVSS 3.0 SCORE

Base	5.7 (Medium)
Temporal	5.7 (Medium)
Environmental	5.7 (Medium)

CVSS Vector String

CVSS:3.0/AV:A/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N

CVSS 3.1 SCORE

Base	5.7 (Medium)
Temporal	5.7 (Medium)
Environmental	5.7 (Medium)

CVSS Vector String

CVSS:3.1/AV:A/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N

CVSS 4.0 Score

5.1 / Medium	
Exploitability	Medium
Complexity	High
Vulnerable system	Low
Subsequent system	Low

CVSS 4.0 Score

Exploitation	High
Security requirements	Medium

CVSS Vector String

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N

4. SSL/TLS Not Implemented

MEDIUM | 1

Invicti Standard detected that SSL/TLS is not implemented after trying to establish a secure connection to the target website.

Impact

An attacker who is able to intercept your - or your users' - network traffic can read and modify any messages that are exchanged with your server.

That means that an attacker can see passwords in clear text, modify the appearance of your website, redirect the user to other web pages or steal session information.

Therefore no message you send to the server remains confidential.

Vulnerabilities

4.1. https://150.1.7.104/dvwa/login.php

Certainty

Request | Response

Request

```
[SSL Connection]
```

Response

Response Time (ms) : 1
Total Bytes Received : 16
Body Length : 0
Is Compressed : No

```
[SSL Connection]
```

Remedy

We suggest that you implement SSL/TLS properly, for example by using the Certbot tool provided by the Let's Encrypt certificate authority. It can automatically configure most modern web servers, e.g. Apache and Nginx to use SSL/TLS. Both the tool and the

certificates are free and are usually installed within minutes.

CLASSIFICATION

PCI DSS v3.2	6.5.4
PCI DSS v4.0	6.2.4
OWASP 2013	A6
OWASP 2017	A3
CWE	311
CAPEC	217
WASC	4
HIPAA	164.306
ASVS 4.0	9.1.1
NIST SP 800-53	SC-8
DISA STIG	V-6136
OWASP API Top Ten 2019	API7
ISO27001	A.14.1.3
ISO27001 2022	A.5.14
ISO27001 2022	A.8.27
OWASP Top Ten 2021	A02
OWASP API Top 10 2023	API8

CVSS 3.0 SCORE

Base	6.8 (Medium)
Temporal	6.1 (Medium)
Environmental	6.1 (Medium)

CVSS Vector String

CVSS:3.0/AV:A/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N/E:P/RL:O/RC:C

CVSS 3.1 SCORE

Base	6.8 (Medium)
Temporal	6.1 (Medium)
Environmental	6.1 (Medium)

CVSS Vector String

CVSS:3.1/AV:A/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N/E:P/RL:O/RC:C

CVSS 4.0 Score

5.1 / Medium	
Exploitability	Medium
Complexity	High
Vulnerable system	Low
Subsequent system	Low

CVSS 4.0 Score

Exploitation	High
Security requirements	Medium

CVSS Vector String

CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N

5. Apache MultiViews Enabled

LOW | 1

Invicti Standard detected that Apache MultiViews is enabled.

This vulnerability can be used for locating and obtaining access to some hidden resources.

Impact

An attacker can use this functionality to aid in finding hidden files in the site and potentially gather further sensitive information.

Vulnerabilities

5.1. http://150.1.7.104/dvwa/login

Certainty

Request | Response

Request

```
HEAD /dvwa/login HTTP/1.1
Host: 150.1.7.104
Accept: netsparker/check
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: security=high; PHPSESSID=**************
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 1.3831
Total Bytes Received : 238
Body Length : 0
Is Compressed : No

```
HTTP/1.1 406 Not Acceptable
Server: Apache/2.2.8 (Ubuntu) DAV/2
TCN: list
Alternates:{"login.php" 1 {type application/x-httpd-php}}
Content-Type: text/html; charset=iso-8859-1
Date: Fri, 27 Mar 2026 19:54:07 GMT
Vary: negotiate
```

Actions to Take

1. Change your server configuration file. A recommended configuration for the requested directory should be in the following format:

   ```
   <Directory /{YOUR DIRECTORY}>
           Options FollowSymLinks
   </Directory>
   ```

   Remove the *MultiViews*option from configuration.

CLASSIFICATION

OWASP 2013	A5
OWASP 2017	A6
CWE	16
WASC	14
ASVS 4.0	4.3.2
NIST SP 800-53	CM-6
DISA STIG	V-6141
OWASP API Top Ten 2019	API7
ISO27001	A.9.4.1
ISO27001 2022	A.8.3
OWASP Top Ten 2021	A05
OWASP API Top 10 2023	API8

6. Autocomplete is Enabled

LOW | 1 CONFIRMED | 1

Invicti Standard detected that Autocomplete is Enabled in one or more of the form fields which might contain sensitive information like "username", "credit card" or "CVV".

Impact

If user chooses to save, data entered in these fields will be cached by the browser. An attacker who can access the victim's browser could steal this information. This is especially important if the application is commonly used in shared computers, such as cyber cafes or airport terminals.

Vulnerabilities

6.1. http://150.1.7.104/dvwa/login.php

CONFIRMED

Identified Field Name

- username

Request | Response

Request

```
GET /dvwa/login.php HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 172.7328
Total Bytes Received : 1710
Body Length : 1289
Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie: PHPSESSID=**************; path=/
Set-Cookie: security=high
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Pragma: no-cache
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Keep-Alive: timeout=15, max=100
Content-Length: 1289
Connection: Keep-Alive
Content-Type: text/html;charset=utf-8
Date: Fri, 27 Mar 2026 19:53:45 GMT
Cache-Control: no-cache, must-revalidate
```

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">

<head>

<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

<title>Damn Vulnerable Web App (DVWA) - Login</title>

<link rel="stylesheet" type="text/css" href="dvwa/css/login.css" />

</head>

<body>

<div align="center">

<br />

<p><img src="dvwa/images/login_logo.png" /></p>

<br />

<form action="login.php" method="post">

<fieldset>
```

```
<label for="user">Username</label> <input type="text"class="loginInput" size="20" name="username"><br />


<label for="pass">Password</label> <input type="password" class="loginInput" AUTOCOMPLETE="off" size="20" name="password"><br />


<p class="submit"><input type="submit" value="Login" name="Login"></p>

</fieldset>

</form>


<br />



<br />
<br />
<br />
<br />
<br />
<br />
<br />
<br />

<!-- <img src="dvwa/images/RandomStorm.png" /> -->

<p>Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project</p>
<p>Hint: default username is 'admin' with password 'password' </p>
</div> <!-- end align div -->

</body>

</html>
```

Actions to Take

1. Add the attribute `autocomplete="new-password"`to the form tag or to individual "input" fields. Please note that modern browsers might ignore the previously recommended `autocomplete="off"`instruction, due to their integrated password management mechanism.
2. Find all instances of inputs that store private data and disable autocomplete. Fields which contain data such as "Credit Card" or "CCV" type data should not be cached. You can allow the application to cache usernames and remember passwords; however, in most cases this is not recommended.
3. Re-scan the application after addressing the identified issues to ensure all of the fixes have been applied properly.

Required Skills for Successful Exploitation

First and foremost, attacker needs either physical access or user-level code execution rights for successful exploitation. Dumping all data from a browser can be fairly easy, and a number of automated tools exist to undertake this. Where the attacker cannot dump the data, he/she could still browse the recently visited websites and activate the autocomplete feature to see previously entered values.

CLASSIFICATION

OWASP 2013	A5
OWASP 2017	A6
CWE	16
WASC	15
ASVS 4.0	2.10.3
NIST SP 800-53	AC-16
DISA STIG	V-16786
ISO27001	A.14.1.2
ISO27001 2022	A.5.34
ISO27001 2022	A.8.3
OWASP Top Ten 2021	A05

7. Cookie Not Marked as HttpOnly

LOW | 1 | CONFIRMED | 1

Invicti Standard identified a cookie not marked as HTTPOnly.

HTTPOnly cookies cannot be read by client-side scripts, therefore marking a cookie as HTTPOnly can provide an additional layer of protection against cross-site scripting attacks.

Impact

During a cross-site scripting attack, an attacker might easily access cookies and hijack the victim's session.

Vulnerabilities

7.1. http://150.1.7.104/dvwa/login.php

CONFIRMED

Identified Cookie(s)

- security
- PHPSESSID

Request | Response

Request

```
GET /dvwa/login.php HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 172.7328
Total Bytes Received : 1710
Body Length : 1289
Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie: PHPSESSID=**************; path=/
Set-Cookie: security=high
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Pragma: no-cache
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Keep-Alive: timeout=15, max=100
Content-Length: 1289
Connection: Keep-Alive
Content-Type: text/html;charset=utf-8
Date: Fri, 27 Mar 2026 19:53:45 GMT
Cache-Control: no-cache, must-revalidate
```

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">

<head>

<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

<title>Damn Vulnerable Web App (DVWA) - Login</title>

<link rel="stylesheet" type="text/css" href="dvwa/css/login.css" />

</head>

<body>

<div align="center">

<br />

<p><img src="dvwa/images/login_logo.png" /></p>

<br />

<form action="login.php" method="post">

<fieldset>
```

```
<label for="user">Username</label> <input type="text" class="loginInput" size="20" name="username"><br
/>


<label for="pass">Password</label> <input type="password" class="loginInput" AUTOCOMPLETE="off"
size="20" name="password"><br />


<p class="submit"><input type="submit" value="Login" name="Login"></p>

</fieldset>

</form>


<br />



<br />
<br />
<br />
<br />
<br />
<br />
<br />
<br />

<!-- <img src="dvwa/images/RandomStorm.png" /> -->

<p>Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project</p>
<p>Hint: default username is 'admin' with password 'password' </p>
</div> <!-- end align div -->

</body>

</html>
```

Actions to Take

1. See the remedy for solution.
2. Consider marking all of the cookies used by the application as HTTPOnly. (*After these changes javascript code will not be able to read cookies.*)

Remedy

Mark the cookie as HTTPOnly. This will be an extra layer of defense against XSS. However this is not a silver bullet and will not protect the system against cross-site scripting attacks. An attacker can use a tool such as [XSS Tunnel]() to bypass HTTPOnly protection.

External References

- [Invicti Standard - Security Cookies - HTTPOnly Flag]()
- [OWASP HTTPOnly Cookies]()

- MSDN - ASP.NET HTTPOnly Cookies

CLASSIFICATION

OWASP 2013	A5
OWASP 2017	A6
CWE	16
CAPEC	107
WASC	15
ASVS 4.0	3.4.2
NIST SP 800-53	AC-16
DISA STIG	V-16786
OWASP API Top Ten 2019	API7
ISO27001	A.14.2.5
ISO27001 2022	A.8.27
OWASP Top Ten 2021	A05
OWASP API Top 10 2023	API8

8. Internal Server Error

LOW 1 | CONFIRMED 1

Invicti Standard identified an internal server error.

The server responded with an HTTP status 500, indicating there is a server-side error. Reasons may vary, and the behavior should be analyzed carefully. If Invicti Standard is able to find a security issue in the same resource, it will report this as a separate vulnerability.

Impact

The impact may vary depending on the condition. Generally this indicates poor coding practices, not enough error checking, sanitization and whitelisting. However, there might be a bigger issue, such as SQL injection. If that's the case, Invicti Standard will check for other possible issues and report them separately.
While the body content of the error page may not expose any information about the technical error, knowing whether certain inputs trigger a server error can aid or inform an attacker on potential vulnerabilities.

Vulnerabilities

8.1. http://150.1.7.104/dvwa/dvwa/includes/DBMS/PGSQL.php

CONFIRMED

Request | Response

Request

```
GET /dvwa/dvwa/includes/DBMS/PGSQL.php HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: security=high; PHPSESSID=**************
Referer: http://150.1.7.104/dvwa/dvwa/includes/DBMS/
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 14.1225
Total Bytes Received : 212
Body Length : 0
Is Compressed : No

```
HTTP/1.1 500 Internal Server Error

Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Connection: close
Content-Length: 0
Content-Type: text/html
Date: Fri, 27 Mar 2026 19:57:00 GMT
```

Remedy

Analyze this issue and review the application code in order to handle unexpected errors; this should be a generic practice, which does not disclose further information upon an error. All errors should be handled server-side only.

CLASSIFICATION

CWE	550
WASC	13
NIST SP 800-53	SI-11
DISA STIG	V-6166
ISO27001	A.14.1.2
ISO27001 2022	A.8.15
ISO27001 2022	A.8.26
ISO27001 2022	A.8.27

9. Missing X-Content-Type-Options Header

LOW | 1

Invicti Standard detected a missing X-Content-Type-Options header which means that this website could be at risk of a MIME-sniffing attacks.

Impact

MIME type sniffing is a standard functionality in browsers to find an appropriate way to render data where the HTTP headers sent by the server are either inconclusive or missing.

This allows web browsers such as Google Chrome to perform MIME-Sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the intended content type.

The problem arises once a website allows users to upload content which is then published on the web server. If an attacker can carry out XSS (Cross-site Scripting) attack by manipulating the content in a way to be accepted by the web application and rendered as HTML by the browser, it is possible to inject code in e.g. an image file and make the victim execute it by viewing the image.

Vulnerabilities

9.1. http://150.1.7.104/dvwa/login.php

Certainty

Request | Response

Request

```
GET /dvwa/login.php HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 172.7328
Total Bytes Received : 1710
Body Length : 1289
Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie: PHPSESSID=**************; path=/
Set-Cookie: security=high
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Pragma: no-cache
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Keep-Alive: timeout=15, max=100
Content-Length: 1289
Connection: Keep-Alive
Content-Type: text/html;charset=utf-8
Date: Fri, 27 Mar 2026 19:53:45 GMT
Cache-Control: no-cache, must-revalidate
```

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">

<head>

<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

<title>Damn Vulnerable Web App (DVWA) - Login</title>

<link rel="stylesheet" type="text/css" href="dvwa/css/login.css" />

</head>

<body>

<div align="center">

<br />

<p><img src="dvwa/images/login_logo.png" /></p>

<br />

<form action="login.php" method="post">

<fieldset>
```

```
<label for="user">Username</label> <input type="text" class="loginInput" size="20" name="username"><br
/>


<label for="pass">Password</label> <input type="password" class="loginInput" AUTOCOMPLETE="off"
size="20" name="password"><br />


<p class="submit"><input type="submit" value="Login" name="Login"></p>

</fieldset>

</form>


<br />



<br />
<br />
<br />
<br />
<br />
<br />
<br />
<br />

<!-- <img src="dvwa/images/RandomStorm.png" /> -->

<p>Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project</p>
<p>Hint: default username is 'admin' with password 'password' </p>
</div> <!-- end align div -->

</body>

</html>
```

Remedy

Add the X-Content-Type-Options header with a value of "nosniff" to inform the browser to trust what the site has sent is the appropriate content-type, and to not attempt "sniffing" the real content-type.

```
X-Content-Type-Options: nosniff
```

External References

- [X-Content-Type-Options HTTP Header]

CLASSIFICATION

OWASP 2013	A5
OWASP 2017	A6
CWE	16
WASC	15
ASVS 4.0	14.4.1
NIST SP 800-53	CM-6
DISA STIG	V-16786
OWASP API Top Ten 2019	API7
ISO27001	A.14.1.2
ISO27001 2022	A.8.27
OWASP Top Ten 2021	A05
OWASP API Top 10 2023	API8

10. Programming Error Message

LOW | 1

Invicti Standard identified a Programming Error Message.

Impact

The error message may disclose sensitive information and this information can be used by an attacker to mount new attacks or to enlarge the attack surface. Source code, stack trace, etc. data may be disclosed. Most of these issues will be identified and reported separately by Invicti Standard.

Vulnerabilities

10.1. http://150.1.7.104/dvwa/dvwa/includes/dvwaPage.inc.php

Identified Error Message

- Warning: Wrong parameter count for define() in /var/www/dvwa/dvwa/includes/dvwaPage.inc.php on line 5

Certainty

Request | Response

Request

```
GET /dvwa/dvwa/includes/dvwaPage.inc.php HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: security=high; PHPSESSID=**************
Referer: http://150.1.7.104/dvwa/dvwa/includes/
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 0
Total Bytes Received : 313
Body Length : 137
Is Compressed : No

```
HTTP/1.1 200 OK
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Content-Length: 137
Content-Type: text/html
Date: Fri, 27 Mar 2026 19:55:49 GMT

<br />
<b>Warning</b>: Wrong parameter count for define() in
<b>/var/www/dvwa/dvwa/includes/dvwaPage.inc.php</b> on line <b>5</b><br />
```

Remedy

Do not provide error messages on production environments. Save error messages with a reference number to a backend storage such as a log, text file or database, then show this number and a static user-friendly error message to the user.

CLASSIFICATION

PCI DSS v3.2	6.5.5
PCI DSS v4.0	6.2.4
OWASP 2013	A5
OWASP 2017	A6
CWE	210
CAPEC	118
WASC	13
HIPAA	164.306(a) , 164.308(a)
ASVS 4.0	7.4.1
NIST SP 800-53	SI-11
DISA STIG	V-6166
OWASP API Top Ten 2019	API7
ISO27001	A.18.1.3
ISO27001 2022	A.8.15
ISO27001 2022	A.8.9
OWASP Top Ten 2021	A05

OWASP API Top 10 2023	API8

11. TRACE/TRACK Method Detected

LOW 1 | CONFIRMED 1

Invicti Standard detected the TRACE/TRACK method is allowed.

Impact

It is possible to bypass the HttpOnly cookie limitation and read the cookies in a cross-site scripting attack by using the TRACE/TRACK method within an XmlHttpRequest. This is not possible with modern browsers, so the vulnerability can only be used when targeting users with unpatched and old browsers.

Vulnerabilities

11.1. http://150.1.7.104/dvwa/

CONFIRMED

Method	Parameter	Parameter Type	Value
TRACE	URI-BASED	FullUrl	

Request | Response

Request

```
TRACE /dvwa/ HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: security=high; PHPSESSID=**************
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
X-NS: N11699557S
```

Response

Response Time (ms) : 2.0233
Total Bytes Received : 1019
Body Length : 444
Is Compressed : No

```
HTTP/1.1 200 OK
Server: Apache/2.2.8 (Ubuntu) DAV/2
Content-Type: message/http
Transfer-Encoding: chunked
Date: Fri, 27 Mar 2026 19:55:49 GMT

TRACE /dvwa/ HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
X-NS: N11699557S
Cookie: security=high; PHPSESSID=**************
Host: 150.1.7.104
Accept-Encoding: gzip, deflate
```

Remedy

Disable this method in all production systems. Even though the application is not vulnerable to cross-site scripting, a debugging feature such as TRACE/TRACK should not be required in a production system and therefore should be disabled.

External References

- Cross Site Tracing
- Web Servers Enable HTTP TRACE Method by Default

CLASSIFICATION

OWASP 2013	A5
OWASP 2017	A6
CWE	16
CAPEC	107
WASC	14
ASVS 4.0	14.5.1
NIST SP 800-53	AC-6
DISA STIG	V-16814
OWASP API Top Ten 2019	API7
ISO27001	A.14.1.2
ISO27001 2022	A.8.27
OWASP Top Ten 2021	A05
OWASP API Top 10 2023	API8

12. Version Disclosure (Apache)

LOW | 1

Invicti Standard identified a version disclosure (Apache) in the target web server's HTTP response.

This information might help an attacker gain a greater understanding of the systems in use and potentially develop further attacks targeted at the specific version of Apache.

Impact

An attacker might use the disclosed information to harvest specific security vulnerabilities for the version identified.

Vulnerabilities

12.1. http://150.1.7.104/dvwa/login.php

Extracted Version

- 2.2.8

Certainty

Request | Response

Request

```
GET /dvwa/login.php HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 172.7328
Total Bytes Received : 1710
Body Length : 1289
Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie: PHPSESSID=**************; path=/
Set-Cookie: security=high
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Pragma: no-cache
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Keep-Alive: timeout=15, max=100
Content-Length: 1289
Connection: Keep-Alive
Content-Type: text/html;charset=utf-8
Date: Fri, 27 Mar 2026 19:53:45 GMT
Cache-Control: no-cache, must-revalidate
```

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">

<head>

<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

<title>Damn Vulnerable Web App (DVWA) - Login</title>

<link rel="stylesheet" type="text/css" href="dvwa/css/login.css" />

</head>

<body>

<div align="center">

<br />

<p><img src="dvwa/images/login_logo.png" /></p>

<br />

<form action="login.php" method="post">

<fieldset>
```

```
<label for="user">Username</label> <input type="text" class="loginInput" size="20" name="username"><br />


<label for="pass">Password</label> <input type="password" class="loginInput" AUTOCOMPLETE="off" size="20" name="password"><br />


<p class="submit"><input type="submit" value="Login" name="Login"></p>

</fieldset>

</form>


<br />



<br />
<br />
<br />
<br />
<br />
<br />
<br />
<br />

<!-- <img src="dvwa/images/RandomStorm.png" /> -->

<p>Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project</p>
<p>Hint: default username is 'admin' with password 'password' </p>
</div> <!-- end align div -->

</body>

</html>
```

Remedy

Configure your web server to prevent information leakage from the `SERVER`header of its HTTP response.

Remedy References

- [Apache ServerTokens Directive]

CLASSIFICATION

OWASP 2013	A5
OWASP 2017	A6
CWE	205
CAPEC	170
WASC	13
HIPAA	164.306(a) , 164.308(a)
ASVS 4.0	14.3.3
NIST SP 800-53	AC-22
DISA STIG	V-16814
OWASP API Top Ten 2019	API7
OWASP Proactive Controls	N/A
ISO27001	A.18.1.3
ISO27001 2022	A.8.27
OWASP Top Ten 2021	A05
OWASP API Top 10 2023	API8

13. Version Disclosure (PHP)

LOW | 1

Invicti Standard identified a version disclosure (PHP) in the target web server's HTTP response.

This information can help an attacker gain a greater understanding of the systems in use and potentially develop further attacks targeted at the specific version of PHP.

Impact

An attacker might use the disclosed information to harvest specific security vulnerabilities for the version identified.

Vulnerabilities

13.1. http://150.1.7.104/dvwa/login.php

Extracted Version

- 5.2.4

Certainty

Request | Response

Request

```
GET /dvwa/login.php HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 172.7328
Total Bytes Received : 1710
Body Length : 1289
Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie: PHPSESSID=**************; path=/
Set-Cookie: security=high
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Pragma: no-cache

Expires: Tue, 23 Jun 2009 12:00:00 GMT
Keep-Alive: timeout=15, max=100
Content-Length: 1289
Connection: Keep-Alive
Content-Type: text/html;charset=utf-8
Date: Fri, 27 Mar 2026 19:53:45 GMT
Cache-Control: no-cache, must-revalidate
```

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">

<head>

<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

<title>Damn Vulnerable Web App (DVWA) - Login</title>

<link rel="stylesheet" type="text/css" href="dvwa/css/login.css" />

</head>

<body>

<div align="center">

<br />

<p><img src="dvwa/images/login_logo.png" /></p>

<br />

<form action="login.php" method="post">
```

```
<fieldset>

<label for="user">Username</label> <input type="text" class="loginInput" size="20" name="username"><br />


<label for="pass">Password</label> <input type="password" class="loginInput" AUTOCOMPLETE="off" size="20" name="password"><br />


<p class="submit"><input type="submit" value="Login" name="Login"></p>

</fieldset>

</form>


<br />



<br />
<br />
<br />
<br />
<br />
<br />
<br />
<br />

<!-- <img src="dvwa/images/RandomStorm.png" /> -->

<p>Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project</p>
<p>Hint: default username is 'admin' with password 'password' </p>
</div> <!-- end align div -->

</body>

</html>
```

Remedy

Configure your web server to prevent information leakage from the `SERVER`header of its HTTP response.

CLASSIFICATION

OWASP 2013	A5
OWASP 2017	A6
CWE	205
CAPEC	170
WASC	13
HIPAA	164.306(a) , 164.308(a)
ASVS 4.0	14.3.3
NIST SP 800-53	AC-22
DISA STIG	V-16814
OWASP API Top Ten 2019	API7
ISO27001	A.18.1.3
ISO27001 2022	A.8.27
OWASP Top Ten 2021	A05
OWASP API Top 10 2023	API8

14. Content Security Policy (CSP) Not Implemented

BEST PRACTICE | 1 CONFIRMED | 1

CSP is an added layer of security that helps to mitigate mainly Cross-site Scripting attacks.

CSP can be enabled instructing the browser with a Content-Security-Policy directive in a response header;

```
Content-Security-Policy: script-src 'self';
```

or in a meta tag;

```
<meta http-equiv="Content-Security-Policy" content="script-src 'self';">
```

In the above example, you can restrict script loading only to the same domain. It will also restrict inline script executions both in the element attributes and the event handlers. There are various directives which you can use by declaring CSP:

- **script-src:**Restricts the script loading resources to the ones you declared. By default, it disables inline script executions unless you permit to the evaluation functions and inline scripts by the unsafe-eval and unsafe-inline keywords.
- **base-uri:**The base element is used to resolve a relative URL to an absolute one. By using this CSP directive, you can define all possible URLs which could be assigned to the base-href attribute of the document.
- **frame-ancestors**: It is very similar to X-Frame-Options HTTP header. It defines the URLs by which the page can be loaded in an iframe.
- **frame-src / child-src**: frame-src is the deprecated version of child-src. Both define the sources that can be loaded by iframe on the page. (Please note that frame-src was brought back in CSP 3)
- **object-src**: Defines the resources that can be loaded by embedding such as Flash files, Java Applets.
- **img-src**: As its name implies, it defines the resources where the images can be loaded from.
- **connect-src**: Defines the whitelisted targets for XMLHttpRequest and WebSocket objects.
- **default-src**: It is a fallback for the directives that mostly end with -src suffix. When the directives below are not defined, the value set to default-src will be used instead:
    - child-src
    - connect-src
    - font-src
    - img-src
    - manifest-src
    - media-src
    - object-src
    - script-src
    - style-src

When setting the CSP directives, you can also use some CSP keywords:

- **none**: Denies loading resources from anywhere.
- **self** : Points to the document's URL (domain + port).
- **unsafe-inline**: Permits running inline scripts.
- **unsafe-eval**: Permits execution of evaluation functions such as eval().

In addition to CSP keywords, you can also use wildcard or only a scheme when defining whitelist URLs for the points. Wildcard can be used for subdomain and port portions of the URLs:

```
Content-Security-Policy: script-src https://*.example.com;
Content-Security-Policy: script-src https://example.com:*;
Content-Security-Policy: script-src https:;
```

It is also possible to set a CSP in Report-Only mode instead of forcing it immediately in the migration period. Thus you can see the violations of the CSP policy in the current state of your web site while migrating to CSP:

```
Content-Security-Policy-Report-Only: script-src 'self'; report-uri: https://example.com;
```

Impact

There is no direct impact of not implementing CSP on your website. However, if your website is vulnerable to a Cross-site Scripting attack CSP can prevent successful exploitation of that vulnerability. By not implementing CSP you'll be missing out on this extra layer of security.

Vulnerabilities

14.1. http://150.1.7.104/dvwa/login.php

CONFIRMED

Request | Response

Request

```
GET /dvwa/login.php HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 172.7328
Total Bytes Received : 1710
Body Length : 1289
Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie: PHPSESSID=**************; path=/
Set-Cookie: security=high
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Pragma: no-cache
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Keep-Alive: timeout=15, max=100
Content-Length: 1289
Connection: Keep-Alive
Content-Type: text/html;charset=utf-8
Date: Fri, 27 Mar 2026 19:53:45 GMT
Cache-Control: no-cache, must-revalidate
```

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">

<head>

<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

<title>Damn Vulnerable Web App (DVWA) - Login</title>

<link rel="stylesheet" type="text/css" href="dvwa/css/login.css" />

</head>

<body>

<div align="center">

<br />

<p><img src="dvwa/images/login_logo.png" /></p>

<br />

<form action="login.php" method="post">

<fieldset>
```

```
<label for="user">Username</label> <input type="text" class="loginInput" size="20" name="username"><br />


<label for="pass">Password</label> <input type="password" class="loginInput" AUTOCOMPLETE="off" size="20" name="password"><br />


<p class="submit"><input type="submit" value="Login" name="Login"></p>

</fieldset>

</form>


<br />



<br />
<br />
<br />
<br />
<br />
<br />
<br />
<br />

<!-- <img src="dvwa/images/RandomStorm.png" /> -->

<p>Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project</p>
<p>Hint: default username is 'admin' with password 'password' </p>
</div> <!-- end align div -->

</body>

</html>
```

Actions to Take

- Enable CSP on your website by sending the `Content-Security-Policy`in HTTP response headers that instruct the browser to apply the policies you specified.
- Apply the whitelist and policies as strict as possible.
- Rescan your application to see if Invicti Standard identifies any weaknesses in your policies.

Remedy

Enable CSP on your website by sending the `Content-Security-Policy`in HTTP response headers that instruct the browser to apply the policies you specified.

External References

- [An Introduction to Content Security Policy]

- Content Security Policy (CSP) HTTP Header
- Content Security Policy (CSP)

CLASSIFICATION

CWE	16
WASC	15
ASVS 4.0	14.4.3
NIST SP 800-53	CM-6
DISA STIG	V-16786
ISO27001	A.14.2.5
ISO27001 2022	A.8.27

15. Referrer-Policy Not Implemented

BEST PRACTICE | 1

Invicti Standard detected that no Referrer-Policy header implemented.

Referrer-Policy is a security header designed to prevent cross-domain Referer leakage.

Impact

Referer header is a request header that indicates the site which the traffic originated from. If there is no adequate prevention in place, the URL itself, and even sensitive information contained in the URL will be leaked to the cross-site.

The lack of Referrer-Policy header might affect privacy of the users and site's itself

Vulnerabilities

15.1. http://150.1.7.104/dvwa/login.php

Certainty

Request | Response

Request

```
GET /dvwa/login.php HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 172.7328
Total Bytes Received : 1710
Body Length : 1289
Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie: PHPSESSID=**************; path=/
Set-Cookie: security=high
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Pragma: no-cache
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Keep-Alive: timeout=15, max=100
Content-Length: 1289
Connection: Keep-Alive
Content-Type: text/html;charset=utf-8
Date: Fri, 27 Mar 2026 19:53:45 GMT
Cache-Control: no-cache, must-revalidate
```

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">

<head>

<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

<title>Damn Vulnerable Web App (DVWA) - Login</title>

<link rel="stylesheet" type="text/css" href="dvwa/css/login.css" />

</head>

<body>

<div align="center">

<br />

<p><img src="dvwa/images/login_logo.png" /></p>

<br />

<form action="login.php" method="post">

<fieldset>
```

```
<label for="user">Username</label> <input type="text" class="loginInput" size="20" name="username"><br />


<label for="pass">Password</label> <input type="password" class="loginInput" AUTOCOMPLETE="off" size="20" name="password"><br />


<p class="submit"><input type="submit" value="Login" name="Login"></p>

</fieldset>

</form>


<br />



<br />
<br />
<br />
<br />
<br />
<br />
<br />
<br />

<!-- <img src="dvwa/images/RandomStorm.png" /> -->

<p>Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project</p>
<p>Hint: default username is 'admin' with password 'password' </p>
</div> <!-- end align div -->

</body>

</html>
```

Actions to Take

In a response header:

```
Referrer-Policy: no-referrer | same-origin | origin | strict-origin | no-origin-when-downgrading
```

In a META tag

```
<meta name="Referrer-Policy" value="no-referrer | same-origin"/>
```

In an element attribute

```
<a href="http://crosssite.example.com" rel="noreferrer"></a>
```

or

```
<a href="http://crosssite.example.com" referrerpolicy="no-referrer | same-origin | origin | strict-origin | no-origin-when-downgrading"></a>
```

Remedy

Please implement a Referrer-Policy by using the Referrer-Policy response header or by declaring it in the meta tags. It's also possible to control referrer information over an HTML-element by using the rel attribute.

External References

- Referrer Policy
- Referrer Policy - MDN
- Referrer Policy HTTP Header
- A New Security Header: Referrer Policy
- Can I Use Referrer-Policy

CLASSIFICATION

OWASP 2013	A6
OWASP 2017	A3
CWE	200
ASVS 4.0	14.4.6
NIST SP 800-53	AC-22
DISA STIG	V-16814
ISO27001	A.14.2.5
ISO27001 2022	A.8.27

16. SameSite Cookie Not Implemented

BEST PRACTICE | 1

Cookies are typically sent to third parties in cross origin requests. This can be abused to do CSRF attacks. Recently a new cookie attribute named *SameSite*was proposed to disable third-party usage for some cookies, to prevent CSRF attacks.

Same-site cookies allow servers to mitigate the risk of CSRF and information leakage attacks by asserting that a particular cookie should only be sent with requests initiated from the same registrable domain.

Vulnerabilities

16.1. http://150.1.7.104/dvwa/login.php

Identified Cookie(s)

- security
- PHPSESSID

Certainty

Request | Response

Request

```
GET /dvwa/login.php HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 172.7328
Total Bytes Received : 1710
Body Length : 1289
Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie: PHPSESSID=**************; path=/
Set-Cookie: security=high
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Pragma: no-cache
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Keep-Alive: timeout=15, max=100
Content-Length: 1289
Connection: Keep-Alive
Content-Type: text/html;charset=utf-8
Date: Fri, 27 Mar 2026 19:53:45 GMT
Cache-Control: no-cache, must-revalidate
```

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">

<head>

<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

<title>Damn Vulnerable Web App (DVWA) - Login</title>

<link rel="stylesheet" type="text/css" href="dvwa/css/login.css" />

</head>

<body>

<div align="center">

<br />

<p><img src="dvwa/images/login_logo.png" /></p>

<br />

<form action="login.php" method="post">

<fieldset>
```

```
<label for="user">Username</label> <input type="text" class="loginInput" size="20" name="username"><br
/>


<label for="pass">Password</label> <input type="password" class="loginInput" AUTOCOMPLETE="off"
size="20" name="password"><br />


<p class="submit"><input type="submit" value="Login" name="Login"></p>

</fieldset>

</form>


<br />



<br />
<br />
<br />
<br />
<br />
<br />
<br />
<br />

<!-- <img src="dvwa/images/RandomStorm.png" /> -->

<p>Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project</p>
<p>Hint: default username is 'admin' with password 'password' </p>
</div> <!-- end align div -->

</body>

</html>
```

Remedy

The server can set a same-site cookie by adding the `SameSite=...`attribute to the `Set-Cookie`header. There are three possible values for the `SameSite`attribute:

- Lax:In this mode, the cookie will only be sent with a top-level get request.

  ```
  Set-Cookie: key=value; SameSite=Lax
  ```

- Strict: In this mode, the cookie will not be sent with any cross-site usage even if the user follows a link to another website.

```
Set-Cookie: key=value; SameSite=Strict
```

- None: In this mode, the cookie will be sent with the cross-site requests. Cookies with `SameSite=None`must also specify the `Secure`attribute to transfer them via a secure context. Setting a `SameSite=None`cookie without the `Secure`attribute will be rejected by the browsers.

```
Set-Cookie: key=value; SameSite=None; Secure
```

External References

- Security Cookies - SameSite Attribute - Invicti Standard
- Using the Same-Site Cookies Attribute to Prevent CSRF Attacks
- Same-site Cookies
- Preventing CSRF with the same-site cookie attribute
- SameSite cookies explained
- Get Ready for New SameSite=None; Secure Cookie Settings

CLASSIFICATION

CWE	16
WASC	15
ASVS 4.0	3.4.3
NIST SP 800-53	CM-6
DISA STIG	V-16786
ISO27001	A.14.2.5
ISO27001 2022	A.8.27

17. [Possible] Internal Path Disclosure (*nix)

INFORMATION | 1

Invicti Standard identified a Possible Internal Path Disclosure (*nix) in the document.

Impact

There is no direct impact; however, this information can help an attacker identify other vulnerabilities or help during the exploitation of other identified vulnerabilities.

Vulnerabilities

17.1. http://150.1.7.104/dvwa/dvwa/includes/dvwaPage.inc.php

Identified Internal Path(s)

- /var/www/dvwa/dvwa/includes/dvwaPage.inc.php

Certainty

Request | Response

Request

```
GET /dvwa/dvwa/includes/dvwaPage.inc.php HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: security=high; PHPSESSID=**************
Referer: http://150.1.7.104/dvwa/dvwa/includes/
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 0
Total Bytes Received : 313
Body Length : 137
Is Compressed : No

```
HTTP/1.1 200 OK
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Content-Length: 137
Content-Type: text/html
Date: Fri, 27 Mar 2026 19:55:49 GMT

<br />
<b>Warning</b>: Wrong parameter count for define() in
<b>/var/www/dvwa/dvwa/includes/dvwaPage.inc.php</b> on line <b>5</b><br />
```

External References

- OWASP - Full Path Disclosure

CLASSIFICATION

OWASP 2017	A6
CWE	200
CAPEC	118
WASC	13
HIPAA	164.306(a) , 164.308(a)
ASVS 4.0	12.5.1
NIST SP 800-53	AC-22
DISA STIG	V-16814
OWASP API Top Ten 2019	API7
OWASP Proactive Controls	C7
ISO27001	A.9.4.1
ISO27001 2022	A.8.27
OWASP Top Ten 2021	A05
OWASP API Top 10 2023	API3

18. [Possible] Login Page Identified

INFORMATION | 1

Invicti Standard identified a login page on the target website.

Impact

This issue is reported as additional information only. There is no direct impact arising from this issue.

Vulnerabilities

18.1. http://150.1.7.104/dvwa/login.php

form.action

- login.php

window.location.pathname

- /dvwa/login.php

input.name

- username

Certainty

Request | Response

Request

```
GET /dvwa/login.php HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 172.7328
Total Bytes Received : 1710
Body Length : 1289
Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie: PHPSESSID=**************; path=/
Set-Cookie: security=high
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Pragma: no-cache
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Keep-Alive: timeout=15, max=100
Content-Length: 1289
Connection: Keep-Alive
Content-Type: text/html;charset=utf-8
Date: Fri, 27 Mar 2026 19:53:45 GMT
Cache-Control: no-cache, must-revalidate
```

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">

<head>

<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

<title>Damn Vulnerable Web App (DVWA) - Login</title>

<link rel="stylesheet" type="text/css" href="dvwa/css/login.css" />

</head>

<body>

<div align="center">

<br />

<p><img src="dvwa/images/login_logo.png" /></p>

<br />

<form action="login.php" method="post">

<fieldset>
```

```
<label for="user">Username</label> <input type="text" class="loginInput" size="20" name="username"><br
/>


<label for="pass">Password</label> <input type="password" class="loginInput" AUTOCOMPLETE="off"
size="20" name="password"><br />


<p class="submit"><input type="submit" value="Login" name="Login"></p>

</fieldset>

</form>


<br />



<br />
<br />
<br />
<br />
<br />
<br />
<br />
<br />

<!-- <img src="dvwa/images/RandomStorm.png" /> -->

<p>Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project</p>
<p>Hint: default username is 'admin' with password 'password' </p>
</div> <!-- end align div -->

</body>

</html>
```

CLASSIFICATION

OWASP Proactive Controls	C6

19. Apache Web Server Identified

INFORMATION | 1

Invicti Standard identified a web server (Apache) in the target web server's HTTP response.

Impact

This issue is reported as additional information only. There is no direct impact arising from this issue.

Vulnerabilities

19.1. http://150.1.7.104/dvwa/login.php

Certainty

Request | Response

Request

```
GET /dvwa/login.php HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 172.7328
Total Bytes Received : 1710
Body Length : 1289
Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie: PHPSESSID=**************; path=/
Set-Cookie: security=high
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Pragma: no-cache
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Keep-Alive: timeout=15, max=100
Content-Length: 1289
Connection: Keep-Alive
Content-Type: text/html;charset=utf-8
Date: Fri, 27 Mar 2026 19:53:45 GMT
Cache-Control: no-cache, must-revalidate
```

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">

<head>

<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

<title>Damn Vulnerable Web App (DVWA) - Login</title>

<link rel="stylesheet" type="text/css" href="dvwa/css/login.css" />

</head>

<body>

<div align="center">

<br />

<p><img src="dvwa/images/login_logo.png" /></p>

<br />

<form action="login.php" method="post">

<fieldset>
```

```
<label for="user">Username</label> <input type="text" class="loginInput" size="20" name="username"><br
/>


<label for="pass">Password</label> <input type="password" class="loginInput" AUTOCOMPLETE="off"
size="20" name="password"><br />


<p class="submit"><input type="submit" value="Login" name="Login"></p>

</fieldset>

</form>


<br />



<br />
<br />
<br />
<br />
<br />
<br />
<br />
<br />

<!-- <img src="dvwa/images/RandomStorm.png" /> -->

<p>Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project</p>
<p>Hint: default username is 'admin' with password 'password' </p>
</div> <!-- end align div -->

</body>

</html>
```

External References

- [Apache ServerTokens Directive]

CLASSIFICATION

OWASP 2017	A6
CWE	205
WASC	13
ASVS 4.0	14.3.3
NIST SP 800-53	AC-22
DISA STIG	V-16814
OWASP API Top Ten 2019	API7
OWASP Proactive Controls	C7
ISO27001	A.14.2.5
OWASP Top Ten 2021	A05
OWASP API Top 10 2023	API8

CVSS 3.0 SCORE

Base	5.3 (Medium)
Temporal	5.1 (Medium)
Environmental	5.1 (Medium)

CVSS Vector String

CVSS Vector String
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N/E:H/RL:O/RC:C

CVSS 3.1 SCORE	
Base	5.3 (Medium)
Temporal	5.1 (Medium)
Environmental	5.1 (Medium)

CVSS Vector String
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N/E:H/RL:O/RC:C

20. Directory Listing (Apache)

INFORMATION | 1

Invicti Standard identified a Directory Listing (Apache).

The web server responded with a list of files located in the target directory.

Impact

An attacker can see the files located in the directory and could potentially access files which disclose sensitive information.

Vulnerabilities

20.1. http://150.1.7.104/dvwa/dvwa/

Certainty

Request | Response

Request

```
GET /dvwa/dvwa/ HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: security=high; PHPSESSID=**************
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 0
Total Bytes Received : 1573
Body Length : 1419
Is Compressed : No

```
HTTP/1.1 200 OK
Server: Apache/2.2.8 (Ubuntu) DAV/2
Content-Length: 1419
Content-Type: text/html;charset=UTF-8
Date: Fri, 27 Mar 2026 19:54:10 GMT

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN">
<html>
<head>
<title>Index of /dvwa/dvwa</title>
</head>
<body>
<h1>Index of /dvwa/dvwa</h1>
<table><tr><th><img src="/icons/blank.gif" alt="[ICO]"></th><th><a href="?C=N;O=D">Name</a></th><th><a
href="?C=M;O=A">Last modified</a></th><th><a href="?C=S;O=A">Size</a></th><th><a href="?
C=D;O=A">Description</a></th></tr><tr><th colspan="5"><hr></th></tr>
<tr><td valign="top"><img src="/icons/back.gif" alt="[DIR]"></td><td><a href="/dvwa/">Parent
Directory</a></td><td> </td><td align="right">  - </td></tr>
<tr><td valign="top"><img src="/icons/folder.gif" alt="[DIR]"></td><td><a href="css/">css/</a></td><td
align="right">20-May-2012 15:22  </td><td align="right">  - </td></tr>
<tr><td valign="top"><img src="/icons/folder.gif" alt="[DIR]"></td><td><a href="images/">images/</a>
</td><td align="right">20-May-2012 15:22  </td><td align="right">  - </td></tr>
<tr><td valign="top"><img src="/icons/folder.gif" alt="[DIR]"></td><td><a
href="includes/">includes/</a></td><td align="right">20-May-2012 15:22  </td><td align="right">  - </td>
</tr>
<tr><td valign="top"><img src="/icons/folder.gif" alt="[DIR]"></td><td><a href="js/">js/</a></td><td
align="right">20-May-2012 15:22  </td><td align="right">  - </td></tr>
<tr><th colspan="5"><hr></th></tr>
</table>
<address>Apache/2.2.8 (Ubuntu) DAV/2 Server at 150.1.7.104 Port 80</address>
</body></html>
```

Actions to Take

1. Change your server configuration file. A recommended configuration for the requested directory should be in the following format:

```
<Directory /{YOUR DIRECTORY}>
        Options FollowSymLinks
</Directory>
```

Remove the *Indexes*option from configuration. Do not forget to remove *MultiViews*as well.
2. Configure the web server to disallow directory listing requests.
3. Ensure that the latest security patches have been applied to the web server and the current stable version of the software is in use.

External References

- WASC - Directory Indexing
- NVD - Apache Directory Indexing

CLASSIFICATION

OWASP 2013	A5
OWASP 2017	A6
CWE	548
CAPEC	127
WASC	16
ASVS 4.0	4.3.2
NIST SP 800-53	SC-4
DISA STIG	V-6141
OWASP API Top Ten 2019	API7
OWASP Proactive Controls	C6
ISO27001	A.9.4.1
ISO27001 2022	A.8.9
OWASP Top Ten 2021	A05
OWASP API Top 10 2023	API8

CVSS 3.0 SCORE

Base	5.3 (Medium)

CVSS 3.0 SCORE

Temporal	5.1 (Medium)
Environmental	5.1 (Medium)

CVSS Vector String

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N/E:H/RL:O/RC:C

CVSS 3.1 SCORE

Base	5.3 (Medium)
Temporal	5.1 (Medium)
Environmental	5.1 (Medium)

CVSS Vector String

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N/E:H/RL:O/RC:C

21. Email Address Disclosure

INFORMATION | 1

Invicti Standard identified an Email Address Disclosure.

Impact

Email addresses discovered within the application can be used by both spam email engines and also brute-force tools. Furthermore, valid email addresses may lead to social engineering attacks.

Vulnerabilities

21.1. http://150.1.7.104/dvwa/login.php@r87.com

Method	Parameter	Parameter Type	Value
GET	URI-BASED	FullUrl	`@r87.com`

Email Address(es)

- login.php@r87.com

Certainty

Remedy

Use generic email addresses such as contact@ or info@ for general communications and remove user/people-specific email addresses from the website; should this be required, use submission forms for this purpose.

External References

- Wikipedia - Email Spam

CLASSIFICATION

CWE	200
CAPEC	118
WASC	13
ASVS 4.0	14.3.3
NIST SP 800-53	AC-22
DISA STIG	V-16814
OWASP Proactive Controls	C7
ISO27001	A.9.4.1
ISO27001 2022	A.8.3

CVSS 3.0 SCORE	
Base	0 (None)
Temporal	0 (None)
Environmental	0 (None)

CVSS Vector String
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N

CVSS 3.1 SCORE

Base	0 (None)
Temporal	0 (None)
Environmental	0 (None)

CVSS Vector String

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N

22. Forbidden Resource

INFORMATION 1 | CONFIRMED 1

Invicti Standard identified a forbidden resource.

Access to this resource has been denied by the web server. This is generally not a security issue, and is reported here for informational purposes.

Impact

This issue is reported as additional information only. There is no direct impact arising from this issue.

Vulnerabilities

22.1. http://150.1.7.104/dvwa/(%23_memberAccess%3d@ognl.OgnlContext@DEFAULT_MEMBER_ACCESS)%3f(%23wr%3d%23context%5b%23parameters.obj%5b0%5d%5d.getWriter(),%23rs%3d@org.apache.commons.io.IOUtils@toString(@java.lang.Runtime@getRuntime().exec(%23parameters.command[0]).getInputStream()),%23wr.println(%23rs),%23wr.flush(),%23wr.close()):xx.toString.json?&obj=com.opensymphony.xwork2.dispatcher.HttpServletResponse&command=expr%20268409241%20-%2059770

CONFIRMED

Method	Parameter	Parameter Type	Value
GET	URI-BASED	FullUrl	`/(%23_memberAccess%3d@ognl.OgnlContext@DEFAULT_MEMBER_ACCESS)%3f(%23wr%3d%23context%5b%23parameters....`

Request | Response

Request

```
GET
/dvwa/(%23_memberAccess%3d@ognl.OgnlContext@DEFAULT_MEMBER_ACCESS)%3f(%23wr%3d%23context%5b%23parameter
s.obj%5b0%5d%5d.getWriter(),%23rs%3d@org.apache.commons.io.IOUtils@toString(@java.lang.Runtime@getRunti
me().exec(%23parameters.command[0]).getInputStream()),%23wr.println(%23rs),%23wr.flush(),%23wr.close())
:xx.toString.json?
&obj=com.opensymphony.xwork2.dispatcher.HttpServletResponse&command=expr%20268409241%20-%2059770
HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
Cookie: security=high; PHPSESSID=**************
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 3.4112
Total Bytes Received : 739
Body Length : 573
Is Compressed : No

```
HTTP/1.1 403 Forbidden

Server: Apache/2.2.8 (Ubuntu) DAV/2
Content-Length: 573
Content-Type: text/html; charset=iso-8859-1
Date: Fri, 27 Mar 2026 19:55:48 GMT

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access /dvwa/(#_memberAccess=@ognl.OgnlContext@DEFAULT_MEMBER_ACCESS)?
(#wr=#context[#parameters.obj[0]].getWriter(),#rs=@org.apache.commons.io.IOUtils@toString(@java.lang.Ru
ntime@getRuntime().exec(#parameters.command[0]).getInputStream()),#wr.println(#rs),#wr.flush(),#wr.clos
e()):xx.toString.json
on this server.</p>
<hr>
<address>Apache/2.2.8 (Ubuntu) DAV/2 Server at 150.1.7.104 Port 80</address>
</body></html>
```

CLASSIFICATION

OWASP Proactive Controls	C8
ISO27001	A.8.1.1

23. PHP Identified

INFORMATION | 1

Invicti Standard identified a PHP in the target web server's HTTP response.

Impact

This issue is reported as additional information only. There is no direct impact arising from this issue.

Vulnerabilities

23.1. http://150.1.7.104/dvwa/login.php

Certainty

Request | Response

Request

```
GET /dvwa/login.php HTTP/1.1
Host: 150.1.7.104
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Accept-Language: en-us,en;q=0.5
Cache-Control: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/131.0.6778.265 Safari/537.36
```

Response

Response Time (ms) : 172.7328
Total Bytes Received : 1710
Body Length : 1289
Is Compressed : No

```
HTTP/1.1 200 OK
Set-Cookie: PHPSESSID=**************; path=/
Set-Cookie: security=high
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Pragma: no-cache

Expires: Tue, 23 Jun 2009 12:00:00 GMT
Keep-Alive: timeout=15, max=100
Content-Length: 1289
Connection: Keep-Alive
Content-Type: text/html;charset=utf-8
Date: Fri, 27 Mar 2026 19:53:45 GMT
Cache-Control: no-cache, must-revalidate
```

```
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">

<head>

<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

<title>Damn Vulnerable Web App (DVWA) - Login</title>

<link rel="stylesheet" type="text/css" href="dvwa/css/login.css" />

</head>

<body>

<div align="center">

<br />

<p><img src="dvwa/images/login_logo.png" /></p>

<br />

<form action="login.php" method="post">
```

```
<fieldset>

<label for="user">Username</label> <input type="text" class="loginInput" size="20" name="username"><br />


<label for="pass">Password</label> <input type="password" class="loginInput" AUTOCOMPLETE="off" size="20" name="password"><br />


<p class="submit"><input type="submit" value="Login" name="Login"></p>

</fieldset>

</form>


<br />



<br />
<br />
<br />
<br />
<br />
<br />
<br />
<br />

<!-- <img src="dvwa/images/RandomStorm.png" /> -->

<p>Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project</p>
<p>Hint: default username is 'admin' with password 'password' </p>
</div> <!-- end align div -->

</body>

</html>
```

External References

- PHP

CLASSIFICATION

OWASP 2017	A6
CWE	205
WASC	13
ASVS 4.0	14.3.3
NIST SP 800-53	AC-22
DISA STIG	V-16814
OWASP API Top Ten 2019	API7
OWASP Proactive Controls	C7
ISO27001	A.14.2.5
OWASP Top Ten 2021	A05
OWASP API Top 10 2023	API8

CVSS 3.0 SCORE

Base	5.3 (Medium)
Temporal	5.1 (Medium)
Environmental	5.1 (Medium)

CVSS Vector String

CVSS Vector String
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N/E:H/RL:O/RC:C

CVSS 3.1 SCORE	
Base	5.3 (Medium)
Temporal	5.1 (Medium)
Environmental	5.1 (Medium)

CVSS Vector String
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N/E:H/RL:O/RC:C

Show Scan Detail

Enabled Security Checks : **ActiveMQ OpenWire RCE,**
Apache Struts S2-045 RCE,
Apache Struts S2-046 RCE,
Arbitrary Files (IAST),
Code Evaluation,
Code Evaluation (IAST),
Code Evaluation (Out of Band),
Command Injection,
Command Injection (Blind),
Command Injection (IAST),
Configuration Analyzer (IAST),
Content Security Policy,
Content-Type Sniffing,
Cookie,
Cross-Origin Resource Sharing (CORS),
Cross-site Scripting,
Cross-site Scripting (Blind),
Custom Script Checks (Active),
Custom Script Checks (Passive),
Custom Script Checks (Per Directory),

Custom Script Checks (Singular),
Drupal Remote Code Execution,
Expression Language Injection,
File Upload,
GraphQL Library Detection,
Header Analyzer,
Heartbleed,
HSTS,
HTML Content,
HTTP Header Injection,
HTTP Header Injection (IAST),
HTTP Methods,
HTTP Status,
HTTP.sys (CVE-2015-1635),
IFrame Security,
Insecure JSONP Endpoint,
Insecure Reflected Content,
JavaScript Libraries,
JSON Web Token,
LDAP Injection (IAST),
Local File Inclusion,
Local File Inclusion (IAST),
Log4j Code Evaluation (Out of Band),
Login Page Identifier,
Mail Header Injection (IAST),
Malware Analyzer,
Mixed Content,
MongoDB Injection (Blind),
MongoDB Injection (Boolean),
MongoDB Injection (Error Based),
MongoDB Injection (IAST),
MongoDB Injection (Operator),
Open Redirection,
Oracle EBS RCE,
Oracle WebLogic Remote Code Execution,
Referrer Policy,
Reflected File Download,
RegreSSHion Attack,
Remote File Inclusion,
Remote File Inclusion (Out of Band),
Reverse Proxy Detection,
RoR Code Execution,
Security Assertion Markup Language (SAML),
Sensitive Data,
Server-Side Request Forgery (DNS),
Server-Side Request Forgery (Pattern Based),
Server-Side Template Injection,
Server-Side Template Injection (IAST),
Signatures,
Software Composition Analysis (SCA),
Spring4Shell Remote Code Execution,
SQL Injection (Blind),
SQL Injection (Boolean),

		SQL Injection (Error Based), SQL Injection (IAST), SQL Injection (Out of Band), SSL, Static Resources (All Paths), Static Resources (Only Root Path), TorchServe Management, Unicode Transformation (Best-Fit Mapping), VmWare Aria RCE, WAF Identifier, Web App Fingerprint, Web Cache Deception, WebDAV, Windows Short Filename, Wordpress Plugin Detection, Wordpress Theme Detection, XML External Entity, XML External Entity (Out of Band), XML External Entity Injection (IAST), XPath Injection (IAST)
URL Rewrite Mode	:	**Heuristic**
Detected URL Rewrite Rule(s)	:	**/dvwa/login.php/etc/dvwa/{param1}/dvwa, /dvwa/login.php/etc/dvwa/{param1}/dvwa/css, /dvwa/login.php/etc/dvwa/{param1}/dvwa/images**
Excluded URL Patterns	:	**gtm\.js WebResource\.axd ScriptResource\.axd**
Authentication	:	**None**
Authentication Profile	:	**None**
Scheduled	:	**No**
Additional Website(s)	:	**None**